

TERMS AND CONDITIONS

You hereby agree that you will not distribute, display, or otherwise make this document available to an *individual or entity*, unless expressly permitted herein. This document is AWS Confidential Information (as defined in the [AWS Customer Agreement](#)), and you may not remove these terms and conditions from this document, nor take excerpts of this document, without Amazon's express written consent. You may not use this document for purposes competitive with Amazon. You may distribute this document, in its complete form, upon the commercially reasonable request by (1) an end user of your service, to the extent that your service functions on relevant AWS offerings provided that such distribution is accompanied by documentation that details the function of AWS offerings in your service, provided that you have entered into a confidentiality agreement with the end user that includes terms not less restrictive than those provided herein and have named Amazon as an intended beneficiary, or (2) a regulator, so long as you request confidential treatment of this document (each (1) and (2) is deemed a "Permitted Recipient"). You must keep comprehensive records of all Permitted Recipient requests, and make such records available to Amazon and its auditors, upon request.

You further (i) acknowledge and agree that you do not acquire any rights against Amazon's Service Auditors in connection with your receipt or use of this document, and (ii) release Amazon's Service Auditor from any and all claims or causes of action that you have now or in the future against Amazon's Service Auditor arising from this document. The foregoing sentence is meant for the benefit of Amazon's Service Auditors, who are entitled to enforce it. "Service Auditor" means the party that created this document for Amazon or assisted Amazon with creating this document.



System and Organization Controls 2 (SOC 2)
Type 1 Report
Description of AWS European Sovereign Cloud
GmbH's System
Relevant to Security, Availability, and
Confidentiality
as of January 15, 2026

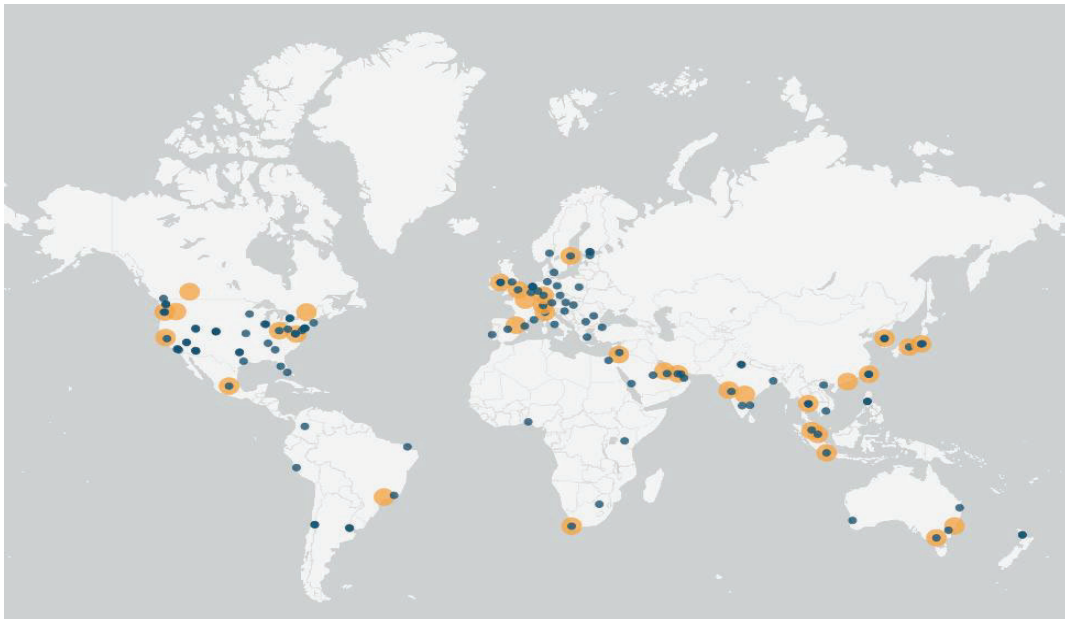




Table of Contents

SECTION I – Independent Service Auditor’s Assurance Report	1
SECTION II – Management Statements	8
SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality as of January 15, 2026	12
AWS European Sovereign Cloud GmbH’s System Overview	13
Shared Responsibility Environment	14
Relevant Aspects of Internal Controls	16
A. Policies	17
B. Communications	20
C. Service Commitments and System Requirements	21
D. Procedures	24
E. Monitoring	58
Complementary User Entity Controls	59
Trust Services Categories, Criteria, and Related Controls	63
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH’s and Amazon Web Services, Inc.’s Controls, Procedures and Results of Procedures	64
Procedures Performed and Results of Entity-Level Controls	65
Trust Services Criteria and Related Controls for Systems and Applications	65
Information System Control Environment	65
AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria	66
AWS Controls & Service Auditor’s Procedures Performed and Results	78
SECTION V – Additional Information Provided by AWS European Sovereign Cloud GmbH	146
Additional information on control non-occurrences	147
APPENDIX	148
Appendix I – Glossary of Terms	149
Appendix II - General Engagement Terms for Wirtschaftsprüferinnen, Wirtschaftsprüfer and Wirtschaftsprüfungsgesellschaften [German Public Auditors and Public Audit Firms] as of January 1, 2024	152

SECTION I – Independent Service Auditor’s Assurance Report

Independent Service Auditor's Assurance Report

To the Management of AWS European Sovereign Cloud GmbH

Scope and Criteria

We have examined AWS European Sovereign Cloud GmbH's accompanying "SECTION III - Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality as of January 15, 2026" ("Description") in accordance with the criteria for a description of a service organization's system set forth in the Description Criteria DC section 200 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report ("Description Criteria") and the suitability of the design of controls stated in the Description as of January 15, 2026 to provide reasonable assurance that the service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability and confidentiality ("Applicable Trust Services Criteria" or "Criteria") set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy, in AICPA Trust Services Criteria*.

The Description covers the services listed on [Page 13 - 14](#) in the Description, as well as the data center locations listed on [Page 14](#) in the Description.

Amazon Web Services Inc. ("AWS Inc.") is an affiliated subservice organization that provides corporate services to AWS European Sovereign Cloud GmbH that constitute part of AWS European Sovereign Cloud GmbH's system ("System"). The Description includes a description of AWS Inc.'s services and the controls designed and operated by AWS Inc. that are necessary for the AWS European Sovereign Cloud GmbH to provide reasonable assurance that its service commitments and system requirements are achieved, based on the Applicable Trust Services Criteria.

The Description indicates that AWS European Sovereign Cloud GmbH's controls can provide reasonable assurance that certain service commitments and system requirements can be achieved only if complementary user entity controls assumed in the design of AWS European Sovereign Cloud GmbH's controls are suitably designed and operating effectively, along with related controls at the service organization. Our examination did not include such complementary user entity controls, and we have not evaluated the suitability of the design or operating effectiveness of such complementary user entity controls.

The information in the accompanying *"SECTION V - Additional Information Provided by AWS European Sovereign Cloud GmbH"* is presented by management of AWS European Sovereign Cloud GmbH to provide additional information and is not a part of the Description. Such information has not been subjected to the procedures applied in our examination and accordingly we express no opinion on it.

AWS European Sovereign Cloud GmbH's responsibilities

AWS European Sovereign Cloud GmbH is responsible for designing, implementing, and operating effective controls within the System to provide reasonable assurance that the Criteria were achieved. AWS European Sovereign Cloud GmbH has provided the accompanying assertion titled, *"Management Statement of AWS European Sovereign Cloud GmbH"* in *"SECTION II - Management Statements"* ("AWS European Sovereign Cloud GmbH Assertion") about the presentation of the Description based on the Description Criteria, and suitability of the design and operating effectiveness of the controls described therein to provide reasonable assurance that the service commitments and system requirements would be achieved based on the Applicable Trust Services Criteria. AWS European Sovereign Cloud GmbH is responsible for (1) preparing the Description and AWS European Sovereign Cloud GmbH Assertion; (2) the completeness, accuracy, and method of presentation of the Description and AWS European Sovereign Cloud GmbH Assertion; (3) providing the services covered by the Description; (4) identifying the risks that would threaten the achievement of the Criteria; and (5) designing, implementing, and documenting controls that are suitably designed to achieve its service commitments and system requirements.

AWS Inc.'s responsibilities

AWS Inc. has provided the accompanying assertion titled, *"Management Statement of Amazon Web Services, Inc."* in *"SECTION II - Management Statements"* (AWS Inc. Assertion) about the presentation of the portion of the Description related to AWS Inc.'s Services based on the Description Criteria and suitability of the design of AWS Inc.'s controls stated therein based on the relevant portions of Applicable Trust Services Criteria. For the aforementioned portion of the Description related to the services provided by AWS Inc., management of AWS Inc. is responsible for (1) preparing that portion of the Description, including the completeness, accuracy, and method of presentation. AWS Inc. is responsible for preparing the AWS Inc. Assertion, including its completeness, accuracy, and method of presentation, providing the services described in the Description, and designing, implementing, operating, and documenting controls that are suitably designed to achieve or help achieve the service commitments and system requirements for the European Sovereign Cloud based on

the Applicable Trust Services Criteria either wholly or in conjunction with controls implemented by AWS European Sovereign Cloud GmbH.

Service auditor's responsibilities

Our responsibility is to express an opinion on the fairness of the presentation of the Description and on the suitability of the design of the controls described therein to meet the Criteria, based on our procedures.

Our engagement was conducted in accordance with German law and ISAE 3000 (Revised), Assurance Engagements Other Than Audits or Reviews of Historical Financial Information, issued by the International Auditing and Assurance Standards Board (IAASB). That standard requires that we plan and perform our procedures to obtain reasonable assurance about whether, in all material respects, (1) the Description is presented in accordance with the Description Criteria, and (2) the controls described therein are suitably designed to provide reasonable assurance that the service organization's service commitments and system requirements were achieved based on the Applicable Trust Services Criteria as of January 15, 2026. The nature, timing, and extent of the procedures selected depend on our judgment, including an assessment of the risk of material misstatement, whether due to fraud or error. We believe that the evidence we have obtained is sufficient and appropriate to provide a reasonable basis for our opinion.

A reasonable assurance engagement of a description of a service organization's System and the suitability of the design of controls involves:

- ▶ Obtaining an understanding of the System and the service organization's service commitments and system requirements.
- ▶ Assessing the risks that the Description is not presented in accordance with the Description Criteria and that controls were not suitably designed based on the Applicable Trust Services Criteria.
- ▶ Performing procedures to obtain evidence about whether the controls stated in the Description are presented in accordance with the Description Criteria.
- ▶ Performing procedures to obtain evidence about whether controls stated in the Description were suitably designed to provide reasonable assurance that the service organization achieved its service commitments and system requirements based on the Applicable Trust Services Criteria.
- ▶ Evaluating the overall presentation of the Description.

Our engagement also included performing such other procedures as we considered necessary in the circumstances.

Our examination was not conducted for the purpose of evaluating the performance or integrity of AWS European Sovereign Cloud GmbH's and AWS Inc.'s AI services. Accordingly, we do not express an opinion or any other form of assurance on the performance or integrity of AWS European Sovereign Cloud GmbH's and AWS Inc.'s AI services.

Our Independence and Quality Control

The quality control system of EY GmbH & Co. KG Wirtschaftsprüfungsgesellschaft is based on national legislation and professional pronouncements, in particular the professional charter for public accountants and chartered accountants as well as the IDW Qualitätsmanagementstandard (Standards on Quality Control): „Anforderungen an das Qualitätsmanagement in der Wirtschaftsprüferpraxis (IDW QMS 1 (09.2022))“, that are consistent with the International Standards on Quality Control issued by the International Auditing and Assurance Standards Board (IAASB).

We are independent from AWS European Sovereign Cloud GmbH and AWS Inc. in terms of German commercial law and professional regulations, and we are compliant with other, related professional requirements.

Inherent limitations

There are inherent limitations in the effectiveness of any system of internal control, including the possibility of human error and the circumvention of controls. Because of their nature, controls at a service organization or subservice organization may not always operate effectively to provide reasonable assurance that the service organization's service commitments and system requirements are achieved based on the Applicable Trust Services Criteria. Also, the projection to the future evaluation of the presentation of the Description or conclusions about the suitability of the design or operating effectiveness of the controls to achieve the service commitments and system requirements based on the Applicable Trust Services Criteria, is subject to the risk that the system may change or that controls may become ineffective.

Other matters

We did not perform any procedures regarding the operating effectiveness of controls stated in the description, and, accordingly, do not express an opinion thereon. Our performed procedures are listed in *"SECTION IV - Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures"*.

As noted in the *"SECTION IV - Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures"*, circumstances that warrant the operation of the control AWSCA-20.1 (see page [133](#)) related to the SOC 2 criteria CC1.2, CC1.5 and CC4.2 did not occur since the implementation of the control and as of January 15, 2026. As a result, we did not perform a walkthrough on the implementation of the control and therefore cannot confirm the achievement of the related SOC 2 criteria CC1.2, CC1.5 and CC4.2. Our opinion is not modified in respect of this matter.

Opinion

In our opinion, in all material respects:

- a. The Description presents the AWS European Sovereign Cloud GmbH's system that was designed and implemented as of January 15, 2026, in accordance with the Description Criteria.
- b. The controls stated in the Description, including the controls designed and operated by AWS European Sovereign Cloud GmbH and AWS Inc. were suitably designed as of January 15, 2026 to provide reasonable assurance that the service commitments and system requirements for the AWS European Sovereign Cloud would be achieved based on the Applicable Trust Services Criteria if user entities applied the complementary controls assumed in the design of AWS European Sovereign Cloud GmbH's and AWS Inc.'s controls as of January 15, 2026.

Restricted use

This report, including the description of procedures and results thereof in *"SECTION IV - Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures"*, is intended solely for the information and use of AWS European Sovereign Cloud GmbH, user entities of AWS European Sovereign Cloud GmbH's system as of January 15, 2026,

and prospective user entities, independent auditors, and practitioners providing services to such user entities who have a sufficient knowledge and understanding of the following:

- The nature of the service provided by the service organization.
- How the service organization's System interacts with user entities, subservice organizations, or other parties including complementary user entity controls assumed in the design of the service organization's controls.
- Internal controls and their limitations.
- Complementary user entity controls and how those controls interact with the controls at the service organization to achieve the service organization's service commitments and system requirements.
- The Applicable Trust Services Criteria.
- The risks that may threaten the achievement of the service organization's service commitments and system requirements and how controls address those risks.

This report is not intended to be, and should not be, used by anyone other than these specified parties.

We issue this Independent Service Auditor's Assurance Report on the basis of the engagement agreement concluded with AWS European Sovereign Cloud GmbH dated November 26, 2025, which is governed, also in relation to third-parties, by the attached "General Engagement Terms for Wirtschaftsprüferinnen, Wirtschaftsprüfer and Wirtschaftsprüfungsgesellschaften [German Public Auditors and Public Audit Firms]" dated January 1, 2024, which include a liability arrangement. In acknowledging and using the information contained in this report, the recipient acknowledges the provisions made therein (including the liability provisions in no. 9 of the General Engagement Terms), acknowledging also that they apply in relation to us.

Mannheim, February 27, 2026

EY GmbH & Co. KG
Wirtschaftsprüfungsgesellschaft



Mathias
Feil
Mathias Feil
Partner



Alex
Fox
ppa. Alex Fox
Senior Manager



SECTION II – Management Statements



Management Statement of AWS European Sovereign Cloud GmbH

We have prepared the accompanying description of AWS European Sovereign Cloud GmbH's ("AWS European Sovereign Cloud Entity") system ("System") titled *"SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality as of January 15, 2026"* ("Description") in accordance with the criteria for a description of a service organization's system set forth in the Description Criteria DC section 200 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report ("Description Criteria").

The Description is intended to provide report users with information about the AWS European Sovereign Cloud services system that may be useful when assessing the risks arising from interactions with the System, particularly information about system controls that the Service Organization has designed, implemented and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability and confidentiality ("Applicable Trust Services Criteria" or "Criteria") set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy, in AICPA Trust Services Criteria*. The Description covers AWS European Sovereign Cloud Entity's services and the data center locations listed in paragraph "AWS European Sovereign Cloud GmbH's System Overview" in the Description.

Amazon Web Services, Inc. ("AWS Inc.") is an affiliated subservice organization that performs controls specified in the Description that constitute a part of our AWS European Sovereign Cloud Entity's system. The Description includes a description of AWS Inc.'s services and controls relevant to the service commitments and system requirements. AWS Inc. has provided the accompanying assertion titled, "Management Statement of Amazon Web Services, Inc." about the Description relevant to the services provided by AWS Inc. and suitability of the design, of the aforementioned controls.

The Description indicates that certain Criteria can be achieved only if complementary user entity controls assumed in the design of AWS European Sovereign Cloud Entity's controls are suitably designed and operating effectively, along with related controls at the service organization. The Description does not extend to controls of the user entities.

We confirm, to the best of our knowledge and belief, that:

- a. The Description presents the System that was designed and implemented as of January 15, 2026, in accordance with the Description Criteria.
- b. The controls stated in the Description were suitably designed as of January 15, 2026 to provide reasonable assurance that AWS European Sovereign Cloud Entity's service commitments and system requirements would be achieved based on the Applicable Trust Services Criteria, if and if user entities applied the complementary user entity controls assumed in the design of AWS European Sovereign Cloud Entity's controls as of January 15, 2026



Non-occurrence

As of January 15, 2026, the circumstances that warrant the operation of the control AWSCA-20.1 related to SOC 2 criteria CC1.2, CC1.5, CC4.2 did not occur since its implementation.

Stéphane Israël
Managing Director
AWS European Sovereign Cloud GmbH

February 27, 2026



Management Statement of Amazon Web Services, Inc.

We have read the portion of the accompanying description titled *"Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality as of January 15, 2026"* ("Description") of AWS European Sovereign Cloud GmbH ("Service Organization" or "AWS European Sovereign Cloud Entity") related to Amazon Web Services, Inc. ("AWS Inc.") controls in accordance with criteria for a description of a service organization's system set forth in the Description Criteria DC section 200 2018 Description Criteria for a Description of a Service Organization's System in a SOC 2 Report ("Description Criteria").

The Description is intended to provide report users with information about the AWS European Sovereign Cloud services system that may be useful when assessing the risks arising from interactions with the System as of January 15, 2026, particularly information about the system controls that AWS European Sovereign Cloud Entity and Amazon Web Services, Inc. has designed, implemented, and operated to provide reasonable assurance that its service commitments and system requirements were achieved based on the trust services criteria relevant to security, availability and confidentiality ("Applicable Trust Services Criteria" or "Criteria") set forth in TSP section 100, *2017 Trust Services Criteria for Security, Availability, Processing Integrity, Confidentiality, and Privacy, in AICPA Trust Services Criteria*.

The Description also indicates complementary user entity controls that need to be suitably designed are necessary to meet certain Criteria along with the Service Organization's and AWS Inc's related controls. The Description presents AWS Inc's controls and the complementary user entity controls assumed in the design of AWS Inc's controls. The Description does not extend to controls of user entities.

We confirm, to the best of our knowledge and belief, that as it relates to the services provided by AWS Inc. to AWS European Sovereign Cloud Entity's part of AWS European Sovereign Cloud Entity's system ("Services"):

- a. The Description presents the Services provided by AWS Inc. in accordance with the Description Criteria.
- b. The controls stated in the Description, in combination with the controls designed by AWS European Sovereign Cloud Entity, were suitably designed as of January 15, 2026, to provide reasonable assurance that AWS European Sovereign Cloud Entity's service commitments and system requirements would be achieved based on the Applicable Trust Services Criteria, if the controls operated effectively and user entities applied the complementary user entity controls assumed in the design of AWS Inc.'s controls as of January 15, 2026.

Sara Duffer
Vice President, AWS Security Assurance
Amazon Web Services, Inc.

February 27, 2026



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality as of January 15, 2026



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

AWS European Sovereign Cloud GmbH’s System Overview

Since 2006, Amazon Web Services, Inc. has provided flexible, scalable and secure IT infrastructure to businesses of all sizes around the world. With Amazon Web Services Inc., customers can deploy solutions in a cloud computing environment that provides compute power, storage, and other application services over the Internet as their business needs demand. Amazon Web Services Inc. affords businesses the flexibility to employ the operating systems, application programs, and databases of their choice. Starting in 2026 these services are now also being offered in a dedicated European Sovereign Cloud by AWS European Sovereign Cloud GmbH.

AWS European Sovereign Cloud GmbH (“AWS European Sovereign Cloud Entity”) is incorporated in Potsdam, Germany, and is the responsible legal entity operating the AWS European Sovereign Cloud. The AWS European Sovereign Cloud is a dedicated cloud in the EU, including infrastructure and services made available through AWS European Sovereign Cloud Region, that is physically and logically separated from other AWS Regions.

Amazon Web Services, Inc. (“AWS Inc.”) operates certain controls upon which the AWS European Sovereign Cloud Entity control environment relies. Controls related to service design and development remain under the responsibility of AWS Inc., while AWS European Sovereign Cloud Entity is responsible for the operation of these services within the AWS European Sovereign Cloud. This report is inclusive of the controls operated by AWS Inc. that are relevant to the AWS European Sovereign Cloud Entity's system and the applicable trust services criteria.

Both AWS European Sovereign Cloud Entity and AWS, Inc. (collectively referred to as “AWS” in this report) are subsidiaries of Amazon.com (“Amazon” or “the Company”). Within these entities, teams are organized by individual web services, such as Amazon EC2, Amazon S3, Amazon VPC, Amazon EBS, and Amazon RDS.

The scope of this system description includes the following AWS services available in AWS European Sovereign Cloud Region:

- Amazon API Gateway
- Amazon Athena
- Amazon Bedrock [excludes Amazon Bedrock Marketplace]
- Amazon CloudWatch
- Amazon Cognito
- Amazon Data Firehose
- Amazon DynamoDB
- Amazon EC2 Auto Scaling
- Amazon Elastic Block Store (EBS)
- Amazon Elastic Compute Cloud (EC2)
- Amazon Elastic Container Registry (ECR)
- Amazon Elastic Container Service
- Amazon Elastic File System (EFS)
- Amazon Elastic Kubernetes Service (EKS)
- Amazon Virtual Private Cloud (VPC)
- AWS Artifact
- AWS Backup
- AWS Batch
- AWS Certificate Manager (ACM)
- AWS Cloud Map
- AWS CloudFormation
- AWS CloudTrail
- AWS CodeDeploy
- AWS Config
- AWS Control Tower
- AWS Database Migration Service (DMS)
- AWS DataSync
- AWS Direct Connect
- AWS Directory Service [excludes Simple AD]



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

- Amazon Elastic MapReduce (EMR)
- Amazon ElastiCache
- Amazon EventBridge
- Amazon FSx
- Amazon GuardDuty
- Amazon Kinesis Data Streams
- Amazon Managed Service for Apache Flink
- Amazon Managed Streaming for Apache Kafka
- Amazon Neptune
- Amazon OpenSearch Service
- Amazon Redshift
- Amazon Relational Database Service (RDS)
- Amazon Route 53
- Amazon SageMaker AI [excludes Studio Lab, Public Workforce and Vendor Workforce for all features]
- Amazon Simple Email Service (SES)
- Amazon Simple Notification Service (SNS)
- Amazon Simple Queue Service (SQS)
- Amazon Simple Storage Service (S3)
- Amazon Simple Workflow Service (SWF)
- AWS Glue
- AWS Health Dashboard
- AWS Identity and Access Management (IAM)
- AWS Key Management Service (KMS)
- AWS Lake Formation
- AWS Lambda
- AWS License Manager
- AWS Organizations
- AWS Private Certificate Authority
- AWS Resource Access Manager (RAM)
- AWS Secrets Manager
- AWS Security Hub CSPM
- AWS Shield
- AWS Step Functions
- AWS Storage Gateway
- AWS Systems Manager
- AWS Transfer Family
- AWS WAF
- AWS X-Ray
- EC2 Image Builder
- Elastic Load Balancing (ELB)

More information can be found at the following web address: <https://aws.eu/compliance/>.

The scope of locations covered in this report includes the supporting data centers located in the following region:

- **EU:** AWS European Sovereign Cloud (Germany) (eusc-de-east-1)

Shared Responsibility Environment

When customers migrate their IT infrastructure to services offered by AWS European Sovereign Cloud Entity, it builds a shared responsibility model between the customers and AWS European Sovereign Cloud Entity. AWS European Sovereign Cloud Entity operates, manages, and controls the components from the host operating system and virtualization layer down to the physical security of the facilities in which the services operate. In turn, customers assume responsibility and management of the design, implementation and operation of their AWS European Sovereign Cloud environment, which may include guest operating systems (including updates and security patches), other associated application software, as well as the configuration of the AWS-provided security group firewall. Customers should carefully consider the services they choose as customer responsibilities vary depending on the services they use, the integration of those services into their IT environments, and applicable laws and regulations. It is possible to enhance security and/or meet more stringent compliance requirements by leveraging technology such as host-based firewalls, host-based intrusion detection/prevention, and encryption. AWS provides tools and information to assist customers in their efforts to account for and to validate that controls are operating effectively in their extended IT environment. More information



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

can be found on the AWS European Sovereign Cloud Compliance center at <https://aws.eu/compliance/>.

AWS European Sovereign Cloud offers a variety of different infrastructure and platform services. More information can be found on the AWS Shared Responsibility Model at <https://aws.amazon.com/compliance/shared-responsibility-model/> which is also applicable to AWS European Sovereign Cloud. For the purpose of understanding security and shared responsibility for AWS services, AWS has categorized its services into three main categories: infrastructure, container, and abstracted. Each category comes with a slightly different security ownership model based on how customers interact and access the functionality. Customer responsibility is determined by the AWS European Sovereign Cloud services that a customer selects. This determines the amount of configuration work the customer must perform as part of their security responsibilities.

Infrastructure Services: Services such as Amazon Elastic Compute Cloud (Amazon EC2) and Amazon Virtual Private Cloud (Amazon VPC) are categorized as Infrastructure Services and, as such, require the customer to perform the necessary security configuration and management tasks. If a customer deploys an Amazon EC2 instance, that customer is responsible for management of the guest operating system (including updates and security patches), any application software or utilities installed by the customer on the instances, and the configuration of the AWS-provided firewall (called a security group) on each instance.

Container Services: Services in this category typically run separately on Amazon EC2 or other infrastructure instances, but sometimes customers are not required to manage the operating system or the platform layer. AWS provides a managed service for these application “containers”. Customers are responsible for setting up and managing network controls, such as firewall rules, and for managing platform-level identity and access management separately from IAM. Examples of container services include Amazon Relational Database Services (Amazon RDS), Amazon Elastic Map Reduce (Amazon EMR).

Abstracted Services: This category includes high-level storage, database, and messaging services, such as Amazon Simple Storage Service (Amazon S3), Amazon DynamoDB, Amazon Simple Queuing Service (Amazon SQS), and Amazon Simple Email Service (Amazon SES). These services abstract the platform or management layer on which the customers can build and operate cloud applications. The customers access the endpoints of these abstracted services using AWS Application Programming Interfaces (APIs), and AWS European Sovereign Cloud Entity manages the underlying service components or the operating system on which they reside.

As every customer deploys their environment differently in AWS European Sovereign Cloud, customers can take advantage of shifting the management of certain IT controls to AWS European Sovereign Cloud, which results in a (new) distributed control environment. Customers can then use the AWS control and compliance documentation available to them to perform their control evaluation and verification procedures as required. Certain functions of services have been identified as controls in the system description and are denoted as “service-specific” as they are unique to the respective service.

More information and examples on the AWS Security Best Practices can be found at <https://aws.amazon.com/architecture/security-identity-compliance/>.

Furthermore, AWS publishes security blogs that cover best practices around using AWS services at <https://aws.amazon.com/blogs/security/tag/best-practices/>.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Relevant Aspects of Internal Controls

As defined by the American Institute of Certified Public Accountants (AICPA), internal control is a process affected by an entity’s board of directors, management, and other personnel and consists of five interrelated components:

- **Control Environment** – Sets the tone of an organization, influencing the control consciousness of its people. It is the foundation for all other components of internal control, providing discipline and structure.
- **Risk Assessment** – The entity’s identification and analysis of relevant risks to the achievement of its objectives, forming a basis for determining how the risks should be managed.
- **Information and Communication** – Surrounding these activities are information and communication systems. These enable the entity’s people to capture and exchange information needed to conduct and control its operations.
- **Monitoring** – The entire process must be monitored, and modifications made as necessary. In this way, the system can react dynamically, changing as conditions warrant.
- **Control Activities** – Control policies and procedures must be established and executed to help ensure that the actions identified by management as necessary to address risks to the achievement of the entity’s objectives are effectively carried out.

This section briefly describes the essential characteristics and other interrelated components of internal controls in achieving the service commitments and system requirements for the applicable trust services criteria of security, availability, and confidentiality as they pertain to AWS European Sovereign Cloud Entity that may be relevant to customers in five broad areas:

- **Policies (Control Environment and Risk Management)** – The entity has defined and documented its policies relevant to the applicable trust services criteria.
- **Communications (Information and Communication)** – The entity has communicated its defined policies to responsible parties and authorized users of the system.
- **Service Commitments and System Requirements (Control Activities)** – The entity has communicated its service commitments and system requirements to customers in accordance with customer agreements.
- **Procedures (Control Activities)** – The entity has placed in operation procedures to achieve service commitments and systems requirements in accordance with its defined policies.
- **Monitoring** – The entity monitors the system and takes action to maintain compliance with its defined policies.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

A. Policies

A.1 Control Environment

AWS European Sovereign Cloud Entity and AWS Inc. (collectively referred to as “AWS” in this report) are subsidiaries of Amazon.com (“Amazon” or “the Company”). Within these entities, teams are organized by individual web services, such as Amazon EC2, Amazon S3, Amazon VPC, Amazon EBS, and Amazon RDS.

AWS European Sovereign Cloud Entity leverages some aspects of AWS Inc., as well as Amazon's overall control environment, in the delivery of these web services. The collective control environment encompasses management and employee efforts to establish and maintain an environment that supports the effectiveness of specific controls.

AWS Inc. maintains internal informational websites describing the AWS environment, its boundaries, user responsibilities and services (**Control AWSCA-9.1**).

The control environment at Amazon begins at the highest level of the Company. Executive and senior leadership play important roles in establishing the Company’s core values and tone at the top. The Company’s Code of Business Conduct and Ethics, which sets guiding principles, is made available to every employee.

Amazon is committed to having highly qualified members as a part of its Board of Directors (Board) (**Control AWSCA-1.7**). Annually, the Amazon Corporate Governance Committee provides each Board member a questionnaire that establishes whether they are independent and qualified to serve on each Board or Committee under the applicable rules. The Corporate Governance Committee periodically reviews and assesses the composition of the Board and evaluates the overall Board performance during the annual assessment of individual Board members. The Leadership Development and Compensation Committee, with the full Board present, annually evaluates the succession plan for each member of the Senior Management team (**Control AWSCA-1.8**). This includes the annual Company and CEO performance and succession plan.

Additionally, AWS European Sovereign Cloud Entity has established an independent advisory board for the AWS European Sovereign Cloud. The advisory board consists of at least four members, all EU citizens residing in the EU, including at least one independent board member who is not affiliated with Amazon. The advisory board acts as a source of expertise and provides accountability on sovereignty-related aspects of the AWS European Sovereign Cloud operations (**Control AWSCA-20.1**).

AWS is committed to protecting its customers’ data and maintaining compliance with applicable regulatory requirements. This is demonstrated by the consolidated annual operational plan that includes regulatory and compliance requirements and objectives to enable the identification and assessment of risks relating to those objectives (**Control AWSCA-1.9**). AWS’ policies and procedures outline the required guidance for operation and information security that supports AWS environments, acceptable use of mobile devices, and access to data content and network devices (**Control AWSCA-3.16**). Periodically, AWS employees are required to review and comply with the most current versions of applicable policies and procedures.

Amazon has set up an ethics hotline for the employees or third-party contractors to report misconduct or violation of AWS policies, practices, rules, requirements or procedures (**Control AWSCA-9.6**). Material violations of the Company Code of Business Conduct and Ethics or any other similar policies



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

are appropriately handled accordingly which may include disciplinary action or termination of employment. Violations by vendors or third-party contractors are reported by Amazon to their employers for disciplinary action, removal of assignment with Amazon, or termination (**Control AWSCA-9.7**).

Amazon Internal Audit has implemented a formal audit program that monitors and audits controls that are designed to protect against organizational risks and safeguard Customer Content. This includes external independent assessments against regulatory, internal and external control frameworks (**Control AWSCA-9.8**). The internal and external audits are planned, performed and reported to the Audit Committee. Amazon Internal Audit conducts audits according to a documented schedule. They review the audit plan and communicate the audit requirements to the Audit Committee. These requirements are based on standard criteria that verify AWS compliance with relevant regulatory obligations and reported risk areas.

AWS Artifact is the primary resource for customers to obtain compliance-related information from AWS. It provides access to AWS Inc., and AWS European Sovereign Cloud Entity security and compliance reports and select online agreements. Reports available in AWS Artifact include also: AWS European Sovereign Cloud System and Organization Controls (SOC) reports, AWS European Sovereign Cloud C5 report, and certifications from accreditation bodies across the AWS European Sovereign Cloud region and industry verticals that validate the implementation and operating effectiveness of AWS European Sovereign Cloud Entity’s security controls. Amongst other things, compliance reports and certificates are made available to customers to enable them to evaluate AWS European Sovereign Cloud Entity’s conformance with security controls and associated compliance obligations.

AWS’ organizational structure provides a framework for planning, executing and controlling business operations (**Control AWSCA-1.1**). AWS leadership assigns roles and responsibilities based on the AWS organizational structure to provide for adequate staffing, efficiency of operations and the segregation of duties. Management has also established authority and appropriate lines of reporting for key personnel. The Company follows a structured on-boarding process to assist new employees as they become familiar with Amazon tools, processes, systems, policies and procedures.

AWS performs a formal evaluation of the appropriate resourcing and staffing to align employee qualifications with the entity’s business objectives to support the achievement of the entity’s business objectives. Appropriate feedback is given to the employee on strengths and growth areas during the annual performance review process. Employee strength and growth evaluations are shared by the employee’s manager with the employee (**Control AWSCA-9.3**).

AWS Inc. has established an information security framework. As part of this framework, AWS Inc. periodically reviews and updates the security policies, provides security training to AWS European Sovereign Cloud Staff, which includes instruction on the Data Handling and Classification Standards applicable to the AWS European Sovereign Cloud (**Control AWSCA-20.7**). Additionally, the AWS Application Security (AppSec) team performs security reviews of AWS applications. These reviews assess the availability, confidentiality, and integrity of data, as well as conformance to the security policies. Where necessary, AWS European Sovereign Cloud security teams leverage the security framework and security policies established and maintained by AWS Inc., and Amazon Corporate Information Security.

AWS Inc. has an approval process in place to review environmental and geo-political risks before launching a new region (**Control AWSCA-1.10**). Risk assessments encompass reviews of natural catastrophe (e.g., extreme weather events), technological (e.g., fire, nuclear radiation, industrial pollution) and man-made (e.g., vehicle impact, intentional acts, geo-political) hazards, including



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

exposures presented by nearby entities; as applicable. In addition to site-specific considerations, AWS Inc. evaluates scenarios potentially affecting separate Availability Zones (AZs) within the AWS European Sovereign Cloud region.

A.2 Risk Management

AWS Inc. maintains a formal risk management program to identify, analyze, mitigate, continuously monitor and report on risks that affect AWS’ business objectives, regulatory requirements, and customers. The AWS Enterprise Risk Management (ERM) team identifies enterprise risks, documents them in a risk register, and reports results to leadership at least on a semi-annual basis. The risk management program consists of the following phases:

1) Identifying Risks

ERM has developed a tailored approach to identifying enterprise risks across the business. The approach is:

- Bottom-up which focuses on internal mechanisms and data to identify risks;
- Top down to gather information from key leaders and external sources; and
- Risk intelligence leveraged from internal and external sources which may provide insights on persistent issues, major events, and industry trends.

2) Analyzing and Rating Risks

ERM analyses and rates the inherent impact and likelihood of each enterprise risk. The inherent impact and likelihood provide a view of the risk without consideration of existing mitigating activities. ERM review the inherent impact and inherent likelihood ratings with the risk owner as part of the risk review process and the risk owner determines the final ratings. Existing mitigating activities are documented.

3) Determining Risk Mitigation Areas

The ERM team and risk owners define the risk threshold for each enterprise risk. The risk threshold triggers when additional mitigation activities may be needed to reduce the risk to within the defined threshold. The inherent risk rating, mitigating activities and risk threshold are used to determine the residual risk category. There are three residual risk categories:

- Monitor – indicates no additional action is required;
- Optimize – indicates that additional mitigating activities may be recommended; and
- Improve – indicates that additional mitigating activities may be required.

Where additional mitigating activities are determined to be needed, the risk owner is responsible for ensuring this occurs and the ERM team will review the status of additional mitigating activities during risk reviews.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

4) Monitoring and Reporting Risks

The ERM team monitors active risks being tracked within the risk register, at a cadence defined by the residual risk category. Reports are provided to senior leadership at least on a semi-annual basis. Reports may include important information about key risks and treatments, as well as emerging trends and general program updates (**Control AWSCA-1.5**).

In addition to the ERM Risk Assessment, Internal Audit performs a separate Risk Assessment to identify and prioritize significant AWS risks and uses this information to define the audit plan. The Risk Assessment incorporates input from multiple sources such as changes to the business, internal audits, operational events, and emerging risks. The audit plan and changes to the plan during the year are presented to the Audit Committee. Internal Audit also communicates significant audit findings and associated action plans to the Audit Committee.

Additionally, at least on a monthly basis, AWS’ management reviews the AWS European Sovereign Cloud operational metrics and Correction of Errors (COEs) to improve the overall availability of AWS services and to identify areas of improvements while mitigating risks to AWS environments. The “COE” documents are used to perform deep root cause analysis of certain incidents across AWS European Sovereign Cloud, document actions taken, and assign follow-up action items and owners to track to resolution.

B. Communications

AWS has implemented various methods of internal communication to help AWS European Sovereign Cloud Staff understand their individual roles and responsibilities and to communicate significant events in a timely manner. These methods include orientation and training programs for newly hired employees; annual training programs are tailored based on employee roles and responsibilities and may include Amazon Security Awareness (ASA) (**Control AWSCA-1.4**), AWS European Sovereign Cloud access Orientation Training, Software Developer Engineer (SDE) Bootcamp, International Traffic in Arms Regulations (ITAR) Secure Coding Training, Threat Modeling the Right Way for Amazon Builders, Fraud/Bribery/Foreign corrupt practices training, Privacy Engineering Foundations for AWS Service Teams training, Managing Third Parties Using the Third-Party Risk Management Lifecycle, Export Compliance trainings; regular management meetings for updates on business performance and other matters; and electronic means such as video conferencing, electronic mail messages, and the posting of information via the Amazon intranet on topics such as reporting of information security incidents and guidelines describing change management. The AWS Internal Privacy Policy informs AWS employees and applicable vendors/contractors about AWS’ requirements regarding the privacy of customers’ personal information in accordance with applicable legislation and other AWS obligations. The dedicated AWS European Sovereign Cloud Access Orientation Training and Data Handling and Classification Standard guide AWS European Sovereign Cloud Staff in protecting AWS data including Customer Content and Customer-Created Metadata and maintaining appropriate data handling standards in the AWS European Sovereign Cloud (**Control AWSCA-20.7**).

AWS offers customers the ability to update their communication preferences through the AWS European Sovereign Cloud console or via the AWS Email Preference Center (**Control AWSCA-12.3**). When customers update their communication preferences using their email, their updated preferences are saved. Customers can unsubscribe from AWS marketing emails within the AWS European Sovereign Cloud console. AWS Customers will still receive important account-related



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

notifications from AWS, such as monthly billing statements, or if there are significant changes to a service that customers use.

AWS provides authenticated AWS European Sovereign Cloud customers the ability to access, update, and confirm their data. Denial of access will be communicated using the AWS console (**Control AWS-12.6**). Customers can sign into their AWS accounts through the AWS console to view and update their data.

C. Service Commitments and System Requirements

C.1 Service Commitments

AWS European Sovereign Cloud Entity communicates service commitments to user entities (AWS European Sovereign Cloud customers) in the form of Service Level Agreements (SLAs), the AWS European Sovereign Cloud Addendum (ESCA: <https://aws.eu/esca/>), the AWS Customer Agreement (<https://aws.amazon.com/agreement/>) other contracts, or the descriptions of the service offerings provided online through the AWS website. More information regarding Service Level Agreements can be found at <https://aws.amazon.com/legal/service-level-agreements/>.

AWS European Sovereign Cloud Entity maintains Customer Content and Customer-Created Metadata within the EU, except where instructed by customers or as necessary to comply with a valid and binding order of a governmental body (**Control AWS-20.6**). To enforce this commitment, AWS European Sovereign Cloud Entity implements a combination of organizational and technical controls. AWS European Sovereign Cloud Staff receive dedicated access orientation training on data residency requirements and their obligations regarding the handling of Customer Content and Customer-Created Metadata. AWS has established data handling and classification standards specific to the AWS European Sovereign Cloud, which are reviewed and approved annually by authorized personnel, ensuring consistent identification and treatment of Customer Content and Customer-Created Metadata (**Control AWS-20.7**). External data transfers made by AWS services to the AWS infrastructure outside of the AWS European Sovereign Cloud are initiated by AWS European Sovereign Cloud Staff only, and are routed through controlled and monitored channels, with controls in place to identify transfers that bypass the approved data transfer mechanism. AWS European Sovereign Cloud Entity maintains an egress transfer approval mechanism requiring AWS service teams to document justification, scope and authorization for external transfers to ensure that Customer Content and Customer-Created Metadata remain within the EU, except where instructed by customers or as necessary to comply with a valid and binding order of a governmental body. The approved transfers are subject to periodic reviews to confirm their continued validity and scope (**Control AWS-20.15**). Additionally, AWS European Sovereign Cloud Entity operates egress detection and monitoring systems and performs regular risk-based reviews of sampled transfers, supplemented by pattern analysis, to verify compliance with data residency requirements. Together, these controls enforce the commitment that Customer Content and Customer-Created Metadata does not leave the EU except under the conditions stated above (**Control AWS-20.6**).

AWS European Sovereign Cloud uses various methods of external communication to support its customers and the community. Mechanisms are in place to allow the AWS European Sovereign Cloud Support Escalation and Event Management (E2M) team to be notified and to notify customers of potential operational issues that could impact the customer experience. AWS Health Dashboard is available to alert customers of “General Service Events” which show the health of all AWS European



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Sovereign Cloud services and “Your Account Events” which show events specific to the account. Current status information can be checked by the customer on this site or by leveraging Amazon EventBridge Integrations or RSS feeds, which allow customers to be notified of interruptions to individual services. Details related to security and compliance with AWS Sovereign Cloud Entity can also be obtained on the [AWS Security Center](#) and [AWS Sovereign Cloud Entity Compliance](#) websites.

Customers can contact AWS European Sovereign Cloud Entity through the ‘[Contact us](#)’ page for issues related to AWS European Sovereign Cloud services. AWS European Sovereign Cloud provides publicly available mechanisms for external parties to contact AWS European Sovereign Cloud to report security events and publishes information including a system description and security and compliance information addressing AWS European Sovereign Cloud commitments and responsibilities (**Control AWSCA-9.5**). Customers can also subscribe to Premium Support offerings that include direct communication with the customer support team and proactive alerts for any customer impacting issues. AWS European Sovereign Cloud customer support is provided by AWS European Sovereign Cloud Staff who are EU residents employed by AWS entities registered in the EU (**Control AWSCA-20.4**). AWS European Sovereign Cloud also deploys monitoring and alarming mechanisms which are configured by AWS Service Owners to identify and notify operational and management personnel of incidents when early warning thresholds are crossed on key operational metrics (**Control AWSCA-8.1**). Additionally, incidents are logged within a ticketing system, assigned a severity rating and tracked to resolution (**Control AWSCA-8.2**).

C.2 System Requirements

The selection and use of services by AWS European Sovereign Cloud Entity customers must be set up and operated under a shared responsibility model so that the functionality of the services and the associated security is appropriately managed. AWS European Sovereign Cloud Entity is responsible for protecting the infrastructure that runs the service(s) offered in the AWS European Sovereign Cloud. Customer Content and Customer-Created Metadata remain within the EU for AWS European Sovereign Cloud Entity’s customers. Only approved AWS European Sovereign Cloud Staff and Approved Vendor Personnel are able to access the AWS European Sovereign Cloud infrastructure. The customer’s responsibility is determined by the AWS European Sovereign Cloud service(s) that a customer selects and the interdependencies of those services within the AWS European Sovereign Cloud and their own network environment. Customers should assess the objectives of their AWS European Sovereign Cloud services network and identify the risks and corresponding controls that need to be implemented to address those risks when using AWS European Sovereign Cloud services, software, and operational controls. Customers should carefully consider the specific AWS European Sovereign Cloud services they choose, as their security responsibilities can vary depending on the service(s) they select, as well as the type of configurations and operational controls required for those services.

When designing and developing its services, AWS management has created internal policies that are relevant to the services and systems available to customers. The development of these policies and procedures helps to support management decision-making and provides the operational teams with clear business requirements and guidance for managing each AWS European Sovereign Cloud service and system. As each AWS European Sovereign Cloud service is unique, the system requirements to use different services vary depending on the service and each customer’s environment.

As explained in the Availability section of the report, AWS European Sovereign Cloud Entity and AWS Inc. have processes and infrastructure in place to make AWS European Sovereign Cloud services



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

available to customers to meet their needs. AWS European Sovereign Cloud is architected to maintain operations independently from other AWS regions and indefinitely, supported by AWS European Sovereign Cloud Staff. AWS communicates its system requirements to customers and how to get started with using AWS European Sovereign Cloud services in the form of user guides, developer guides, API references, service specific tutorials, or SDK toolkits. More information regarding AWS Documentation can be found at <https://docs.aws.eu>. These resources help the customers with architecting the AWS services to satisfy their business needs.

AWS European Sovereign Cloud Entity has identified the following objectives to support the security, change, and operational processes underlying their service commitments and business requirements. These objectives help ensure the system operates and mitigates risks that threaten the achievement of the service commitments and system requirements. The objectives below provide reasonable assurance that:

- Data integrity is maintained through all phases, including transmission, storage and processing.
- Policies and mechanisms are in place to appropriately restrict unauthorized access to systems and data, and Customer Content is appropriately segregated from other customers.
- System incidents are recorded and analyzed timely and tracked to resolution.
- Changes (including emergency/non-routine and configuration) to existing IT resources are documented, authorized, tested, approved and implemented by authorized personnel.
- Critical system components are replicated across multiple Availability Zones and authoritative backups are maintained and monitored to help ensure successful replication to meet the service commitments.
- Controls are implemented to safeguard data from within and outside of the boundaries of environments which store Customer Content and Customer-Created Metadata to meet the service commitments.
- Procedures have been established so that the collection, use, retention, disclosure, and disposal of Customer Content and Customer-Created Metadata within AWS services is in accordance with the service commitments.
- The AWS European Sovereign Cloud will be overseen by an independent advisory board of EU citizens.
- Controls are implemented so Customer Content and Customer-Created Metadata remain within the EU except as instructed by customers or required by applicable law.
- Access restrictions are maintained to limit access to Customer Content and Customer-Created Metadata to AWS European Sovereign Cloud Staff within the EU.
- Operations of Services, infrastructure, and customer support are performed by AWS European Sovereign Cloud Staff who are EU residents located in the EU.
- Procedures are established to handle governmental requests for Customer Content and Customer-Created Metadata in accordance with applicable legal requirements, including EU and Member State law.
- Operational continuity capabilities are maintained within the EU to provide services independently of other AWS regions.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

D. Procedures

D.1 Security Organization

AWS European Sovereign Cloud Entity has an established information security organization led by the Security Director based in the EU. The AWS European Sovereign Cloud security teams work with AWS service teams, other internal security teams, and external parties striving to ensure that security risks are mitigated. AWS Inc. Security establishes and maintains policies and procedures to delineate standards for logical access on the AWS European Sovereign Cloud system and infrastructure hosts. The policies also identify functional responsibilities for the administration of logical access, privacy, and security. Where applicable, AWS European Sovereign Cloud security teams leverage the information system framework and policies established and maintained by Amazon Corporate Information Security. AWS and Amazon Corporate Information Security policies are reviewed and approved on an annual basis by AWS Inc. Security Leadership and are used to support meeting the service commitments made to the customers (**Control AWSCA-1.1, AWSCA -1.2, and AWSCA-1.3**).

As part of this annual assessment, the following primary policies were inspected to verify approval occurred within the last year:

AWS Access Control Policy	AWS Media Protection Policy
AWS Configuration Management Policy	AWS Password Policy
AWS Contingency Planning Policy	AWS Personnel Security Policy
AWS Critical Permission Group Standard	AWS Physical and Environmental Protection Policy
Data Center Security Standard: Media Handling, Storage and Destruction	Secure Software Development Policy
AWS Data Classification and Handling Policy	AWS Security Assessment and Certification Standard
AWS Facility Badge Management and Use Standard	AWS Security Awareness Training Policy
AWS Identification and Authentication Policy	AWS System and Communications Protection Policy
AWS Incident Response Policy	AWS System and Information Integrity Policy
AWS Information Security Risk Management Policy	AWS System Maintenance Policy
AWS Internal Privacy Policy	AWS Third Party Information Sharing Policy
AWS Risk Management Policy	AWS European Sovereign Cloud Data Handling Standard



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

AWS has a security awareness and training policy that is disseminated via an internal Amazon communication portal to all employees. This policy addresses purpose, scope, roles and responsibilities. AWS Inc. maintains and provides security awareness training to all information system users on an annual basis. The training also includes components such as privacy, data protection training, and data handling leading practices (**Control AWSCA-1.4**).

As a part of AWS’ responsibilities within the shared responsibility model, AWS implements the three lines of defense model established by the Institute of Internal Auditors (IIA), discussed in the IIA’s Three Lines Model “<https://www.theiia.org/en/content/position-papers/2020/the-iias-three-lines-model-an-update-of-the-three-lines-of-defense/>” whitepaper. In this model, operational management is the first line of defense, the various risk control and compliance oversight functions established by management are the second line of defense (**Control AWSCA-1.5**), and independent assurance is the third. As its third line of defense, Amazon has an Internal Audit function to periodically evaluate risks and assess conformance to AWS security processes with due professional care (**Control AWSCA-9.8**).

Further, AWS Compliance and Security Assurance works with third-party assessors to obtain an independent assessment of risk management content/processes by performing periodic security assessments and compliance audits or examinations (e.g., SOC, ISO) to evaluate the security, integrity, privacy, confidentiality, and availability of information and resources. AWS management also collaborates with Internal Audit to determine the health of the AWS control environment and leverages this information to fairly present the assertions made within the reports.

D.2 Logical Security

AWS Inc. has established policies and procedures to delineate standards for logical access to AWS European Sovereign Cloud systems and infrastructure hosts. The policies also identify functional responsibilities for the administration of logical access and security. Where permitted by law, AWS requires that employees undergo a background screening, at the time of hiring commensurate with their position and level of access and in accordance with the AWS Personnel Security Policy (**Control AWSCA-9.2**). Additionally, AWS European Sovereign Cloud maintains residency and work authorization requirements for AWS European Sovereign Cloud employees who operate and support the AWS European Sovereign Cloud. AWS European Sovereign Cloud Staff provide documentation validating their residency status upon hiring, which is verified before granting access privileges to the AWS European Sovereign Cloud (**Control AWSCA-20.10**).

AWS European Sovereign Cloud Staff who have access to systems that could impact the security, confidentiality, integrity, availability, or privacy of Customer Content or Customer-Created Metadata are required to complete a post-hire background screening within a year from their last background check. Post-hire screening includes criminal screening requirements consistent with the pre-hire background screening. Access to the systems that could impact the security, confidentiality, integrity, availability, or privacy of Customer Content and Customer-Created Metadata is managed by membership in permission groups. Employees who only support internal services or only have access to network resources are not required to complete the post-hire background screening. Post-hire background screening is conducted where it is legally permissible by local law and in accordance with the AWS Personnel Security Policy (**Control AWSCA-9.9**). The re-validation of temporary work authorization documentation of the AWS European Sovereign Cloud Staff is performed not later than the last day of validity. AWS European Sovereign Cloud Staff are required to notify AWS European Sovereign Cloud Entity of any residency status changes (**Control AWSCA-20.10**).



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Account Provisioning

The responsibility for provisioning user access, which includes employee and contractor access, is shared across Human Resources (HR), Corporate Operations, and Service Owners.

A standard employee or contractor account with minimum privileges is provisioned in a disabled state when a hiring manager submits their new employee or contractor onboarding request in Amazon’s HR system. The account is automatically enabled after the employee’s record is activated in Amazon’s HR system. First time passwords are set to a unique value and are required to be changed on first use **(Control AWSCA-2.1)**.

Access Management

AWS employs the concept of least privilege, allowing only the necessary access for users to accomplish their job function. User accounts are created to have minimal access. Access above these least privileges require appropriate and separate authorization.

Access to AWS European Sovereign Cloud resources including Services, Hosts, Network devices, and Windows and UNIX groups is approved in Amazon’s proprietary Permission management system by the appropriate owner or manager. Requests for changes in access are captured in the Amazon permissions management tool audit log. When changes in an employee’s job function occur, continued access must be approved to the resource, or it will be automatically revoked **(Control AWSCA-2.2)**.

AWS European Sovereign Cloud Entity has implemented location-based access controls for access to AWS European Sovereign Cloud production environments. User geographic location is verified at session start and throughout the duration of the session **(Control AWSCA-20.9)**.

Periodic Access Review

Access control lists or permission groups granting access to critical infrastructure are reviewed for appropriateness on a periodic basis. On a quarterly basis, reviews are performed by appropriate AWS management personnel of user access to AWS European Sovereign Cloud systems supporting the infrastructure and network; explicit re-approval is required, or access to the resource is revoked. On a semi-annual basis granted access rights to AWS European Sovereign Cloud accounts are reviewed. When an internal user no longer has a required business need to access the operational management system, the user’s privileges and access to the relevant systems are revoked **(Control AWSCA-2.3)**.

Access Removal

Access is revoked when an employee’s record is terminated in Amazon’s HR system. Windows and UNIX accounts are disabled, and Amazon’s permission management system removes the user from all systems **(Control AWSCA-2.4)**.

Password Policy

Access and administration of logical security for Amazon relies on user IDs, passwords and Kerberos to authenticate users to services, resources and devices as well as to authorize the appropriate level of access for the user. AWS Security has established a password policy with required configurations and expiration intervals. AWS has a credential monitoring and response process to monitor compromised credentials for Amazon employees. Impacted user credentials are identified, tracked and rotated in a timely manner **(Control AWSCA-2.5)**.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Remote Access

AWS requires two-factor authentication over an approved cryptographic channel for authentication to the internal AWS European Sovereign Cloud network from remote locations (**Control AWSCA-2.6**).

AWS European Sovereign Cloud enables AWS European Sovereign Cloud customers to select who has access to AWS European Sovereign Cloud services and resources (if resource-level permissions are applicable to the service) that they own. AWS European Sovereign Cloud prevents customers from accessing AWS resources that are not assigned to them via access permissions. User content is segregated by the service’s software. Content is only returned to individuals authorized to access the specified AWS European Sovereign Cloud service or resource (if resource-level permissions are applicable to the service) (**Control AWSCA-3.5**).

Application Security Reviews

AWS Inc. performs Application Security (AppSec) reviews when needed for externally launched products, services, and significant feature additions prior to launch to identify security and privacy risks and determine if they are mitigated. As a part of the AppSec review, the Application Security team collects detailed information from service teams required for the review. The Application Security team tracks reviews against an independently managed inventory of products and features to be released to ensure that none are inadvertently launched before a completed review. As part of the security review, newly created or modified IAM policies allowing end users to interact with launched updates are also reviewed. The Application Security team then determines the granularity of review required based on the design, threat model, and impact to AWS’ risk profile. During this process, they work with the service team to identify, prioritize, and remediate security findings. The Application Security team provides their final approval for launch only upon completion of the review (**Control AWSCA-3.6**). Penetration testing is performed as needed.

AWS European Sovereign Cloud Network Security

The AWS European Sovereign Cloud Network consists of the internal data center facilities, servers, networking equipment and host software systems that are within AWS European Sovereign Cloud control and are used to provide AWS European Sovereign Cloud services.

Controls around the AWS European Sovereign Cloud network have been designed and implemented by AWS to provide significant protection against traditional network security issues. The following are a few examples:

- **Distributed Denial of Service (DDoS) Attacks.** In order to defend against network attacks, including DDoS attempts and suspicious traffic patterns, events from multiple sources are collected, monitored and actioned through an integrated ticketing system, enabling rapid threat detection and coordinated response measures. (**Control AWSCA-8.2**). Additionally, AWS European Sovereign Cloud Entity’s networks are multi-homed across a number of providers to achieve Internet access diversity.
- **Man in the Middle (MITM) Attacks.** All of the AWS European Sovereign Cloud APIs are available via TLS/SSL-protected endpoints, which provide server authentication. Amazon EC2 Amazon Machine Images (AMIs) automatically generate new SSH host certificates on first boot and log them to the instance’s console. Customers can then use the secure APIs to call the console and access the host certificates before logging into the instance for the first time. Customers can use TLS/SSL for all of their interactions with AWS European Sovereign Cloud (**Control AWSCA-3.11**).



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

- **IP Spoofing.** The AWS-controlled, host-based firewall infrastructure will not permit an instance to send traffic with a source IP or MAC address other than its own (**Control AWSCA-3.10**).
- **Port Scanning.** Unauthorized port scans by Amazon EC2 customers are a violation of the AWS Acceptable Use Policy. Violations of the AWS Acceptable Use Policy are taken seriously, and every reported violation is investigated. Customers can report suspected abuse via the contacts available on our website at: <https://aws.amazon.com/contact-us/report-abuse/>. Port scans of Amazon EC2 instances are generally ineffective because, by default, all inbound ports on Amazon EC2 instances are closed and are only opened by the customer. Customers' strict management of security groups can further mitigate the threat of port scans. Customers may request permission to conduct vulnerability scans as required to meet specific compliance requirements. These scans must be limited to customers' own instances and must not violate the AWS Acceptable Use Policy. Advanced approval for these types of scans can be initiated by submitting a request via the AWS website at: <https://aws.amazon.com/security/penetration-testing/>.
- **Packet sniffing by other tenants.** Virtual instances are designed to prevent other instances running in promiscuous mode to receive or "sniff" traffic that is intended for a different virtual instance. While customers can place instances into promiscuous mode, the hypervisor will not deliver any traffic to them that is not addressed to them. Even two virtual instances that are owned by the same customer located on the same physical host cannot listen to each other's traffic. While Amazon EC2 does provide protection against one customer inadvertently or maliciously attempting to view another's data, as standard practice customers can encrypt sensitive traffic (**Control AWSCA-3.10**).
- **Anti-virus software installed on workstations.** Anti-virus software is deployed and running on Amazon corporate workstations. Client Engineering and Enterprise Engineering teams deploy Anti-virus software at imaging to Amazon corporate workstations. AWS Inc. has implemented checks to ensure that anti-virus software is installed, running, and capable of quarantining any non-compliant workstations. This quarantine functionality isolates those workstations from the network until the necessary remediation actions have been taken (**Control AWSCA-3.18**).

Firewall devices are configured to restrict access to production networks (**Control AWSCA-3.1**). The configurations of these firewall policies are maintained via an automatic push from a parent server (**Control AWSCA-3.2**). All changes to the firewall policies are reviewed and approved by appropriate AWS management personnel prior to deployment (**Control AWSCA-3.3**).

AWS Inc. Security performs at least quarterly vulnerability scans on host operating systems, web applications, and databases in the AWS European Sovereign Cloud environment using a variety of tools (**Control AWSCA-3.4**). AWS Inc. Security teams also subscribe to newsfeeds for applicable vendor flaws and proactively monitor vendors' websites and other relevant outlets for new patches. AWS European Sovereign Cloud customers have the ability to report issues to AWS European Sovereign Cloud Entity via the AWS Vulnerability Reporting website at: <https://aws.amazon.com/security/vulnerability-reporting/>.

AWS European Sovereign Cloud utilizes virtualization techniques to control and restrict traffic flow. This includes the use of virtual networking devices, host-based firewalls, and Access Control Lists (ACLs) within EC2 and VPC. Additionally, AWS European Sovereign Cloud offers a variety of operating systems for its EC2 instances. It is the responsibility of the customers to appropriately configure server resources within the customer VPC.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

External Access Control

External API access to services is configurable by customers via AWS Identity and Access Management (IAM) in the AWS European Sovereign Cloud. IAM enables customers to securely control access to AWS European Sovereign Cloud services and resources for their users. Using IAM, AWS European Sovereign Cloud customers can create and manage AWS users, roles, groups, and create and attach policies to those entities with granular permissions that allow or deny access to AWS European Sovereign Cloud resources. Security Groups act as firewalls and may also be used to control access to some in-scope applications such as VPC, EFS, ElastiCache, and DMS. These groups default to a “deny all” access mode and customers must specifically authorize network connectivity. This can be achieved by authorizing a network IP range or authorizing an existing Security Group (**Control AWSCA-3.5**).

Interacting with the Services

AWS provides several methods of interacting with its services in the form of APIs, Software Development Kits (SDKs), the AWS Management Console, and the AWS command line interface. All of the methods ultimately rely on public APIs and follow standard AWS authentication and authorization practices.

Authenticated calls to AWS European Sovereign Cloud services are signed by an X.509 certificate and/or the customer's AWS Secret Access Key. When using the AWS Command Line Interface (AWS CLI) or one of the AWS SDKs to make requests to AWS, these tools automatically sign the requests with the access key specified by the customer when the tools were configured. Manually created requests must be signed using Signature Version 4 or Signature Version 2. For AWS European Sovereign Cloud services that support both versions, it is recommended to use Signature Version 4.

Internal Logging

AWS Inc. maintains centralized repositories that provide core log archival functionality available for internal use by AWS service teams. Leveraging S3 for high scalability, durability, and availability allows service teams to collect, archive, and view service logs in a central log service. Additionally, system activities are logged, retained for a defined period of time, and protected from unauthorized modifications (**Control AWSCA-8.3**).

Production hosts at AWS European Sovereign Cloud are deployed using master baseline images (**Control AWSCA-9.4**). The baseline images are equipped with a standard set of configurations and functions including logging and monitoring for security purposes.

These logs are stored and accessible by AWS European Sovereign Cloud security teams for root cause analysis in the event of a suspected security incident. Logs for a given host are also available to the team within the AWS European Sovereign Cloud that owns that host in case the team needs to search their logs for operational and security analysis.

Encryption

AWS European Sovereign Cloud leverages Amazon cryptographic policy, which defines the appropriate cryptography implementation through the Amazon cryptographic standard, which is based on FIPS standards, NIST standards, and/or the Commercial National Security Algorithm Suite (Suite B). Implementation guidance including appropriate encryption key length and algorithm specific parameters, are provided to service teams through application security reviews. Additionally, AWS Security Engineers within the cryptography review program evaluate the appropriate use of cryptography within AWS European Sovereign Cloud services. In addition, API calls can be encrypted



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

with TLS/SSL to maintain confidentiality. It is the customer's responsibility to appropriately configure and manage usage and implementation of available encryption options to meet compliance requirements.

The AWS European Sovereign Cloud Entity operates its own root of trust that autonomously controls and operates its CA key materials. **(Control AWSCA-20.14).**

Each production firmware version release for the AWS Key Management Service HSM (Hardware Security Module) in the AWS European Sovereign Cloud either holds or is in the process of actively pursuing FIPS 140-3 level 3 certification from the National Institute of Standards and Technology's (NIST) Cryptographic Module Validation Program (CMVP) **(Control AWSCA-4.14)**. The certification process involves a coordinated effort between the AWS Inc. KMS team and NVLAP-certified FIPS consulting laboratories which acts as authorized intermediary between AWS KMS and NIST/CMVP. Before deployment, each new firmware version undergoes thorough evaluation to ensure compliance with the FIPS 140-3 level 3 standards, as verified by the FIPS consulting laboratory. Once compliance is confirmed, the laboratory submits a comprehensive report to NIST's CMVP, initiating the formal FIPS 140-3 review and certification process for the firmware version.

All new objects uploaded to Amazon S3 are automatically encrypted with server-side encryption **(AWSCA-3.19)**. Amazon S3 automatically applies server-side encryption with Amazon S3 managed keys (SSE-S3) for each new object uploaded to Amazon S3, unless a customer specifies a different encryption option. Amazon S3 server-side encryption utilizes 256-bit Advanced Encryption Standard Galois/Counter Mode (AES-GCM) to encrypt all uploaded objects. Customers can also alternatively choose to encrypt their objects with server-side encryption with customer-provided encryption keys (SSE-C), server-side encryption with AWS Key Management Service keys (SSE-KMS), server-side encryption with AWS Key Management Service keys (SSE-KMS) with S3 Bucket Keys, or Dual-layer server-side encryption with AWS Key Management Service keys (DSSE-KMS).

Deletion of Customer Content

AWS European Sovereign Cloud provides customers with the ability to delete their content. Once successfully removed, the data is rendered unreadable **(Control AWSCA-7.7)**. For services that utilize ephemeral storage, such as EC2, the ephemeral storage is deleted once the EC2 instance is deleted.

D.3 AWS Service Descriptions

The following section describes the AWS European Sovereign Cloud services within the scope of this report. These descriptions are not exhaustive, and customers should review documentation provided online for additional information on these services. Any AI functionality made available by services within the scope of this report are not included in the controls described.

AWS services are developed centrally by AWS Inc. and operated by the AWS European Sovereign Cloud. Accordingly, controls related to service design and development remain under the responsibility of AWS Inc., while AWS European Sovereign Cloud Entity is responsible for the operation of these services within the AWS European Sovereign Cloud. Once deployed in the AWS European Sovereign Cloud Region, services are able to operate independently from any AWS Inc. infrastructure components or resources located outside the defined geographical and logical boundaries.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Amazon API Gateway

Amazon API Gateway is a service that makes it easy for developers to publish, maintain, monitor, and secure APIs at any scale. With Amazon API Gateway, customers can create a custom API to code running in AWS Lambda, and then call the Lambda code from customers' API. Amazon API Gateway can execute AWS Lambda code in a customer's account, start AWS Step Functions state machines, or make calls to AWS Elastic Beanstalk, Amazon EC2, or web services outside of AWS with publicly accessible HTTP endpoints. Using the Amazon API Gateway console, customers can define customers' REST API and its associated resources and methods, manage customers' API lifecycle, generate customers' client SDKs, and view API metrics.

Amazon Athena

Amazon Athena is an interactive query service that makes it easy to analyze data in Amazon S3 using standard SQL. Athena is serverless, so there is no infrastructure for customers to manage. Athena is highly available; and executes queries using compute resources across multiple facilities and multiple devices in each facility. Amazon Athena uses Amazon S3 as its underlying data store, making customers' data highly available and durable.

Amazon Bedrock (excludes Amazon Bedrock Marketplace)

Amazon Bedrock is a fully managed service that makes foundation models (FMs) from Amazon and leading Artificial Intelligence (AI) companies available through an API, so customers can choose from various FMs to find the model that's best suited for their use case. With the Amazon Bedrock serverless experience, customers can quickly get started, easily experiment with FMs, privately customize FMs with their own data, and seamlessly integrate and deploy them into customer applications using AWS tools and capabilities. Agents for Amazon Bedrock are fully managed and make it easier for developers to create generative-AI applications that can deliver up-to-date answers based on proprietary knowledge sources and complete tasks for a wide range of use cases. The Foundational Models (FMs) from Amazon and leading AI companies, made available by Amazon Bedrock, and the FMs offered through Bedrock Marketplace, are not included in the design of the controls described in this SOC report.

Amazon CloudWatch

Amazon CloudWatch is a monitoring and management service built for developers, system operators, site reliability engineers (SRE), and IT managers. CloudWatch provides the customers with data and actionable insights to monitor their applications, understand and respond to system-wide performance changes, optimize resource utilization, and get a unified view of operational health. CloudWatch collects monitoring and operational data in the form of logs, metrics, and events, providing the customers with a unified view of AWS resources, applications and services that run on AWS, and on-premises servers.

Amazon Cognito

Amazon Cognito lets customers add user sign-up, sign-in, and manage permissions for mobile and web applications. Customers can create their own user directory within Amazon Cognito. Customers can also choose to authenticate users through social identity providers such as Facebook, Twitter, or Amazon; with SAML identity solutions; or by using customers' own identity system.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Amazon Data Firehose

Amazon Data Firehose is a reliable way to load streaming data into data stores and analytics tools. It can capture, transform, and load streaming data into Amazon S3, Amazon Redshift, and Amazon OpenSearch Service enabling near real-time analytics with existing business intelligence tools and dashboards customers are already using today. The service automatically scales to match the throughput of the customers’ data and requires no ongoing administration. It can also batch, compress, transform, and encrypt the data before loading it, minimizing the amount of storage used at the destination and increasing security.

Amazon DynamoDB

Amazon DynamoDB is a managed NoSQL database service. Amazon DynamoDB enables customers to offload to AWS the administrative burdens of operating and scaling distributed databases such as hardware provisioning, setup and configuration, replication, software patching, and cluster scaling.

Customers can create a database table that can store and retrieve data and serve any requested traffic. Amazon DynamoDB automatically spreads the data and traffic for the table over a sufficient number of servers to handle the request capacity specified and the amount of data stored, while maintaining consistent, fast performance. All data items are stored on Solid State Drives (SSDs) and are automatically replicated across multiple AZs in a region.

Amazon EC2 Auto Scaling

Amazon EC2 Auto Scaling launches/terminates instances on a customer's behalf according to conditions customers define, such as schedule, changing metrics like average CPU utilization, or health of the instance as determined by EC2 or ELB health checks. It allows customers to have balanced compute across multiple AZs and scale their fleet based on usage.

Amazon Elastic Block Store (EBS)

Amazon Elastic Block Store (EBS) provides persistent block storage volumes for use with Amazon EC2 instances in the AWS Cloud. Each Amazon EBS volume is automatically replicated within its AZ to protect customers from component failure. Amazon EBS allows customers to create storage volumes from 1 GB to 16 TB that can be mounted as devices by Amazon EC2 instances. Storage volumes behave like raw, unformatted block devices, with user supplied device names and a block device interface. Customers can create a file system on top of Amazon EBS volumes or use them in any other way one would use a block device (e.g., a hard drive).

Amazon EBS volumes are presented as raw unformatted block devices that have been wiped prior to being made available for use. Wiping occurs before reuse. If customers have procedures requiring that all data be wiped via a specific method, customers can conduct a wipe procedure prior to deleting the volume for compliance with customer requirements. Amazon EBS includes Data Lifecycle Manager, which provides a simple, automated way to back up data stored on Amazon EBS volumes.

Amazon Elastic Compute Cloud (EC2)

Amazon Elastic Compute Cloud (EC2) is Amazon’s Infrastructure as a Service (IaaS) offering, which provides scalable computing capacity using server instances in AWS’ data centers. Amazon EC2 is designed to make web-scale computing easier by enabling customers to obtain and configure capacity with minimal friction. Customers create and launch instances, which are virtual machines that are available in a wide variety of hardware and software configurations.



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

Security within Amazon EC2 is provided on multiple levels: the operating system (OS) of the host layer, the virtual instance OS or guest OS, a firewall, and signed API calls. Each of these items builds on the capabilities of the others. This helps prevent data contained within Amazon EC2 from being intercepted by unauthorized systems or users and to provide Amazon EC2 instances themselves security without sacrificing flexibility of configuration. The Amazon EC2 service utilizes a hypervisor to provide memory and CPU isolation between virtual machines and controls access to network, storage, and other devices, and maintains strong isolation between guest virtual machines. Independent auditors regularly assess the security of Amazon EC2 and penetration teams regularly search for new and existing vulnerabilities and attack vectors.

AWS prevents customers from accessing physical hosts or instances not assigned to them by filtering through the virtualization software (**Control AWSCA-3.12**).

Amazon EC2 provides a complete firewall solution, referred to as a Security Group. This mandatory inbound firewall is configured in a default deny-all mode to prevent unauthorized access and Amazon EC2 customers must explicitly open the ports needed to allow inbound traffic (**Control AWSCA-3.9**).

Amazon provides a Time Sync function for time synchronization in EC2 Linux instances with the Coordinated Universal Time (UTC). It is delivered over the Network Time Protocol (NTP) and uses a fleet of redundant satellite-connected and atomic clocks in each region to provide a highly accurate reference clock via the local 169.254.169.123 IPv4 address or fd00:ec2::123 IPv6 address. Irregularities in the Earth's rate of rotation that cause UTC to drift with respect to the International Celestial Reference Frame (ICRF), by an extra second, are called leap second. Time Sync addresses this clock drift by smoothing out leap seconds over a period of time (commonly called leap smearing) which makes it easy for customer applications to deal with leap seconds (**Control AWSCA-7.10**).

Amazon Elastic Container Registry (ECR)

Amazon Elastic Container Registry is a Docker container image registry that makes it easy for developers to store, manage, and deploy Docker container images. Amazon Elastic Container Registry is integrated with Amazon Elastic Container Service (ECS) and Amazon Elastic Kubernetes Service (EKS).

Amazon Elastic Container Service

Amazon Elastic Container Service is a highly scalable, high performance container management service that supports Docker containers and allows customers to easily run applications on a managed cluster of Amazon EC2 instances. Amazon Elastic Container Service eliminates the need for customers to install, operate, and scale customers' own cluster management infrastructure. With simple API calls, customers can launch and stop Docker-enabled applications, query the complete state of customers' clusters, and access many familiar features like security groups, Elastic Load Balancing, EBS volumes, and IAM roles. Customers can use Amazon Elastic Container Service to schedule the placement of containers across customers' clusters based on customers' resource needs and availability requirements.

Amazon Elastic File System (EFS)

Amazon Elastic File System (EFS) provides file storage for Amazon EC2 instances. EFS presents a network attached file system interface via the NFS v4 protocol. EFS file systems grow and shrink elastically as data is added and deleted by users. Amazon EFS spreads data across multiple AZs; in the event that an AZ is not reachable, the structure allows customers to still access their full set of data. The customer is responsible for choosing which of their Virtual Private Clouds (VPCs) they want a file system to be accessed from by creating resources called mount targets. One mount target exists for



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

each AZ, which exposes an IP address and DNS name for mounting the customer’s file system onto their EC2 instances. Customers then log into their EC2 instance and issue a ‘mount’ command, pointing at their mount target’ IP address or DNS name. A mount target is assigned one or more VPC security groups to which it belongs. The VPC security groups define rules for what VPC traffic can reach the mount targets and in turn can reach the file system.

Amazon Elastic Kubernetes Service (EKS)

Amazon Elastic Kubernetes Service (EKS) makes it easy to deploy, manage, and scale containerized applications using Kubernetes on AWS. Amazon EKS runs the Kubernetes management infrastructure for the customer across multiple AWS AZs to eliminate a single point of failure. Amazon EKS is certified Kubernetes conformant so the customers can use existing tooling and plugins from partners and the Kubernetes community. Applications running on any standard Kubernetes environment are fully compatible and can be easily migrated to Amazon EKS.

Amazon Elastic MapReduce (EMR)

Amazon Elastic MapReduce (EMR) is a web service that provides managed Hadoop clusters on Amazon EC2 instances running a Linux operating system. Amazon EMR uses Hadoop processing combined with several AWS products to do such tasks as web indexing, data mining, log file analysis, machine learning, scientific simulation, and data warehousing. Amazon EMR actively manages clusters for customers, replacing failed nodes and adjusting capacity as requested. Amazon EMR securely and reliably handles a broad set of big data use cases, including log analysis, web indexing, data transformations (ETL), machine learning, financial analysis, scientific simulation, and bioinformatics.

Amazon ElastiCache

Amazon ElastiCache automates management tasks for in-memory cache environments, such as patch management, failure detection, and recovery. It works in conjunction with other AWS services to provide a managed in-memory cache. For example, an application running in Amazon EC2 can securely access an Amazon ElastiCache Cluster in the same region with very slight latency.

Using the Amazon ElastiCache service, customers create a Cache Cluster, which is a collection of one or more Cache Nodes, each running an instance of the Memcached or Redis Engine. A Cache Node is a self-contained environment which provides a fixed-size chunk of secure, network-attached RAM. Each Cache Node runs an instance of the Memcached or Redis Engine, and has its own DNS name and port. Multiple types of Cache Nodes are supported, each with varying amounts of associated memory.

Amazon EventBridge

Amazon EventBridge delivers a near real-time stream of events that describe changes in AWS resources. Customers can configure routing rules to determine where to send collected data to build application architectures that react in real time to the data sources. Amazon EventBridge becomes aware of operational changes as they occur and responds to these changes by taking corrective action as necessary by sending message to respond to the environment, activating functions, making changes and capturing state information.

Amazon FSx

Amazon FSx provides third-party file systems. Amazon FSx provides the customers with the native compatibility of third-party file systems with feature sets for workloads such as Windows-based storage, high-performance computing (HPC), machine learning, and electronic design automation (EDA). The customers don’t have to worry about managing file servers and storage, as Amazon FSx



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

automates the time-consuming administration tasks such as hardware provisioning, software configuration, patching, and backups. Amazon FSx integrates the file systems with cloud-native AWS services, making them even more useful for a broader set of workloads.

Amazon GuardDuty

Amazon GuardDuty is a threat detection service that continuously monitors AWS accounts and workloads for malicious activity and delivers detailed security findings for visibility and remediation. Amazon GuardDuty uses AI and ML with integrated threat intelligence from AWS and leading third parties to help AWS accounts, workloads, and data from threats.

Amazon Kinesis Data Streams

Amazon Kinesis Data Streams is a scalable and durable real-time data streaming service. Kinesis Data Streams can continuously capture gigabytes of data per second from hundreds of thousands of sources such as website clickstreams, database event streams, financial transactions, social media feeds, IT logs and location-tracking events. The collected data is available in milliseconds to enable real-time analytics use cases such as real-time dashboards, real-time anomaly detection, dynamic pricing and more.

Amazon Managed Service for Apache Flink

Amazon Managed Service for Apache Flink is an easy way for customers to analyze streaming data, gain actionable insights, and respond to business and customer needs in real time. Amazon Managed Service for Apache Flink reduces the complexity of building, managing, and integrating streaming applications with other AWS services. SQL users can easily query streaming data or build entire streaming applications using templates and an interactive SQL editor. Java developers can quickly build sophisticated streaming applications using open-source Java libraries and AWS integrations to transform and analyze data in real-time.

Amazon Managed Streaming for Apache Kafka

Amazon Managed Streaming for Apache Kafka is a service that makes it easy for customers to build and run applications that use Apache Kafka to process streaming data. Apache Kafka is an open-source platform for building real-time streaming data pipelines and applications. With Amazon MSK, customers can use Apache Kafka APIs to populate data lakes, stream changes to and from databases, and power machine learning and analytics applications.

Amazon Neptune

Amazon Neptune is a fast and reliable graph database service that makes it easy to build and run applications that work with highly connected datasets. The core of Amazon Neptune is a purpose-built, high-performance graph database engine optimized for storing billions of relationships and querying the graph with milliseconds latency. Amazon Neptune supports popular graph models, Property Graph, and W3C's RDF, and their respective query languages Apache, TinkerPop Gremlin, and SPARQL, allowing customers to easily build queries that efficiently navigate highly connected datasets. Neptune powers graph use cases such as recommendation engines, fraud detection, knowledge graphs, drug discovery, and network security.

Amazon OpenSearch Service

Amazon OpenSearch Service is a service that makes it easy for the customer to deploy, secure, and operate OpenSearch cost effectively at scale. Amazon OpenSearch Service lets the customers pay only



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

for what they use – there are no upfront costs or usage requirements. With Amazon OpenSearch Service, the customers get the ELK stack they need, without the operational overhead.

Amazon Redshift

Amazon Redshift is a data warehouse service to analyze data using a customer’s existing Business Intelligence (BI) tools. Amazon Redshift also includes Redshift Spectrum, allowing customers to directly run SQL queries against Exabytes of unstructured data in Amazon S3.

Amazon Relational Database Service (RDS)

Amazon Relational Database Service (RDS) enables customers to set up, operate, and scale a relational database in the cloud. Amazon RDS manages backups, software patching, automatic failure detection, and recovery. It provides cost-efficient and resizable capacity while automating time-consuming administration tasks such as hardware provisioning, database setup, patching and backups.

Amazon Route 53

Amazon Route 53 provides managed Domain Name System (DNS) web service. Amazon Route 53 connects user requests to infrastructure running both inside and outside of AWS. Customers can use Amazon Route 53 to configure DNS health checks to route traffic to healthy endpoints or to independently monitor the health of their application and its endpoints. Amazon Route 53 enables customers to manage traffic globally through a variety of routing types, including Latency Based Routing, Geo DNS, and Weighted Round Robin, all of these routing types can be combined with DNS Failover. Amazon Route 53 also offers Domain Name Registration; customers can purchase and manage domain names such as example.com and Amazon Route 53 will automatically configure DNS settings for their domains. Amazon Route 53 sends automated requests over the internet to a resource, such as a web server, to verify that it is reachable, available, and functional. Customers also can choose to receive notifications when a resource becomes unavailable and choose to route internet traffic away from unhealthy resources.

Amazon SageMaker AI (excludes Studio Lab, Public Workforce and Vendor Workforce for all features)

Amazon SageMaker AI is a platform that enables developers and data scientists to quickly and easily build, train, and deploy machine learning models at any scale. Amazon SageMaker AI removes the barriers that typically “slow down” developers who want to use machine learning.

Amazon SageMaker AI removes the complexity that holds back developer success with the process of building, training, and deploying machine learning models at scale. Amazon SageMaker AI includes modules that can be used together or independently to build, train, and deploy a customer’s machine learning models.

Amazon Simple Email Service (SES)

Amazon Simple Email Service (SES) is a cost-effective, flexible and scalable email service that enables developers to send mail from within any application. Customers can configure Amazon SES to support several email use cases including transactional, marketing, or mass email communications. Amazon SES’ flexible IP deployment and email authentication options help drive higher deliverability and protect sender reputation, while sending analytics to measure impact of each email. With Amazon SES, customers can send email securely, globally and at scale.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Amazon Simple Notification Service (SNS)

Amazon Simple Notification Service (SNS) is a web service to set up, operate, and send notifications. It provides developers the capability to publish messages from an application and deliver them to subscribers or other applications. Amazon SNS follows the “publish-subscribe” (pub-sub) messaging paradigm, with notifications being delivered to clients using a “push” mechanism. Using SNS requires defining a “Topic”, setting policies on access and delivery of the Topic, subscribing consumers and designating delivery endpoints, and publishing messages to a Topic. Administrators define a Topic as an access point for publishing messages and allowing customers to subscribe to notifications. Security policies are applied to Topics to determine who can publish, who can subscribe, and to designate protocols supported.

Amazon Simple Queue Service (SQS)

Amazon Simple Queue Service (SQS) is a message queuing service that offers a distributed hosted queue for storing messages as they travel between computers. By using Amazon SQS, developers can move data between distributed components of their applications that perform different tasks, without losing messages or requiring each component to be always available. Amazon SQS allows customers to build an automated workflow, working in close conjunction with Amazon EC2 and the other AWS infrastructure web services.

Amazon SQS’ main components consist of a frontend request-router fleet, a backend data-storage fleet, a metadata cache fleet, and a dynamic workload management fleet. User queues are mapped to one or more backend clusters. Requests to read, write, or delete messages come into the frontends. The frontends contact the metadata cache to find out which backend cluster hosts that queue and then connect to nodes in that cluster to service the request.

For authorization, Amazon SQS has its own resource-based permissions system that uses policies written in the same language used for AWS IAM policies. User permissions for any Amazon SQS resource can be given either through the Amazon SQS policy system or the AWS IAM policy system, which is authorized by AWS Identity and Access Management Service. Such policies with a queue are used to specify which AWS Accounts have access to the queue as well as the type of access and conditions.

Amazon Simple Storage Service (S3)

Amazon Simple Storage Service (S3) provides a web services interface that can be used to store and retrieve data from anywhere on the web. To provide customers with the flexibility to determine how, when, and to whom they wish to expose the information they store in AWS, Amazon S3 APIs provide both bucket and object-level access controls, with defaults that only permit authenticated access by the bucket and/or object creator. Unless a customer grants anonymous access, the first step before a user can access Amazon S3 is to be authenticated with a request signed using the user’s secret access key.

An authenticated user can read an object only if the user has been granted read permissions in an Access Control List (ACL) at the object level. An authenticated user can list the keys and create or overwrite objects in a bucket only if the user has been granted read and write permissions in an ACL at the bucket level. Bucket and object-level ACLs are independent; an object does not inherit ACLs from its bucket. Permissions to read or modify the bucket or object ACLs are themselves controlled by ACLs that default to creator-only access. Therefore, the customer maintains full control over who has access to its data. Customers can grant access to their Amazon S3 data to other AWS users by AWS Account



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

ID or email, or DevPay Product ID. Customers can also grant access to their Amazon S3 data to all AWS users or to everyone (enabling anonymous access).

Network devices supporting Amazon S3 are configured to only allow access to specific ports on other Amazon S3 server systems (**Control AWS-3.7**). External access to data stored in Amazon S3 is logged and the logs are retained for at least 90 days, including relevant access request information, such as the data accessor IP address, object, and operation (**Control AWS-3.8**).

Amazon Simple Workflow Service (SWF)

Amazon Simple Workflow Service (SWF) is an orchestration service for building scalable distributed applications. Often an application consists of several different tasks to be performed in a particular sequence driven by a set of dynamic conditions. Amazon SWF enables developers to architect and implement these tasks, run them in the cloud or on-premises and coordinate their flow. Amazon SWF manages the execution flow such that tasks are load balanced across the workers, inter-task dependencies are respected, concurrency is handled appropriately, and child workflows are executed.

Amazon SWF enables applications to be built by orchestrating tasks coordinated by a decider process. Tasks represent logical units of work and are performed by application components that can take any form, including executable code, scripts, web service calls, and human actions.

Developers implement workers to perform tasks. They run their workers either on cloud infrastructure, such as Amazon EC2, or off-cloud. Tasks can be long-running, may fail, may timeout and may complete with varying throughputs and latencies. Amazon SWF stores tasks for workers, assigns them when workers are ready, tracks their progress, and keeps their latest state, including details on their completion. To orchestrate tasks, developers write programs that get the latest state of tasks from Amazon SWF and use it to initiate subsequent tasks in an ongoing manner. Amazon SWF maintains an application's execution state durably so that the application can be resilient to failures in individual application components.

Amazon SWF provides auditability by giving customers visibility into the execution of each step in the application. The Management Console and APIs let customers monitor all running executions of the application. The customer can zoom in on any execution to see the status of each task and its input and output data. To facilitate troubleshooting and historical analysis, Amazon SWF retains the history of executions for any number of days that the customer can specify, up to a maximum of 90 days.

The actual processing of tasks happens on compute resources owned by the end customer. Customers are responsible for securing these compute resources, for example if a customer uses Amazon EC2 for workers then they can restrict access to their instances in Amazon EC2 to specific AWS IAM users. In addition, customers are responsible for encrypting sensitive data before it is passed to their workflows and decrypting it in their workers.

Amazon Virtual Private Cloud (VPC)

Amazon Virtual Private Cloud (VPC) enables customers to provision a logically isolated section of the AWS cloud where AWS resources can be launched in a virtual network defined by the customer. Customers can connect their existing infrastructure to the network isolated Amazon EC2 instances within their Amazon VPC, including extending their existing management capabilities, such as security services, firewalls and intrusion detection systems, to include their instances via a Virtual Private Network (VPN) connection. The VPN service provides end-to-end network isolation by using an IP address range of a customer's choice, and routing all of their network traffic between their Amazon



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

VPC and another network designated by the customer via an encrypted Internet Protocol security (IPsec) VPN.

Customers can optionally connect their VPC to the Internet by adding an Internet Gateway (IGW) or a NAT Gateway. An IGW allows bi-directional access to and from the internet for some instances in the VPC based on the routes a customer defines, which specify which IP address traffic should be routable from the internet, Security Groups, and Network ACLs (NACLs) which limit which instances can accept or send this traffic. Customers can also optionally configure a NAT Gateway which allows egress-only traffic initiated from a VPC instance to reach the internet, but not allow traffic initiated from the internet to reach VPC instances. This is accomplished by mapping the private IP addresses to a public address on the way out, and then map the public IP address to the private address on the return trip.

The objective of this architecture is to isolate AWS resources and data in one Amazon VPC from another Amazon VPC, and to help prevent data transferred from outside the Amazon network except where the customer has specifically configured internet connectivity options or via an IPsec VPN connection to their off-cloud network.

Further details are provided below:

- **Virtual Private Cloud (VPC):** An Amazon VPC is an isolated portion of the AWS cloud within which customers can deploy Amazon EC2 instances into subnets that segment the VPC’s IP address range (as designated by the customer) and isolate Amazon EC2 instances in one subnet from another. Amazon EC2 instances within an Amazon VPC are accessible to customers via Internet Gateway (IGW), Virtual Gateway (VGW), Transit Gateway (TGW) or VPC Peerings established to the Amazon VPC (**Control AWSCA-3.13** and **AWSCA-3.15**).
- **IPsec VPN:** An IPsec VPN connection connects a customer’s Amazon VPC to another network designated by the customer. IPsec is a protocol suite for securing Internet Protocol (IP) communications by authenticating and encrypting each IP packet of a data stream. An AWS site-to-site VPN connection consists of two independent IPsec VPN tunnels for redundancy and availability. Amazon VPC customers can create an IPsec VPN connection to their Amazon VPC by first establishing an Internet Key Exchange (IKE) security association between their Amazon VPC VPN gateway and another network gateway using a pre-shared key as the authenticator. Upon establishment, IKE negotiates an ephemeral key to secure future IKE messages. An IKE security association cannot be established unless there is complete agreement among the parameters. Next, using the IKE ephemeral key, two keys in total are established between the VPN gateway and customer gateway to form an IPsec security association. Traffic between gateways is encrypted and decrypted using this security association. IKE automatically rotates the ephemeral keys used to encrypt traffic within the IPsec security association on a regular basis to ensure confidentiality of communications (**Control AWSCA-3.14** and **AWSCA-4.3**).

AWS Artifact

AWS Artifact is a self-service audit artifact retrieval portal that provides customers with on-demand access to AWS’ compliance documentation and AWS agreements. Customers can use AWS Artifact Reports to download AWS security and compliance documents, such as AWS ISO certifications, and System and Organization Control (SOC) reports. Customers can use AWS Artifact Agreements to review, accept, and track the status of AWS agreements.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

AWS Backup

AWS Backup is a backup service that makes it easy to centralize and automate the back up of data across AWS services in the cloud as well as on premises using the AWS Storage Gateway. Using AWS Backup, the customers can centrally configure backup policies and monitor backup activity for AWS resources, such as Amazon EBS volumes, Amazon RDS databases, Amazon DynamoDB tables, Amazon EFS file systems, and AWS Storage Gateway volumes. AWS Backup automates and consolidates backup tasks previously performed service-by-service, removing the need to create custom scripts and manual processes.

AWS Batch

AWS Batch enables developers, scientists, and engineers to run batch computing jobs on AWS. AWS Batch dynamically provisions the optimal quantity and type of compute resources (e.g., CPU or memory optimized instances) based on the volume and specific resource requirements of the batch jobs submitted. AWS Batch plans, schedules, and executes customers’ batch computing workloads across the full range of AWS compute services and features, such as [Amazon EC2](#) and [Spot Instances](#).

AWS Certificate Manager (ACM)

AWS Certificate Manager (ACM) is a service that lets the customer provision, manage, and deploy public and private Secure Sockets Layer/Transport Layer Security (SSL/TLS) certificates for use with AWS services and their internal connected resources. SSL/TLS certificates are used to secure network communications and establish the identity of websites over the Internet as well as resources on private networks. AWS Certificate Manager removes the manual process of purchasing, uploading, and renewing SSL/TLS certificates.

AWS Cloud Map

AWS Cloud Map is a cloud resource discovery service which allows customers to define custom names for their application resources. Cloud Map maintains the location of these changing resources to increase application availability.

Customers can register any application resource, such as databases, queues, microservices, and other cloud resources, with custom names. Cloud Map then constantly checks the health of resources to make sure the location is up-to-date. The application can then query the registry for the location of the resources needed based on the application version and deployment environment.

AWS CloudFormation

AWS CloudFormation is a service that helps customers model and set up their AWS resources so that they can spend less time managing those resources and more time focusing on applications that run in AWS. Customers create a template that describes all the AWS resources that they want (like Amazon EC2 instances or Amazon RDS DB instances), and CloudFormation takes care of provisioning and configuring those resources. Customers don't need to individually create and configure AWS resources and figure out what's dependent on what; CloudFormation handles that.

AWS CloudTrail

AWS CloudTrail is a web service that records AWS activity for customers and delivers log files to a specified Amazon S3 bucket. The recorded information includes the identity of the API caller, the time of the API call, the source IP address of the API caller, the request parameters, and the response elements returned by the AWS service.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

AWS CloudTrail provides a history of AWS API calls for customer accounts, including API calls made via the AWS Management Console, AWS SDKs, command line tools, and higher-level AWS services (such as AWS CloudFormation). The AWS API call history produced by AWS CloudTrail enables security analysis, resource change tracking, and compliance auditing.

AWS CodeDeploy

AWS CodeDeploy is a deployment service that automates software deployments to a variety of compute services such as Amazon EC2, AWS Fargate, AWS Lambda, and the customer’s on-premises servers. AWS CodeDeploy allows customers to rapidly release new features, helps avoid downtime during application deployment, and handles the complexity of updating the applications.

AWS Config

AWS Config enables customers to assess, audit, and evaluate the configurations of their AWS resources. AWS Config continuously monitors and records AWS resource configurations and allows customers to automate the evaluation of recorded configurations against desired configurations. With AWS Config, customers can review changes in configurations and relationships between AWS resources, dive into detailed resource configuration histories, and determine overall compliance against the configurations specified within the customers’ internal guidelines. This enables customers to simplify compliance auditing, security analysis, change management, and operational troubleshooting.

AWS Control Tower

AWS Control Tower provides the easiest way to set up and govern a new, secure, multi-account AWS environment based on AWS’ best practices established through AWS’ experience working with thousands of enterprises as they move to the cloud. With AWS Control Tower, builders can provision new AWS accounts that conform to customer policies. If customers are building a new AWS environment, starting out on the journey to AWS, starting a new cloud initiative, or are completely new to AWS, Control Tower will help customers get started quickly with governance and AWS’ best practices built-in.

AWS Database Migration Service (DMS)

AWS Database Migration Service (DMS) is a cloud service that enables customers to migrate relational databases, data warehouses, NoSQL databases, and other types of data stores. AWS DMS can be used to migrate data into the AWS Cloud, between on-premises instances (through AWS Cloud setup), or between combinations of cloud and on-premises setups. The service supports homogenous migrations within one database platform, as well as heterogeneous migrations between different database platforms. AWS Database Migration Service can also be used for continuous data replication with high availability.

AWS DataSync

AWS DataSync is an online data transfer service that simplifies data migration and helps you quickly, easily, and securely transfer your file or object data to, from, and between AWS storage services.

AWS Direct Connect

AWS Direct Connect enables customers to establish a dedicated network connection between their network and one of the AWS Direct Connect locations. Using AWS Direct Connect, customers can establish private connectivity between AWS and their data center, office, or colocation environment.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

AWS Directory Service (excludes Simple AD)

AWS Directory Service for Microsoft Active Directory, also known as AWS Managed Microsoft Active Directory (AD), enables customers' directory-aware workloads and AWS resources to use managed Active Directory in the AWS Cloud. AWS Managed Microsoft AD stores directory content in encrypted Amazon Elastic Block Store volumes using encryption keys. Data in transit to and from Active Directory clients is encrypted when it travels through Lightweight Directory Access Protocol (LDAP) over customers' Amazon Virtual Private Cloud (VPC) network. If an Active Directory client resides in an off-cloud network, the traffic travels to customers' VPC by a virtual private network link or an AWS Direct Connect link.

AWS Glue

AWS Glue is an extract, transform, and load (ETL) service that makes it easy for customers to prepare and load their data for analytics. The customers can create and run an ETL job with a few clicks in the AWS Management Console.

AWS Health Dashboard

AWS Health Dashboard provides alerts and remediation guidance when AWS is experiencing events that may impact customers. While the AWS Health Dashboard displays the general status of AWS services, AWS Health Dashboard gives customers a personalized view into the performance and availability of the AWS services underlying customer's AWS resources.

The dashboard displays relevant and timely information to help customers manage events in progress and provides proactive notification to help customers plan for scheduled activities. With AWS Health Dashboard, alerts are triggered by changes in the health of AWS resources, giving event visibility, and guidance to help quickly diagnose and resolve issues.

AWS Identity and Access Management (IAM)

AWS Identity and Access Management is a web service that helps customers securely control access to AWS resources for their users. Customers use IAM to control who can use their AWS resources (authentication) and what resources they can use and in what ways (authorization). Customers can grant other people permission to administer and use resources in their AWS account without having to share their password or access key. Customers can grant different permissions to different people for different resources. Customers can use IAM features to securely give applications that run on EC2 instances the credentials that they need in order to access other AWS resources, like S3 buckets and RDS or DynamoDB databases.

AWS Key Management Service (KMS)

AWS Key Management Service (KMS) allows users to create and manage cryptographic keys. One class of keys, KMS keys, are designed to never be exposed in plaintext outside the service. KMS keys can be used to encrypt data directly submitted to the service. KMS keys can also be used to protect other types of keys, data keys which are created by the service and returned to the user's application for local use. AWS KMS only creates and returns data keys to users; the service does not store or manage data keys.

AWS KMS is integrated with several AWS services so that users can request that resources in those services are encrypted with unique data keys provisioned by KMS that are protected by a KMS key the user chooses at the time the resource is created (**Control AWS-4.6**). See in-scope services integrated with KMS at <https://aws.amazon.com/kms/>. Integrated services use the data keys from AWS KMS.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Data keys provisioned by AWS KMS are encrypted with a 256-bit key unique to the customer’s account under a defined mode of AES – Advanced Encryption Standard **(Control AWS-4.7)**.

When a customer requests AWS KMS to create a KMS key, the service creates a key ID for the KMS key and key material, referred to as a backing key, which is tied to the key ID of the KMS key. The 256-bit backing key can only be used for encrypt or decrypt operations by the service **(Control AWS-4.10)**. KMS will generate an associated key ID if a customer chooses to import their own key. If the customer chooses to enable key rotation for a KMS key with a backing key that the service generated, AWS KMS will create a new version of the backing key for each rotation event, but the key ID remains the same **(Control AWS-4.11)**. All future encrypt operations under the key ID will use the newest backing key, while all previous versions of backing keys are retained to decrypt ciphertexts created under the previous version of the key. Backing keys and customer-imported keys are encrypted under AWS-controlled keys when created/imported and they are only ever stored on disk in encrypted form.

All requests to AWS KMS APIs are logged and available in the AWS CloudTrail of the requester and the owner of the key. The logged requests provide information about who made the request, under which KMS key, and describes information about the AWS resource that was protected through the use of the KMS key. These log events are visible to the customer after turning on AWS CloudTrail in their account **(Control AWS-4.8)**.

AWS KMS creates and manages multiple distributed replicas of KMS keys and key metadata automatically to enable high availability and data durability. KMS keys themselves are regional objects; KMS keys can only be used in the AWS region in which they were created. KMS keys are only stored on persistent disk in encrypted form and in two separate storage systems to ensure durability. When a KMS key is needed to fulfill an authorized customer request, it is retrieved from storage, decrypted on one of many AWS KMS hardened security modules (HSMs) in the region, then used only in memory to execute the cryptographic operation (e.g., encrypt or decrypt). Future requests to use the KMS key each require the decryption of the KMS key in memory for another one-time use.

AWS KMS endpoints are only accessible via TLS using the following cipher suites that support forward secrecy **(Control AWS-4.9)**:

- TLS_AES_128_GCM_SHA256
- TLS_AES_256_GCM_SHA384
- TLS_CHACHA20_POLY1305_SHA256
- ECDHE-RSA-AES256-GCM-SHA384
- ECDHE-RSA-AES128-GCM-SHA256
- ECDHE-RSA-AES256-SHA384
- ECDHE-RSA-AES256-SHA
- ECDHE-RSA-AES128-SHA256
- DHE-RSA-AES256-SHA256
- DHE-RSA-AES128-SHA256
- DHE-RSA-AES256-SHA
- DHE-RSA-AES128-SHA



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

By design, no one can gain access to KMS key material. KMS keys are only ever present on hardened security modules for the amount of time needed to perform cryptographic operations under them. AWS employees have no tools to retrieve KMS keys from these hardened security modules. In addition, multi-party access controls are enforced for operations on these hardened security modules that involve changing the software configuration or introducing new hardened security modules into the service. These multi-party access controls minimize the possibility of an unauthorized change to the hardened security modules, exposing key material outside the service, or allowing unauthorized use of customer keys (**Control AWS-4.5**). Additionally, key material used for disaster recovery processes by KMS are located with the EU and physically secured such that no AWS employee can gain access (**Control AWS-4.12**). Access attempts to recovery key materials are reviewed by authorized AWS European Sovereign Cloud operators on a periodic basis (**Control AWS-4.13**). Roles and responsibilities for those cryptographic custodians with access to systems that store or use key material are formally documented and acknowledged (**Control AWS-1.6**).

AWS Lake Formation

AWS Lake Formation is an integrated data lake service that makes it easy for customers to ingest, clean, catalog, transform, and secure their data and make it available for analysis and ML. AWS Lake Formation gives customers a central console where they can discover data sources, set up transformation jobs to move data to an Amazon Simple Storage Service (S3) data lake, remove duplicates and match records, catalog data for access by analytic tools, configure data access and security policies, and audit and control access from AWS analytic and ML services. Lake Formation automatically manages access to the registered data in Amazon S3 through services including AWS Glue, Amazon Athena, Amazon Redshift, Amazon QuickSight, and Amazon EMR to ensure compliance with customer defined policies. With AWS Lake Formation, customers can configure and manage their data lake without manually integrating multiple underlying AWS services.

AWS Lambda

AWS Lambda lets customers run code without provisioning or managing servers on their own. AWS Lambda uses a compute fleet of Amazon Elastic Compute Cloud (Amazon EC2) instances across multiple AZs in a region, which provides the high availability, security, performance, and scalability of the AWS infrastructure.

AWS License Manager

AWS License Manager makes it easier to manage licenses in AWS and on-premises servers from software vendors. AWS License Manager allows customer’s administrators to create customized licensing rules that emulate the terms of their licensing agreements, and then enforces these rules when an instance of EC2 gets launched. Customer administrators can use these rules to limit licensing violations, such as using more licenses than an agreement stipulates or reassigning licenses to different servers on a short-term basis. The rules in AWS License Manager also enable customers to limit a licensing breach by stopping the instance from launching or by notifying the customer administrators about the infringement. Customer administrators gain control and visibility of all their licenses with the AWS License Manager dashboard and reduce the risk of non-compliance, misreporting, and additional costs due to licensing overages.

AWS License Manager integrates with AWS services to simplify the management of licenses across multiple AWS accounts, IT catalogs, and on-premises, through a single AWS account.



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

AWS Organizations

AWS Organizations helps customers centrally govern their environment as customers grow and scale their workloads on AWS. Whether customers are a growing startup or a large enterprise, Organizations helps customers to centrally manage billing; control access, compliance, and security; and share resources across customer AWS accounts.

Using AWS Organizations, customers can automate account creation, create groups of accounts to reflect their business needs, and apply policies for these groups for governance. Customers can also simplify billing by setting up a single payment method for all of their AWS accounts. Through integrations with other AWS services, customers can use Organizations to define central configurations and resource sharing across accounts in their organization.

AWS Private Certificate Authority

AWS Private Certificate Authority (CA) is a managed private CA service enables customers to easily and securely manage the lifecycle of their private certificates. Private CA allows developers to be more agile by providing them APIs to create and deploy private certificates programmatically. Customers also have the flexibility to create private certificates for applications that require custom certificate lifetimes or resource names. With Private CA, customers can create and manage private certificates for their connected resources in one place with a secure, pay as you go, managed private CA service.

AWS Resource Access Manager (RAM)

AWS Resource Access Manager helps customers securely share their resources across AWS accounts, within their organization or organizational units (OUs) in AWS Organizations, and with IAM roles and IAM users for supported resource types. Customers are able to use AWS Resource Access Manager to share transit gateways, subnets, AWS License Manager license configurations, Amazon Route 53 Resolver rules, and more resource types.

AWS Secrets Manager

AWS Secrets Manager helps customers protect secrets needed to access their applications, services, and IT resources. The service enables customers to easily rotate, manage, and retrieve database credentials, API keys, and other secrets throughout their lifecycle. Users and applications retrieve secrets with a call to Secrets Manager APIs, eliminating the need to hard-code sensitive information in plain text. Secrets stored within Secrets Manager are protected by AWS Key Management Service (KMS) using either customer-managed or AWS-managed encryption keys. Secrets Manager offers secret rotation and managed secrets with built-in integration for a number of services including Amazon RDS for MySQL, PostgreSQL, Amazon Aurora, Amazon DocumentDB, Amazon Redshift, and Amazon ECS Service Connect. AWS Secrets Manager also integrates with third party secrets management vendors such as Hashicorp and CyberArk. In addition, Secrets Manager enables customers to control access to secrets (using the full range of fine-grained policies available with AWS Identity & Access Management), enables auditing of secret configurations centrally through AWS Config and AWS Security Hub CSPM for resources in the AWS Cloud And provides support multi-cloud and on-premises consumption of Secrets via IAM Roles Anywhere.

AWS Security Hub CSPM (formerly known as AWS Security Hub)

AWS Security Hub CSPM gives customers a comprehensive view of their high-priority security alerts and compliance status across AWS accounts. There are a range of powerful security tools at customers'



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

disposal, from firewalls and endpoint protection to vulnerability and compliance scanners. With Security Hub, customers can now have a single place that aggregates, organizes, and prioritizes their security alerts, or findings, from multiple AWS services, such as Amazon GuardDuty, Amazon Inspector Classic, and Amazon Macie, as well as from AWS Partner solutions. Findings are visually summarized on integrated dashboards with actionable graphs and tables.

AWS Shield

AWS Shield is a managed Distributed Denial of Service (DDoS) protection service that safeguards web applications running on AWS. AWS Shield provides always-on detection and automatic inline mitigations that minimize application downtime and latency, so there is no need to engage AWS Support to benefit from DDoS protection.

AWS Step Functions

AWS Step Functions is a web service that enables customers to coordinate the components of distributed applications and microservices using visual workflows. Customers can build applications from individual components that each perform a discrete function, or task, allowing them to scale and change applications quickly. Step Functions provides a reliable way to coordinate components and step through the functions of a customer’s application. Step Functions provides a graphical console to visualize the components of a customer’s application as a series of steps. It automatically triggers and tracks each step, and retries when there are errors, so the customer’s application executes in order and as expected, every time. Step Functions logs the state of each step, so when things do go wrong, customers can diagnose and debug problems quickly.

AWS Storage Gateway

The AWS Storage Gateway service connects customers’ off-cloud software appliances with cloud-based storage. The service enables organizations to store data in AWS’ highly durable cloud storage services: Amazon S3 and Amazon Glacier.

AWS Storage Gateway backs up data off-site to Amazon S3 in the form of Amazon EBS snapshots. AWS Storage Gateway transfers data to AWS and stores this data in either Amazon S3 or Amazon Glacier, depending on the use case and type of gateway used. There are three types of gateways: Tape, File, and Volume Gateways. The Tape Gateway allows customers to store more frequently accessed data in Amazon S3 and less frequently accessed data in Amazon Glacier.

The File Gateway allows customers to copy data to S3 and have those files appear as individual objects in S3. Volume gateways store data directly in Amazon S3 and allow customers to snapshot their data so that they can access previous versions of their data. These snapshots are captured as Amazon EBS Snapshots, which are also stored in Amazon S3. Both Amazon S3 and Amazon Glacier redundantly store these snapshots on multiple devices across multiple facilities, detecting and repairing any lost redundancy. The Amazon EBS snapshot provides a point-in-time backup that can be restored off-cloud or on a gateway running in Amazon EC2 or used to instantiate new Amazon EBS volumes. Data is stored within a single region that customers specify.

AWS Systems Manager

AWS Systems Manager gives customers the visibility and control to their infrastructure on AWS. AWS Systems Manager provides customers a unified user interface so that customers can view their operational data from multiple AWS services, and it allows customers to automate operational tasks across the AWS resources.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

With AWS Systems manager, customers can group resources, like Amazon EC2 instances, Amazon S3 buckets, or Amazon RDS instances, by application, view operational data for monitoring and troubleshooting, and take action on groups of resources.

AWS Transfer Family

AWS Transfer Family enables the transfer of files directly into and out of Amazon S3. With the support for Secure File Transfer Protocol (SFTP) - also known as Secure Shell (SSH) File Transfer Protocol, the File Transfer Protocol over SSL (FTPS) and the File Transfer Protocol (FTP), the AWS Transfer Family helps the customers seamlessly migrate their file transfer workflows to AWS by integrating with existing authentication systems and providing DNS routing with Amazon Route 53.

AWS WAF

AWS WAF is a web application firewall that helps protect customer web applications from common web exploits that could affect application availability, compromise security, or consume excessive resources.

Customers can use AWS WAF to create custom rules that block common attack patterns, such as SQL injection or cross-site scripting, and rules that are designed for their specific application. New rules can be deployed within minutes, letting customers respond quickly to changing traffic patterns. Also, AWS WAF includes a full-featured API that customers can use to automate the creation, deployment, and maintenance of web security rules.

AWS X-Ray

AWS X-Ray helps developers analyze and debug production, distributed applications, such as those built using a microservices architecture. With X-Ray, customers or developers can understand how their application and its underlying services are performing to identify and troubleshoot the root cause of performance issues and errors. X-Ray provides an end-to-end view of requests as they travel through the customers’ application and shows a map of the application’s underlying components. Customers or developers can use X-Ray to analyze both applications in development and in production.

EC2 Image Builder

EC2 Image Builder makes it easier to automate the creation, management, and deployment of customized, secure, and up-to-date “golden” server images that are pre-installed and pre-configured with software and settings to meet specific IT standards.

Elastic Load Balancing (ELB)

Elastic Load Balancing (ELB) provides customers with a load balancer that automatically distributes incoming application traffic across multiple Amazon EC2 instances in the cloud. It allows customers to achieve greater levels of fault tolerance for their applications, seamlessly providing the required amount of load balancing capacity needed to distribute application traffic.

D.4 Secure Data Handling

AWS provides many methods for customers to securely handle their data. AWS enables customers to open a secure, encrypted channel to AWS European Sovereign Cloud servers using HTTPS (TLS/SSL).



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Amazon S3 provides a mechanism that enables users to utilize MD5 checksums to validate that data sent to AWS is bitwise identical to what is received, and that data sent by Amazon S3 is identical to what is received by the user. When customers choose to provide their own keys for encryption and decryption of Amazon S3 objects (S3 SSE-C), Amazon S3 does not store the encryption key provided by the customer. Amazon S3 generates and stores a one-way salted HMAC of the customer encryption key and that salted HMAC value is not logged **(Control AWSCA-4.4)**.

Upon initial communication with an AWS-provided Windows AMI, AWS enables secure communication by configuring Terminal Services on the instance by generating a unique self-signed X.509 server certificate and delivering the certificate’s thumbprint to the user over a trusted channel **(Control AWSCA-4.2)**.

AWS European Sovereign Cloud further enables secure communication with Linux AMIs by configuring SSH on the instance, generating a unique host-key and delivering the key’s fingerprint to the user over a trusted channel **(Control AWSCA-4.1)**.

Connections between customer applications and Amazon RDS MySQL instances can be encrypted using TLS/SSL. Amazon RDS generates a TLS/SSL certificate for each database instance, which can be used to establish an encrypted connection using the default MySQL client. Once an encrypted connection is established, data transferred between the database instance and a customer’s application will be encrypted during transfer. If customers require data to be encrypted while “at rest” in the database, the customer application must manage the encryption and decryption of data. Additionally, customers can set up controls to have their database instances only accept encrypted connections for specific user accounts.

D.5 Physical Security and Environmental Protection

Amazon has significant experience in designing, constructing, and operating large-scale data centers. This experience has been applied to the AWS European Sovereign Cloud system and infrastructure. Refer to the “AWS European Sovereign Cloud System Overview” section above for list of in-scope data centers.

Physical Security

AWS Inc. provides physical access to its data centers for approved employees and contractors who have a legitimate business need for such privileges. Access to data centers must be approved by an authorized individual **(Control AWSCA-5.1)**. All visitors are required to present identification and are signed in and escorted by authorized staff.

When an employee or contractor no longer requires data center access, their access is promptly revoked, even if they continue to be an employee or contractor of Amazon or AWS. In addition, access is automatically revoked when an employee or contractor’s record is terminated in Amazon’s HR system **(Control AWSCA-5.2)**. Cardholder access to data centers is reviewed quarterly. Cardholders marked for removal have their access automatically revoked as part of the review **(Control AWSCA-5.3)**.

AWS European Sovereign Cloud data centers are located within the EU. The physical access and security controls described above are also deployed by AWS European Sovereign Cloud with additional physical security controls designed to prevent unauthorized access to infrastructure containing Customer Content and/or Customer-Created Metadata. Unescorted physical access to Key Data Center



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Areas within the AWS European Sovereign Cloud is restricted to AWS European Sovereign Cloud Staff and Approved Vendor Personnel for whom the vendor has provided attestation that personnel meet EU residency requirement and who have been approved through AWS European Sovereign Cloud Entity's vendor vetting process (**Control AWSCA-20.12**).

Physical access is controlled both at the perimeter and at building ingress points by professional security staff utilizing video surveillance, intrusion detection systems, and badge and pin electronic means. Authorized staff utilize multi-factor authentication mechanisms to access data center floors (**Control AWSCA-5.4, AWSCA-5.5, and AWSCA-5.6**).

Amazon owns and operates many of its data centers, while others are housed in colocation spaces that are offered by various reputable companies under contract with Amazon. The physical access and security controls described above are also deployed by AWS European Sovereign Cloud Entity at colocation spaces.

Contracts with third-party colocation providers include provisions to support the protection of AWS European Sovereign Cloud assets and communication of incidents or events that impact Amazon assets and/or customers to AWS European Sovereign Cloud (**Control AWSCA-5.11**). In addition, AWS Inc. provides monitoring of adherence with security and operational standards by performing periodic reviews of colocation service providers at least once per calendar year (**Control AWSCA-5.12**). AWS Inc. performs additional reviews as necessary based on the contracts and level of engagement with the colocation service provider.

AWS European Sovereign Cloud spaces within colocation facilities are installed with AWS European Sovereign Cloud-operated closed circuit television (CCTV) cameras, intrusion detection systems, and access control devices that alert AWS European Sovereign Cloud Staff of access and incidents. Physical access to AWS European Sovereign Cloud spaces within colocation facilities is controlled by AWS European Sovereign Cloud and follows standard AWS access management processes.

Redundancy

Data centers are designed to anticipate and tolerate failure while maintaining service levels. AWS European Sovereign Cloud Region is comprised of multiple data centers. All data centers are online and serving traffic; no data center is “cold.” In case of failure, automated processes move traffic away from the affected area. Core applications are deployed to an N+1 standard, so that in the event of a data center failure, there is sufficient capacity to enable traffic to be load-balanced to the remaining sites.

Fire Detection and Suppression

Automatic fire detection and suppression equipment has been installed to reduce risk. The fire detection system utilizes smoke detection sensors in Amazon-owned data center environments (e.g., multi-point aspirating smoke detection (MASD), point source detection), mechanical and electrical infrastructure spaces, chiller rooms, and generator equipment rooms. These areas are protected by either wet-pipe, double-interlocked pre-action, or gaseous sprinkler systems (**Control AWSCA-5.7**).

Power

The data center electrical power systems supporting AWS European Sovereign Cloud are designed to be fully redundant and maintainable without impact to operations, 24 hours a day, and Uninterruptible Power Supply (UPS) units provide back-up power in the event of an electrical failure for critical and essential loads in Amazon-owned data centers and third-party colocation sites where Amazon



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

maintains the UPS units. Amazon-owned data centers use generators to provide back-up power for the facility (**Control AWSCA-5.9** and **AWSCA-5.10**).

Climate and Temperature

Climate control is required to maintain a controlled operating temperature for servers and other hardware, preventing overheating and reducing the possibility of service outages. Amazon-owned data centers are conditioned to maintain environmental conditions at specified levels. Personnel and systems monitor and control temperature and humidity at appropriate levels. This is provided at N+1 and utilizes free cooling as primary source of cooling where it is available based on local environmental conditions (**Control AWSCA-5.8**).

Environment Management

In Amazon-owned data centers, AWS European Sovereign Cloud Entity monitors electrical, mechanical, and life support systems and equipment so that any issues are immediately identified. This is carried out via daily rounds and readings, in tandem with an overview of our data centers provided via AWS’ Building Management System (BMS) and Electrical Monitoring System (EMS). Preventative maintenance is performed to maintain the continued operability of equipment utilizing the Enterprise Asset Management (EAM) tool and trouble ticketing and change management system. The primary objective of this process is to provide a holistic insight into Mechanical, Electrical, Plumbing (MEP) Assets owned by AWS infrastructure teams. This includes providing a centralized repository for equipment, optimizing planned and unplanned maintenance and managing data center critical spare parts.

Management of Media

When a storage device has reached the end of its useful life, AWS Inc. procedures include a decommissioning process that is designed to prevent unauthorized access to assets. AWS uses techniques detailed in NIST 800-88 (“Guidelines for Media Sanitization”) as part of the decommissioning process. All production media is securely decommissioned by AWS European Sovereign Cloud Staff in accordance with industry-standard practices (**Control AWSCA-5.13**). Production media is not removed from AWS European Sovereign Cloud control until it has been securely decommissioned.

D.6 Change Management

Software

AWS Inc. applies a systematic approach to managing changes so that changes to customer impacting services are reviewed, tested, approved, and well communicated. Change management procedures/policies are based on Amazon change management guidelines and tailored to the specifics of each AWS service (**Control AWSCA-6.1**). These processes are documented and communicated to the necessary personnel by service team management.

The goal of AWS Inc.’ change management process is to prevent unintended service disruptions and maintain the integrity of service to the customer. Change details are documented in one of Amazon’s change management or deployment tools (**Control AWSCA-6.2**).



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

Prior to deployment to production environments, changes are:

- Developed in a development environment that is segregated from the production environment **(Control AWSCA-6.4)**.
- Reviewed by peers for technical aspects and appropriateness **(Control AWSCA-6.5)**.
- Tested to confirm the changes will behave as expected when applied and not adversely impact performance **(Control AWSCA-6.3)**.
- Approved by authorized team members to provide appropriate oversight and understanding of business impact **(Control AWSCA-6.5)**.

Changes are typically pushed into production in a phased deployment starting with the lowest impact sites. Deployments are closely monitored so impact can be evaluated. Service owners have a number of configurable metrics that measure the health of the service's upstream dependencies. These metrics are closely monitored with thresholds and alarming in place (e.g., latency, availability, fatal errors, CPU utilization, etc.). Customer information, including personal information, Customer Content and Customer-Created Metadata are not used in test and development environments **(Control AWSCA-6.7)**. Rollback procedures are documented so that team members can revert back to the previous state if needed.

When possible, changes are scheduled during regular change windows. Emergency changes to production systems that require deviations from standard change management procedures are associated with an incident and are logged and approved as appropriate.

AWS European Sovereign Cloud Entity implements an internal deployment approval tool within the AWS European Sovereign Cloud to manage the deployment of software changes. The tool operates separately from the global infrastructure, and only authorized AWS European Sovereign Cloud Staff who meet sovereign access requirements are granted access. Every code change to services available in the AWS European Sovereign Cloud results in a deployment task that is sent from the global environment to the sovereign environment for processing. Authorized AWS European Sovereign Cloud Staff retain the ability to invoke a procedure that blocks deployments and requires manual review. When this procedure is triggered, all software changes are blocked until an authorized AWS European Sovereign Cloud Staff approves or rejects each task **(Control AWSCA-20.5)**.

AWS Inc. performs deployment validations and change reviews to detect unauthorized changes to its environment and tracks identified issues to resolution. AWS Inc. management reviews and tracks deployment violations for services enrolled in the Deployment Monitoring program as part of the AWS Security business review. For those services not enrolled in the Deployment Monitoring program, a secondary monthly review of deployments is conducted within 60 days of the month in which they were made. If any unauthorized changes are detected or deviates from the standard review and approval process, they are tracked to resolution **(Control AWSCA-6.6)**.

Infrastructure

AWS Inc. internally developed configuration management software is installed when new hardware is provisioned. These tools are run on all UNIX hosts to validate that they are configured, and software is installed in a standard manner based on host classes and updated regularly.

Only approved users with verified business needs are authorized through a permissions service may log in to the central configuration management servers. Host configuration settings are monitored to



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

validate compliance with AWS security standards and automatically pushed to the host fleet (**Control AWSCA-9.4**).

Emergency, non-routine and other configuration changes to existing AWS European Sovereign Cloud infrastructure are authorized, logged, tested, approved and documented in accordance with industry norms for similar systems. Updates to AWS infrastructure are performed in such a manner to minimize impact to the customer and their service use. AWS communicates with customers, either via email, or through the AWS European Sovereign Cloud Health Dashboard (<https://health.amazonaws-eusc.eu/health/status>) when service use may be adversely affected.

D.7 Data Integrity, Availability, Redundancy and Data Retention

AWS seeks to maintain data integrity through all phases including transmission, storage, and processing.

Amazon S3 utilizes checksums internally to confirm the continued integrity of data in transit within the system and at rest. Amazon S3 provides a facility for customers to send checksums along with data transmitted to the service. The latest AWS SDKs, CLI, and the S3 console calculate these checksums automatically. The service validates the checksum upon receipt of the data to determine that no corruption occurred in transit. S3 currently supports the CRC64NVME, CRC32, CRC32C, SHA1, and SHA256 algorithms for integrity validation. The MD5 algorithm is also supported for customers utilizing older SDKs that provide their own checksum for integrity of data in transit. Regardless of whether a checksum is sent with an object to Amazon S3, the service utilizes checksums internally to confirm the continued integrity of data in transit within the system and at rest. When disk corruption or device failure is detected, the system automatically attempts to restore normal levels of object storage redundancy (**Control AWSCA-7.1, AWSCA-7.2, and AWSCA-7.3**).

AWS European Sovereign Cloud services and systems hosting Customer Content are designed to retain Customer Content until the customer removes it or the customer agreement ends (**Control AWSCA-7.8**). Once the contractual obligation to retain content ends, or upon a customer-initiated action to remove or delete content, AWS European Sovereign Cloud services have processes and procedures to detect a deletion and make the content inaccessible. AWS utilizes Amazon Simple Storage Service (S3), Amazon Elastic Compute Cloud (EC2), Amazon Elastic Block Store (EBS), and Amazon DynamoDB, as the primary services for Customer Content storage, which individually or in combination are also utilized by many of the other AWS European Sovereign Cloud services listed in the System Overview for storage of Customer Content. Amazon Relational Database Service (RDS) Aurora, Amazon Simple Queue Service (SQS), AWS Secrets Manager, and Amazon Elastic File System (EFS) utilize local storage to store Customer Content but are not utilized for content storage functionalities by other services, similar to the primary AWS European Sovereign Cloud content storage services. When customers request data to be deleted, automated processes are initiated to remove the data and render the content unreadable (**Control AWSCA-7.7**).

Availability

The AWS Resiliency Program encompasses the processes and procedures by which AWS identifies, responds to, and recovers from a major availability event or incident within the AWS European Sovereign Cloud services environment. This program builds upon the traditional approach of addressing contingency management which incorporates elements of business continuity and disaster recovery plans and expands this to consider critical elements of proactive risk mitigation strategies,



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

such as engineering physically separate Availability Zones (AZs) and continuous infrastructure capacity planning.

AWS Inc. contingency plans and incident response playbooks are maintained and updated to reflect emerging risks and lessons learned from past incidents. Service team response plans are tested and updated through the due course of business, and the AWS Resiliency Plan is tested, reviewed, and approved by senior leadership annually (**Control AWSCA-10.3**).

AWS Inc. has identified critical system components required to maintain the availability of the system and recover service in the event of outage. Critical system components, such as code bases, are backed up across multiple, isolated locations known as Availability Zones. These system components do not store Customer Content, or Customer-Created Metadata. Each Availability Zone runs on its own physically distinct, independent infrastructure, and is engineered to be highly reliable. Common points of failure, like generators and cooling equipment, are not shared across Availability Zones. Additionally, Availability Zones are physically separate, and designed such that even extremely uncommon disasters, such as fires, tornados, or flooding should only affect a single Availability Zone. AWS Inc. replicates critical system components across multiple Availability Zones, and authoritative backups are maintained and monitored to ensure successful replication (**Control AWSCA-10.1** and **AWSCA-10.2**).

The AWS European Sovereign Cloud Entity maintains dedicated, physically distinct infrastructure within the EU that is designed to operate independently of AWS Inc., infrastructure components or resources outside the defined geographical and logical boundaries (**Control AWSCA-20.2**). To support this independent operation, AWS European Sovereign Cloud Staff maintain dedicated runbooks and standard operating procedures to ensure continuous service delivery for core compute, storage, identity, and monitoring capabilities (**Control AWSCA-20.4**). AWS conducts business continuity exercises at least annually for the AWS European Sovereign Cloud to test the ability to maintain essential operation in the event of complete disconnection from the AWS Backbone Network (**Control AWSCA-20.3**).

To further support operational resilience, AWS European Sovereign Cloud Entity maintains a replica of source code required to operate AWS European Sovereign Cloud services within the AWS European Sovereign Cloud Region. The replica is protected with encryption and integrity controls, and updated through a controlled replication process from authoritative sources. The replica is independently accessible by AWS European Sovereign Cloud Staff in the event of disconnection from the AWS Backbone Network (**Control AWSCA-20.11**).

Data Backup

AWS core storage services have the capability to be redundantly stored in multiple physical locations as part of normal operations. Customers should enable backups of their data across AWS European Sovereign Cloud services.

Amazon S3 is designed to provide 99.99999999% durability and 99.99% availability of objects over a given year. Objects are redundantly stored on multiple devices across multiple facilities in an Amazon S3 region. To help provide durability, Amazon S3 PUT and COPY operations synchronously store Customer Content across multiple facilities before returning SUCCESS. Once stored, Amazon S3 helps maintain the durability of the objects by detecting and repairing lost redundancy. Amazon S3 also regularly verifies the integrity of data stored using checksums. If corruption is detected, it is repaired using redundant data. In addition, Amazon S3 calculates checksums on all network traffic to detect corruption of data packets when storing or retrieving data (**Control AWSCA-7.3**, **AWSCA-7.4**, and **AWSCA-7.5**).



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Amazon EBS replication is stored within the same AZ, not across multiple zones, but customers have the ability to conduct regular snapshots to Amazon Simple Storage Service (S3) in order to provide long-term data durability. For customers who have architected complex transactional databases using Amazon EBS, backups to Amazon S3 can be performed through the database management system so that distributed transactions and logs can be checkpointed. AWS European Sovereign Cloud does not perform backups of data that are maintained on virtual disks attached to running instances on Amazon EC2.

Amazon RDS provides two different methods for backing up and restoring customer DB Instance(s): automated backups and database snapshots (DB Snapshots). Turned on by default, the automated backup feature of Amazon RDS enables point-in-time recovery for a DB Instance. Amazon RDS will back up databases and transaction logs and store both for a user-specified retention period. This allows for restoration of a DB Instance to any second during the defined retention period, up to the last five minutes. The automatic backup retention period can be configured to up to 35 days. During the backup window, storage input/output (I/O) may be suspended for a few seconds, while data is being backed up. This I/O suspension is avoided with Multi-AZ DB deployments, since the backup is taken from the standby. DB Snapshots are user-initiated backups of DB Instances. These full database backups will be stored by Amazon RDS until customers explicitly delete them. Customers can create a new DB Instance from a DB Snapshot as needed (**Control AWSCA-7.6**).

The AWS Inc. team responsible for capacity management continuously monitors service usage to project infrastructure needs for availability commitments and requirements. AWS Inc. maintains a capacity planning model to assess infrastructure usage and demands at least monthly, and usually more frequently (e.g., weekly). In addition, the AWS capacity planning model supports the planning of future demands to acquire and implement additional resources based upon current resources and forecasted requirements (**Control AWSCA-10.4**).

D.8 Confidentiality

AWS classifies information provided by customer into categories including Customer Content, Customer-Created Metadata and account information. AWS defines Customer Content as software (including machine images), data, text, audio, video, or images that a customer or any end user transfers to AWS for processing, storage, or hosting by AWS services in connection with that customer's account, and any computational results that a customer or any end user derives from the foregoing through their use of AWS services. For example, Customer Content includes content that a customer or any end user stores in Amazon Simple Storage Service (S3). AWS defines Customer-Created Metadata as metadata that a customer creates to manage and configure AWS resources, including the roles, permissions, resource labels, and configurations a customer uses to run AWS. For example, Customer-Created Metadata includes customer-supplied tags, resource identifiers, system configurations, and AWS Identity and Access Management policies. The terms of the AWS Customer Agreement (<https://aws.amazon.com/agreement/>) and AWS Service Terms (<https://aws.amazon.com/service-terms/>) apply to Customer Content (**Controls AWSCA-12.1, AWSCA-11.3**). For the AWS European Sovereign Cloud, the AWS European Sovereign Cloud Addendum (<https://aws.eu/esca/>) applies to Customer Content and Customer-Created Metadata (**Control AWSCA-20.8**), including commitments that AWS personnel who are not EU residents and/or are outside of the EU do not have access to Customer Content or Customer-Created Metadata, and that AWS will not move or copy Customer Content or Customer-Created Metadata outside the EU except



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

as instructed by the customer or as necessary to comply with a valid and binding order of a governmental body(**Control AWSCA-20.6**).

Account Information is information about a customer that a customer provides to AWS in connection with the creation or administration of a customer account. For example, Account Information includes names, usernames, phone numbers, email addresses, and billing information associated with a customer account. Any information submitted by the customer that AWS needs in order to provide services to the customer or in connection with the administration of customer accounts, is not in-scope for this report.

The AWS Privacy Notice is available from the AWS website at <https://aws.amazon.com/privacy/>. The AWS Privacy Notice is reviewed by the AWS Legal team and is updated as required to reflect Amazon’s current business practices and global regulatory requirements. The Privacy Notice describes how AWS collects and uses a customer’s personal information in relation to AWS websites, applications, products, services, events, and experiences. The Privacy Notice does not apply to Customer Content. AWS’ systems and services are designed to enable authenticated AWS customers to access and manage their content. AWS notifies customers of third-party access to a customer’s content on the third-party access page located at <https://aws.amazon.com/compliance/third-party-access>. AWS may remove a customer’s content when compelled to do so by a legal order, or where there is evidence of fraud or abuse as described in the Customer Agreement (<https://aws.amazon.com/agreement/>) and Acceptable Use Policy (<https://aws.amazon.com/aup/>). In executing the removal of a customer’s content due to the reasons stated above, employees may render it inaccessible as the situation requires. For clarity, this capability to render Customer Content inaccessible extends to encrypted content as well.

The AWS Customer Agreement and AWS European Sovereign Cloud Addendum inform AWS European Sovereign Cloud customers of the AWS data security commitments prior to activating an AWS account and is made available to customers to review at any time on the AWS website (**Control AWSCA-12.1**). The AWS European Sovereign Cloud Addendum outlines roles, responsibilities, and obligations for protecting Customer Content and/or Customer-Created Metadata, including data subject to applicable data protection laws (**Control AWSCA-20.8**).

Additionally, the AWS Customer Agreement notes how AWS secures and retains Customer Content, including commitments regarding disclosure limitations. AWS also informs customers of updates to the Customer Agreement by making it available on its website and providing the last updated date. Customers should check the Customer Agreement website frequently for any changes to the Customer Agreement (**Control AWSCA-12.2**).

The European Sovereign Cloud customer determines what data is entered into AWS European Sovereign Cloud services and has the ability to configure the appropriate security and privacy settings for the data, including who can access and use the data. Further, the customer is able to choose not to provide certain data. Additionally, the customer manages notification or consent requirements, and maintains the accuracy of the data.

AWS European Sovereign Cloud does not disclose customer information in response to government demands unless required to do so to comply with a legally valid and binding order. Dedicated AWS European Sovereign Cloud Staff reviews and maintains records of all the information requests, which lists information on the types and volume of information requested. Unless AWS European Sovereign Cloud Entity is prohibited from doing so or there is clear indication of illegal conduct in connection with the use of Amazon products or services, AWS European Sovereign Cloud Staff notify customers before



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

disclosing Customer Content so they can seek protection from disclosure (**Control AWSCA-12.8, AWSCA-20.13**).

AWS European Sovereign Cloud Entity may produce non-content and/or content information in response to valid and binding law enforcement and governmental requests, such as subpoenas, court orders, and search warrants. “Non-content information” means customer information such as name, address, email address, billing information, date of account creation, and service usage information. “Content information” includes the content that a customer transfers for processing, storage, or hosting in connection with AWS European Sovereign Cloud services and any computational results. AWS European Sovereign Cloud records customer information requests to maintain a complete, accurate, and timely record of such requests (**Control AWSCA-12.7, AWSCA-20.13**).

If required, customers are responsible for providing notice to the individuals whose data the customer collects and uses within AWS European Sovereign Cloud services. AWS European Sovereign Cloud Entity is not responsible for providing such notice to or obtaining consent from these individuals and is only responsible for communicating its privacy commitments to AWS European Sovereign Cloud customers, which is provided during the account creation and activation process.

AWS European Sovereign Cloud Entity retains and disposes of Customer Content and Customer-Created Metadata in accordance with the Customer Agreement and the AWS Data Classification and Handling Policy (**Controls AWSCA-20.7, AWSCA-20.8**). When a customer terminates their account or contract with AWS European Sovereign Cloud, the account is put under isolation; after which within 90 days, customers can restore their accounts and related content. AWS services hosting Customer Content are designed to retain Customer Content until the contractual obligation to retain a customer’s content ends or a customer-initiated action to remove or delete the content is taken (**Control AWSCA-7.8**). When a customer requests data to be deleted, AWS utilizes automated processes to detect that request and make the content inaccessible. After the deletion is complete, automated actions are taken on deleted content to render the content unreadable (**Control AWSCA-7.7**).

In the course of AWS Inc.’s system and software design, build, and test of product features, a Customer Content is not used and remains in the production environment. Customer Content is not required for the AWS software development life cycle. When content is required for the development or test of a service’s software, AWS service teams have tools to generate mock, random data.

AWS knows customers care about privacy and data security. That is why AWS gives customers ownership and control over their content by design through tools that allow customers to determine where their content is stored, secure their content in transit or at rest, and manage access to AWS European Sovereign Cloud services and resources. AWS also implements technical and physical controls designed to prevent unauthorized access to or disclosure of a customer’s content. As described in the Physical Security and Change Management areas in Section III of this report, AWS employs a number of controls to safeguard data from within and outside of the boundaries of environments which store a customer’s content and Customer-Created Metadata. As a result of these measures, access to Customer Content and Customer-Created Metadata is restricted to authorized AWS European Sovereign Cloud Staff.

AWS contingency plans and incident response playbooks have defined and tested tools and processes to detect, mitigate, investigate, and assess security breaches and incidents. These plans and playbooks include guidelines for responding to potential data breaches in accordance with contractual and regulatory requirements. AWS European Sovereign Cloud security engineers follow a documented protocol when responding to potential data security incidents. The protocol involves steps, which



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

include validating the presence of Customer Content within the AWS European Sovereign Cloud service (without actually viewing the data), determining the encryption status of a customer’s content, and determining improper access to a Customer’s Content to the extent possible (**Control AWSCA-20.4**).

During the course of their response, the security engineers document relevant findings in internal tools used to track the security issue. AWS Security Leadership is regularly apprised of all data security issue investigations. In the event there are positive indicators that Customer Content was potentially accessed by an unintended party, a security engineer engages AWS Security Leadership and the AWS Legal team to review the findings. AWS Security Leadership and the Legal team review the findings and determine if a notifiable data breach has occurred pursuant to contractual or regulatory obligations. If confirmed, affected customers are notified in accordance with the applicable reporting requirement (**Control AWSCA-12.5**). Customers can subscribe to the AWS Security Bulletins page, which provides information regarding identified security issues.

Vendors and third parties with restricted access, that engage in business with Amazon, are subject to confidentiality commitments as part of their agreements with Amazon. Confidentiality commitments are included in agreements with vendors and third parties with restricted access and are reviewed by AWS Inc. and the third-party at time of contract creation or execution (**Control AWSCA-11.1**). AWS Inc. monitors the performance of third parties through periodic reviews on a risk-based approach, which evaluate performance against contractual obligations (**Control AWSCA-11.2**).

AWS Inc. maintains an externally posted list of third-party sub-processors that are currently engaged by AWS European Sovereign Cloud to process customer data depending on the AWS European Sovereign Cloud service the customer selects at <https://aws.amazon.com/compliance/sub-processors/>. Before AWS Inc. authorizes and permits any new third-party sub-processor to access any Customer Content, AWS Inc. will update the website to inform customers (**Control AWSCA-12.12**). AWS Inc. maintains contracts with third-party sub-processors that define how access to Customer Content is limited to the minimum levels necessary to provide the service described on the page and also contain data protection, confidentiality commitments, and security requirements (**Control AWSCA-12.9 and 12.10**). AWS Inc. performs application security reviews for each third-party sub-processor provider prior to integration with AWS European Sovereign Cloud to ascertain and mitigate security risks (**Control AWSCA-12.4**). A typical security review considers privacy components, such as retention period, use, and collection of data as applicable. The review starts with a system owner initiating a review request to the dedicated AWS Vendor Security (AVS) team, and submitting detailed information required for the review.

During this process, the AVS team determines the granularity of review required based on the type of Customer Content that will be shared, design, threat model, and impact to AWS’ risk profile. They provide security guidance, validate security assurance material, and meet with external parties to discuss their penetration tests, Software Development Life Cycle, change management processes, and other operating security controls. They work with the system owner to identify, prioritize, and remediate security findings. The AVS team collaborates with AWS Legal as needed to validate that the content of the AVS reviews are in-line with AWS privacy policies. The AVS team provides their final approval for the third-party system after they have adequately assessed the risks and worked with the requester to implement security controls to mitigate identified risks. These application security reviews are not only executed for new third-party sub-processors, but also renewed on an annual basis with every third-party sub-processor (**Control AWSCA-12.10 and AWSCA-12.11**).

In addition to the above controls, physical access controls apply to vendor personnel accessing AWS European Sovereign Cloud facilities. Unescorted physical access to Key Data Center Areas within the



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

AWS European Sovereign Cloud is restricted to AWS European Sovereign Cloud Staff and Approved Vendor Personnel (**Control AWSCA-20.12**).

Internally, confidentiality requirements are communicated to employees through training and policies. Employees are required to attend Amazon Security Awareness (ASA) training, which includes policies and procedures related to protecting a customer’s content. Confidentiality requirements are included in the Data Handling and Classification Policy. Policies are reviewed and updated at least annually.

AWS implements policies and controls to monitor access to resources that process or store Customer Content and Customer-Created Metadata. In addition, a Master Service Agreement (MSA) or Non-Disclosure Agreement (NDA) bind a subcontractor to confidentiality in the unlikely event they are exposed to a customer’s content. The MSA references both an NDA and a requirement to protect a Customer’s Content in the event they do not have an NDA. AWS Legal maintains the most current MSA in a legal document portal. The portal serves as the repository for contracts with the most current commitments, document owner, and date modified. A legal review is also performed when the MSA is executed with a vendor.

Services and systems hosted by AWS European Sovereign Cloud Entity are designed to retain and protect a customer’s content for the duration of the customer agreement period, and in some cases, up to 30 days beyond termination. The customer agreement, <https://aws.amazon.com/agreement/>, specifies the terms and conditions. AWS European Sovereign Cloud services are designed to retain a customer’s content until the contractual obligation to retain a customer’s content ends, or upon a customer-initiated action to remove or delete their content. AWS’ data residency commitments and obligations for protecting Customer Content and Customer-Created Metadata are defined in AWS European Sovereign Cloud Addendum, <https://aws.eu/esca/> (**Control AWSCA-20.8**).

Once the contractual obligation to retain a customer’s content ends, or upon a customer-initiated action to remove or delete their content, AWS European Sovereign Cloud services have processes and procedures to detect a deletion and make the content inaccessible. After a delete event, automated actions act on deleted content to render the content inaccessible (**Control AWSCA-7.7**).

E. Monitoring

E.1 Monitoring Activities

AWS European Sovereign Cloud utilizes a wide variety of automated monitoring systems to facilitate a high level of service performance and availability. AWS Inc. defines a Security Incident as a security-related adverse event in which there was a loss of data confidentiality, disruption of data or systems integrity, or disruption or denial of availability. AWS European Sovereign Cloud monitoring tools are implemented to detect unusual or unauthorized activities and conditions at ingress and egress communication points. These tools monitor server and network usage, port scanning activities, application usage, and unauthorized intrusion attempts.

Systems within AWS European Sovereign Cloud are further designed to monitor key operational metrics, and alarms are configured to automatically notify operations and management personnel when early warning thresholds are crossed. An on-call schedule is used such that personnel are always available to respond to operational issues. This includes a pager system, so that notifications are quickly and reliably communicated to operations personnel (**Control AWSCA-8.1, AWSCA-20.4**).



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

Documentation is maintained to aid and inform AWS European Sovereign Cloud Staff in handling incidents or issues. A ticketing system is used which supports communication, progress updates, necessary collaboration between teams, and logging capabilities. Trained call leaders facilitate communication and progress during the handling of operational issues that require collaboration. After action reviews are convened following significant operational issue, regardless of external impact, and Correction of Errors (COE) documents are composed such that the root cause is captured, and preventative actions may be taken for the future. Implementation of the preventative measures identified in COEs is tracked during weekly operations meetings.

The AWS European Sovereign Cloud Security Operations team employs industry-standard diagnosis procedures (such as incident identification, registration and verification, initial incident classification and prioritizing actions) to drive resolution during business-impacting events. AWS European Sovereign Cloud Staff operators in the EU provide 24 x 7 continuous coverage to detect incidents and to manage the impact and resolution (**Control AWSCA-8.2, AWSCA-20.4**). Controls are implemented to monitor that AWS European Sovereign Cloud will not move or copy Customer Content or Customer-Created Metadata outside the EU except as instructed by the customer or as necessary to comply with applicable law (**Control AWSCA-20.6**).

E.2 Incident Notification

AWS Inc. has documented an incident response policy and plan which outlines an organized approach for responding to security breaches and incidents (**Control AWSCA-1.2**). The AWS European Sovereign Cloud Security team is responsible for monitoring AWS European Sovereign Cloud systems, tracking issues, and documenting findings of security-related events. Records are maintained for security breaches and incidents, which include status information required for supporting forensic activities, trend analysis, and evaluation of incident details.

As part of the process, potential breaches of Customer Content are investigated and escalated to the appropriate AWS European Sovereign Cloud Security and Legal teams. Customers can subscribe to the AWS Security Bulletins page, which provides information regarding identified security issues. AWS European Sovereign Cloud notifies affected customers and regulators of breaches and incidents as legally required in accordance with team processes.

Complementary User Entity Controls

AWS European Sovereign Cloud services were designed with the assumption that certain policies, procedures, and controls are implemented by its user entities (or customers). In certain situations, the application of specific policies, procedures, and controls by the customer is necessary to achieve the service commitments and system requirements that are based on the applicable trust services criteria included in this report. This section describes the additional policies, procedures, and controls customers may need to implement in order to satisfy the service commitments and system requirements for customers’ specific use cases.



CC1.0 – Common Criteria Related to Control Environment

CC2.0 – Common Criteria Related to Communication and Information

- Customers should subscribe to AWS European Sovereign Cloud notifications to receive timely updates regarding service changes, security bulletins, and any changes to the AWS European Sovereign Cloud Addendum or Articles of Association of the AWS European Sovereign Cloud Entity.
- Customers are responsible for updating their communication preferences.
- Customers are responsible for providing individuals with their personal information, that the customer has stored in AWS services, if required to do so by law.

CC3.0 – Common Criteria Related to Risk Assessment

CC4.0 – Common Criteria Related to Monitoring Activities

- Customers should ensure appropriate logging of events is in place to support monitoring and incident response processes. Customers should log events that include but are not limited to administrator activity, system errors, authentication checks, and data deletions.
- Customers should enable and configure service-specific logging features where available for all services and implement appropriate monitoring and incident response processes.

CC5.0 – Common Criteria Related to Control Activities

CC6.0 – Common Criteria Related to Logical and Physical Access Controls

- Customers should use asymmetric key-pairs or multi-factor authentication to access their hosts and avoid simple password-based authentication.
- Customers should implement access controls, such as Security-Groups, IAM roles and/or Access control lists (ACLs), to segment and isolate like-functioning instances.
- S3-Specific – Customers should utilize managed rules and ACLs to secure their S3 buckets by controlling access to the S3 buckets and preventing them being accessible to the public.
- Customers should utilize multi-factor authentication for controlling access to their root account credentials and should avoid using root account credentials beyond initial account configuration of AWS Identity and Access Management (IAM), except for Services for which IAM is not available. Customers should delete access key(s) for the root account when not in use.
- Customers are responsible for managing and reviewing users' access to their instance of AWS European Sovereign Cloud services in accordance with their access management policies.
- Customers should configure IAM policies and resource configurations (each of which is classified as Customer-Created Metadata) with the understanding that Customer- Created Metadata is subject to the same data residency and access protections as Customer Content within the AWS European Sovereign Cloud.
- Customers should utilize identity and access management capabilities available in AWS European Sovereign Cloud region to maintain sovereignty requirements for access to their resources.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

CC7.0 – Common Criteria Related to System Operations

- Customers may subscribe to Premium Support offerings that include direct communication with the customer support team and proactive alerting to any issues that may impact the customer.
- VPC-Specific – Customers are responsible for their network security requirements and connecting their Amazon Virtual Private Cloud to an appropriate point of their internal network.
- EC2-Specific – Customers are responsible for configuring the Time Sync functionality and monitoring the synchronization for accuracy across their EC2 instances, as published by AWS Inc. in user guide documentation - <https://docs.aws.amazon.com/AWSEC2/latest/UserGuide/set-time.html#configure-amazon-time-service-amazon-linux>.
- Customers should ensure that any third-party tools or services integrated with their AWS European Sovereign Cloud environment do not transfer Customer Content or Customer-Created Metadata outside the EU, unless explicitly intended by the customer.
- Customers should utilize AWS European Sovereign Cloud Support for AWS European Sovereign Cloud Accounts, which is provided by AWS European Sovereign Cloud Staff, for any support requests involving Customer Content or Customer-Created Metadata.

CC8.0 – Common Criteria Related to Change Management

- Customers are responsible for maintaining the application of patches to customers’ Amazon instances. Customers can leverage automated patching tools such as AWS Systems Manager Patch Manager to help deploy operating systems and software patches automatically across large groups of instances.
- Customers should set up separate development and production accounts to isolate the production system from development work.
- Customers should review and understand the implications of any changes to their configurations, ensuring that changes do not inadvertently transfer Customer Content or Customer-Created Metadata outside the defined geographical and logical boundaries of the AWS European Sovereign Cloud.

CC9.0 – Common Criteria Related to Risk Mitigation

- Customers should maintain policies and procedures that provide training and guidance for information security within the organization, the IT environment, and the use of AWS European Sovereign Cloud services.
- Customers should assess the objectives of their AWS European Sovereign Cloud services network and identify the risks and corresponding controls that need to be implemented to address those risks when using AWS European Sovereign Cloud services, software, and operational controls.
- Customers should assess their data sovereignty and residency requirements and ensure that their use of AWS European Sovereign Cloud services aligns with applicable EU and Member State regulatory obligations.



SECTION III – Description of AWS European Sovereign Cloud GmbH’s System Relevant to Security, Availability, and Confidentiality

- Customers are responsible for complying with any regulations or laws that require a rationale of the purposes for which personal information is collected, used, retained, and disclosed.

A – Availability Criteria

- EC2-Specific – Customers using the EC2 service should augment the AWS instance firewalls with a host-based firewall for redundancy and egress filtering.
- EC2/VPC-Specific – Data stored on Amazon EC2 virtual disks should be proactively copied to another storage option for redundancy.
- Customers should ensure their AWS European Sovereign Cloud resources such as server and database instances have the appropriate levels of redundancy and isolation. Redundancy can be achieved through utilization of the Multi-AZ deployment option where available.
- EBS-Specific – Amazon EBS replication is stored within the same AZ, not across multiple zones, and therefore customers should conduct regular snapshots to Amazon S3 in order to provide long-term data durability.
- Customers should enable backups of their data across AWS European Sovereign Cloud services.

C – Confidentiality Criteria

- Customers should utilize Amazon S3’s option to specify an MD5 checksum as part of a REST PUT operation for the data being sent to Amazon S3. When the request arrives at Amazon S3, an MD5 checksum will be recalculated for the object data received and compared to the provided MD5 checksum. If there is a mismatch, the PUT will be failed, preventing data that was corrupted on the wire from being written into Amazon S3. Customers should use the MD5 checksums returned in response to REST GET requests to confirm that the data returned by the GET was not corrupted in transit.
- Any code customers write to call Amazon APIs should expect to receive and handle errors from the service. Specific guidance for each service can be found within the corresponding User Guide and API documentation.
- Customers should transmit secret keys over secure channels. Customers should avoid embedding secret keys in web pages or other publicly accessible source code. Customers should encrypt sensitive data at rest as well as in transit over the network.
- Customers should appropriately configure and manage usage and implementation of available encryption options to meet their requirements.
- Customers should use encrypted (TLS/SSL) connections for all of their interactions with AWS European Sovereign Cloud. Leading practices include the use of TLS 1.2. Customers should opt in for a key rotation schedule that meets their needs for any KMS key they would like rotated.
- Customers should check the Customer Agreement and Privacy Notice website frequently for any changes.
- Customers are responsible for managing disclosure and notice requirements for data stored in AWS European Sovereign Cloud services, when applicable, because AWS European Sovereign Cloud Entity is not responsible for providing notice, obtaining consent, or having knowledge of what individuals have been provided notice or consented to.



SECTION III – Description of AWS European Sovereign Cloud GmbH's System Relevant to Security, Availability, and Confidentiality

- Customers should understand the commitments AWS European Sovereign Cloud Entity has made regarding governmental requests for Customer Content and Customer-Created Metadata, including AWS European Sovereign Cloud Entity's commitment to redirect requests to the customer, notify the customer where legally permitted, and challenge requests that conflict with EU or Member State law, as outlined in the AWS European Sovereign Cloud Addendum.
- Customers are responsible for keeping personal information, that the customer has stored in AWS European Sovereign Cloud services, accurate, complete and relevant as required by any regulations or laws.

The list of control considerations presented above does not represent all the controls that should be employed by the customer. Other controls may be required. Customers should reference additional AWS European Sovereign Cloud service documentation on the [AWS European Sovereign Cloud website](#).

Trust Services Categories, Criteria, and Related Controls

AWS European Sovereign Cloud Entity's mapping between AWS European Sovereign Cloud Entity's and AWS Inc.'s controls and the Trust Services Criteria is included in „ *SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures*“. The mapping further delineates the AWS entity accountable for the respective control. Although the Trust Services Categories, Criteria, and related AWS European Sovereign Cloud Entity's and AWS Inc.'s controls are presented in Section IV, they are nevertheless an integral part of AWS European Sovereign Cloud Entity's Description of AWS European Sovereign Cloud's Systems Relevant to Security, Availability and Confidentiality as described in this section.

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Procedures Performed and Results of Entity-Level Controls

In planning the nature, timing and extent of testing of the controls, EY considered the aspects of AWS' control environment and tested those controls that were considered necessary.

In addition to the tests of operating effectiveness of specific controls described below, procedures included tests of the following components of the internal control environment of AWS:

- Management controls and organizational structure
- Risk assessment process
- Information and communication
- Control activities
- Monitoring

Tests of the control environment included the following procedures, to the extent EY considered necessary: (a) a review of AWS' organizational structure, including the segregation of functional responsibilities, policy statements, processing manuals and personnel controls, (b) discussions with management, operations, administrative and other personnel who are responsible for developing, ensuring adherence to and applying controls, and (c) observations of personnel in the performance of their assigned duties.

The control environment was considered in determining the nature, timing and extent of the testing of controls and controls relevant to the achievement of the control objectives.

The evaluation of the controls was also performed before the official launch of the AWS European Sovereign Cloud services on January 15, 2026, after it was already in operational mode.

Trust Services Criteria and Related Controls for Systems and Applications

On the pages that follow, the description of control objectives and the controls to achieve the objectives have been specified by, and are the responsibility of, AWS. The "Procedures Performed by EY" and the "Results of Procedures" are the responsibility of the service auditor.

Information System Control Environment

The following controls apply to the services listed in the System Description and their supporting data centers, except where controls are unique to one of the services – in those cases, the controls are indicated as "S3-Specific", "EC2-Specific", "VPC-Specific", "KMS-Specific", "RDS-Specific" or otherwise noted as being specific to a certain service or set of services.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
CC1.0 – Common Criteria Related to Control Environment		
CC1.1	AWSCA-1.1 ; AWSCA-1.2 ; AWSCA-9.2 ; AWSCA-9.3 ; AWSCA-9.7 ; AWSCA-9.9 ; AWSCA-11.1 ; AWSCA-11.2 ; AWSCA-20.1 ; AWSCA-20.10	COSO Principle 1: The entity demonstrates a commitment to integrity and ethical values.
CC1.2	AWSCA-1.7 ; AWSCA-1.8 ; AWSCA-9.8 ; AWSCA-20.1	COSO Principle 2: The board of directors demonstrates independence from management and exercises oversight of the development and performance of internal control.
CC1.3	AWSCA-1.1 ; AWSCA-1.2 ; AWSCA-20.1 ; AWSCA-20.10	COSO Principle 3: Management establishes, with board oversight, structures, reporting lines, and appropriate authorities and responsibilities in the pursuit of objectives.
CC1.4	AWSCA-1.2 ; AWSCA-1.4 ; AWSCA-1.7 ; AWSCA-1.8 ; AWSCA-9.2 ; AWSCA-9.3 ; AWSCA-9.9 ; AWSCA-11.1 ; AWSCA-11.2 ; AWSCA-20.10	COSO Principle 4: The entity demonstrates a commitment to attract, develop, and retain competent individuals in alignment with objectives.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
CC1.5	AWSCA-1.1; AWSCA-1.2; AWSCA-1.3; AWSCA-9.3; AWSCA-9.7; AWSCA-20.1; AWSCA-20.10	COSO Principle 5: The entity holds individuals accountable for their internal control responsibilities in the pursuit of objectives.
CC2.0 – Common Criteria Related to Communication and Information		
CC2.1	AWSCA-1.2; AWSCA-1.5; AWSCA-1.9; AWSCA-1.10; AWSCA-3.6; AWSCA-8.1; AWSCA-8.2; AWSCA-9.8; AWSCA-20.6; AWSCA-20.15	COSO Principle 13: The entity obtains or generates and uses relevant, quality information to support the functioning of internal control.
CC2.2	AWSCA-1.2; AWSCA-1.4; AWSCA-1.6; AWSCA-1.9; AWSCA-9.1; AWSCA-9.5; AWSCA-9.6; AWSCA-10.3; AWSCA-11.1; AWSCA-11.3; AWSCA-20.4; AWSCA-20.7; AWSCA-20.8	COSO Principle 14: The entity internally communicates information, including objectives and responsibilities for internal control, necessary to support the functioning of internal control.
CC2.3	AWSCA-1.4; AWSCA-1.6; AWSCA-9.1; AWSCA-9.5; AWSCA-11.1; AWSCA-11.2; AWSCA-11.3; AWSCA-12.1; AWSCA-12.2;	COSO Principle 15: The entity communicates with external parties regarding matters affecting the functioning of internal control.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-12.3; AWSCA-12.4; AWSCA-12.5; AWSCA-12.8; AWSCA-20.8; AWSCA-20.13	
CC3.0 – Common Criteria Related to Risk Assessment		
CC3.1	AWSCA-1.5; AWSCA-1.9; AWSCA-1.10; AWSCA-9.8	COSO Principle 6: The entity specifies objectives with sufficient clarity to enable the identification and assessment of risks relating to objectives.
CC3.2	AWSCA-1.5; AWSCA-1.9; AWSCA-1.10; AWSCA-3.4; AWSCA-5.12; AWSCA-10.3; AWSCA-12.9; AWSCA-12.10; AWSCA-12.11; AWSCA-12.12	COSO Principle 7: The entity identifies risks to the achievement of its objectives across the entity and analyzes risks as a basis for determining how the risks should be managed.
CC3.3	AWSCA-1.5; AWSCA-1.10; AWSCA-3.4; AWSCA-5.12; AWSCA-10.3	COSO Principle 8: The entity considers the potential for fraud in assessing risks to the achievement of objectives.
CC3.4	AWSCA-1.5; AWSCA-1.10; AWSCA-3.4; AWSCA-5.12; AWSCA-10.3; AWSCA-20.2; AWSCA-20.3; AWSCA-20.11	COSO Principle 9: The entity identifies and assesses changes that could significantly impact the system of internal control.
CC4.0 – Common Criteria Related to Monitoring Activities		
CC4.1	AWSCA-1.10; AWSCA-3.4; AWSCA-5.12;	COSO Principle 16: The entity selects, develops, and performs ongoing and/or separate evaluations to ascertain whether the components of internal control are present and functioning.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-9.8; AWSCA-11.2	
CC4.2	AWSCA-1.5; AWSCA-1.10; AWSCA-9.8; AWSCA-20.1; AWSCA-20.10	COSO Principle 17: The entity evaluates and communicates internal control deficiencies in a timely manner to those parties responsible for taking corrective action, including senior management and the board of directors, as appropriate.
CC5.0 – Common Criteria Related to Control Activities		
CC5.1	AWSCA-1.2; AWSCA-1.3; AWSCA-1.5; AWSCA-1.10	COSO Principle 10: The entity selects and develops control activities that contribute to the mitigation of risks to the achievement of objectives to acceptable levels.
CC5.2	AWSCA-1.2; AWSCA-1.3; AWSCA-1.5; AWSCA-1.10	COSO Principle 11: The entity also selects and develops general control activities over technology to support the achievement of objectives.
CC5.3	AWSCA-1.1; AWSCA-1.2; AWSCA-1.3; AWSCA-1.5; AWSCA-1.10; AWSCA-10.3; AWSCA-20.3; AWSCA-20.4; AWSCA-20.7	COSO Principle 12: The entity deploys control activities through policies that establish what is expected and in procedures that put policies into action.
CC6.0 - Common Criteria Related to Logical and Physical Access Controls		
CC6.1	AWSCA-1.2; AWSCA-2.1; AWSCA-2.2; AWSCA-2.3; AWSCA-2.4; AWSCA-2.5; AWSCA-2.6; AWSCA-3.1; AWSCA-3.2; AWSCA-3.3; AWSCA-3.5; AWSCA-3.6; AWSCA-3.7;	The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-3.8; AWSCA-3.9; AWSCA-3.10; AWSCA-3.11; AWSCA-3.12; AWSCA-3.13; AWSCA-3.14; AWSCA-3.15; AWSCA-3.19; AWSCA-4.4; AWSCA-4.5; AWSCA-4.6; AWSCA-4.7; AWSCA-4.8; AWSCA-4.9; AWSCA-4.10; AWSCA-4.11; AWSCA-4.12; AWSCA-4.13; AWSCA-4.14; AWSCA-6.1; AWSCA-8.1; AWSCA-8.2; AWSCA-9.4; AWSCA-12.6; AWSCA-12.7; AWSCA-20.4; AWSCA-20.5; AWSCA-20.6; AWSCA-20.9; AWSCA-20.10; AWSCA-20.14; AWSCA-20.15	
CC6.2	AWSCA-2.1; AWSCA-2.2; AWSCA-2.3; AWSCA-2.4; AWSCA-20.9; AWSCA-20.10	Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized.
CC6.3	AWSCA-2.1; AWSCA-2.2; AWSCA-2.3;	The entity authorizes, modifies, or removes access to data, software, functions, and other protected information assets based on roles, responsibilities, or the system design and changes, giving consideration to

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-2.4; AWSCA-2.5; AWSCA-2.6; AWSCA-20.9; AWSCA-20.10	the concepts of least privilege and segregation of duties, to meet the entity’s objectives.
CC6.4	AWSCA-3.16; AWSCA-4.12; AWSCA-4.13; AWSCA-5.1; AWSCA-5.2; AWSCA-5.3; AWSCA-5.4; AWSCA-5.5; AWSCA-20.2; AWSCA-20.12; AWSCA-20.14	The entity restricts physical access to facilities and protected information assets (for example, data center facilities, back-up media storage, and other sensitive locations) to authorized personnel to meet the entity’s objectives.
CC6.5	AWSCA-5.13; AWSCA-7.7; AWSCA-7.8; AWSCA-20.2; AWSCA-20.12	The entity discontinues logical and physical protections over physical assets only after the ability to read or recover data and software from those assets has been diminished and is no longer required to meet the entity’s objectives.
CC6.6	AWSCA-2.6; AWSCA-3.1; AWSCA-3.2; AWSCA-3.3; AWSCA-3.7; AWSCA-3.8; AWSCA-3.9; AWSCA-4.14; AWSCA-8.1; AWSCA-8.2; AWSCA-20.6; AWSCA-20.9; AWSCA-20.14; AWSCA-20.15	The entity implements logical access security measures to protect against threats from sources outside its system boundaries.
CC6.7	AWSCA-1.2; AWSCA-1.4; AWSCA-1.6; AWSCA-2.2; AWSCA-2.3; AWSCA-3.16;	The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal to meet the entity’s objectives.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-3.18; AWSCA-3.19; AWSCA-4.1; AWSCA-4.2; AWSCA-4.3; AWSCA-4.4; AWSCA-4.6; AWSCA-4.7; AWSCA-4.9; AWSCA-4.11; AWSCA-4.14; AWSCA-5.1; AWSCA-5.2; AWSCA-5.3; AWSCA-5.13; AWSCA-7.1; AWSCA-20.9; AWSCA-20.12	
CC6.8	AWSCA-2.2; AWSCA-2.3; AWSCA-3.4; AWSCA-3.18; AWSCA-6.1; AWSCA-6.2; AWSCA-6.3; AWSCA-6.4; AWSCA-6.5; AWSCA-6.6; AWSCA-8.1; AWSCA-8.2; AWSCA-9.4; AWSCA-20.5; AWSCA-20.9	The entity implements controls to prevent or detect and act upon the introduction of unauthorized or malicious software to meet the entity’s objectives.
CC7.0 - Common Criteria Related to System Operations		
CC7.1	AWSCA-3.1; AWSCA-3.2; AWSCA-3.3; AWSCA-3.4; AWSCA-3.6; AWSCA-6.6; AWSCA-7.10;	To meet its objectives, the entity uses detection and monitoring procedures to identify (1) changes to configurations that result in the introduction of new vulnerabilities, and (2) susceptibilities to newly discovered vulnerabilities.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-9.4; AWSCA-12.10; AWSCA-12.11	
CC7.2	AWSCA-1.2; AWSCA-3.4; AWSCA-5.6; AWSCA-8.1; AWSCA-8.2; AWSCA-8.3; AWSCA-9.6; AWSCA-20.4; AWSCA-20.6; AWSCA-20.9; AWSCA-20.15	The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives; anomalies are analyzed to determine whether they represent security events.
CC7.3	AWSCA-1.1; AWSCA-5.6; AWSCA-5.11; AWSCA-5.12; AWSCA-8.1; AWSCA-8.2; AWSCA-9.6; AWSCA-10.3; AWSCA-12.5; AWSCA-12.8; AWSCA-20.4; AWSCA-20.6; AWSCA-20.13; AWSCA-20.15	The entity evaluates security events to determine whether they could or have resulted in a failure of the entity to meet its objectives (security incidents) and, if so, takes actions to prevent or address such failures.
CC7.4	AWSCA-1.1; AWSCA-1.2; AWSCA-3.4; AWSCA-5.11; AWSCA-5.12; AWSCA-8.1; AWSCA-8.2; AWSCA-9.6; AWSCA-9.7; AWSCA-10.3; AWSCA-12.5; AWSCA-12.6; AWSCA-12.7;	The entity responds to identified security incidents by executing a defined incident-response program to understand, contain, remediate, and communicate security incidents, as appropriate.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-20.3; AWSCA-20.4	
CC7.5	AWSCA-5.11; AWSCA-5.12; AWSCA-6.1; AWSCA-8.2; AWSCA-9.6; AWSCA-10.3; AWSCA-20.3; AWSCA-20.4; AWSCA-20.5	The entity identifies, develops, and implements activities to recover from identified security incidents.
CC8.0 - Common Criteria Related to Change Management		
CC8.1	AWSCA-3.1; AWSCA-3.2; AWSCA-3.3; AWSCA-3.6; AWSCA-3.16; AWSCA-6.1; AWSCA-6.2; AWSCA-6.3; AWSCA-6.4; AWSCA-6.5; AWSCA-6.6; AWSCA-6.7; AWSCA-8.2; AWSCA-9.4; AWSCA-10.3; AWSCA-12.4; AWSCA-20.5; AWSCA-20.14	The entity authorizes, designs, develops or acquires, configures, documents, tests, approves, and implements changes to infrastructure, data, software, and procedures to meet its objectives.
CC9.0 – Risk Mitigation		
CC9.1	AWSCA-1.2; AWSCA-1.5; AWSCA-1.10; AWSCA-10.3	The entity identifies, selects, and develops risk mitigation activities for risks arising from potential business disruptions.
CC9.2	AWSCA-1.5; AWSCA-1.10; AWSCA-5.11; AWSCA-5.12; AWSCA-9.7;	The entity assesses and manages risks associated with vendors and business partners.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
	AWSCA-11.1; AWSCA-11.2; AWSCA-11.3; AWSCA-12.4; AWSCA-12.9; AWSCA-12.10; AWSCA-12.11; AWSCA-12.12	

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
Additional Criteria for Availability		
A1.1	AWSCA-8.1; AWSCA-10.3; AWSCA-10.4; AWSCA-20.2; AWSCA-20.11	The entity maintains, monitors, and evaluates current processing capacity and use of system components (infrastructure, data, and software) to manage capacity demand and to enable the implementation of additional capacity to help meet its objectives.
A1.2	AWSCA-1.2; AWSCA-1.5; AWSCA-1.10; AWSCA-5.7; AWSCA-5.8; AWSCA-5.9; AWSCA-5.10; AWSCA-5.11; AWSCA-5.12; AWSCA-7.3; AWSCA-7.4; AWSCA-7.5; AWSCA-7.6; AWSCA-8.1; AWSCA-8.2; AWSCA-10.1; AWSCA-10.2; AWSCA-10.3; AWSCA-10.4; AWSCA-20.2; AWSCA-20.3; AWSCA-20.4; AWSCA-20.11	The entity authorizes, designs, develops or acquires, implements, operates, approves, maintains, and monitors environmental protections, software, data backup processes, and recovery infrastructure to meet its objectives.
A1.3	AWSCA-1.2; AWSCA-10.2; AWSCA-10.3; AWSCA-20.3	The entity tests recovery plan procedures supporting system recovery to meet its objectives.

AWS Controls Mapped to the Security, Availability, and Confidentiality Criteria

Criteria	Supporting AWS Control Activity (AWSCA)	Criteria Description
Additional Criteria for Confidentiality		
C1.1	AWSCA-1.2; AWSCA-7.2; AWSCA-7.3; AWSCA-7.4; AWSCA-7.5; AWSCA-7.6; AWSCA-7.8; AWSCA-10.2; AWSCA-20.7;	The entity identifies and maintains confidential information to meet the entity's objectives related to confidentiality.
C1.2	AWSCA-5.13; AWSCA-7.7; AWSCA-20.7; AWSCA-20.8	The entity disposes of confidential information to meet the entity's objectives related to confidentiality.

AWS Controls & Service Auditor's Procedures Performed and Results

While the AWS controls supporting the applicable SOC 2 Trust Services Criteria at AWS European Sovereign Cloud Entity and AWS Inc. are collectively presented in the following tables, the responsibility of each control was added.

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSA-1.1: The AWS organization has defined structures, reporting lines with assigned authority and responsibilities to appropriately meet requirements relevant to security, availability, confidentiality, and privacy. Control responsible: AWS Inc.	CC1.1 ; CC1.3 ; CC1.5 ; CC5.3 ; CC7.3 ; CC7.4	Inquired of an AWS IT Security Response Director to ascertain the AWS organization has defined structures, reporting lines with assigned authority, and responsibilities to appropriately meet business requirements, including an information security function.	No deviations noted.
		Inspected the organizational chart and the Integrated Information Management System Policy to ascertain the AWS organization has defined structures, reporting lines with assigned authority, and responsibilities to appropriately meet security, availability, confidentiality, and privacy requirements, including an information security function.	No deviations noted.
		Inspected the Integrated Information Management System Policy to ascertain the full document was approved within the last year by Security Leadership and that any changes were approved by appropriate members of the Security team.	No deviations noted.
AWSA-1.2: AWS maintains formal policies that provide guidance for information security within the organization and the supporting IT environment. Control responsible: AWS Inc.	CC1.1 ; CC1.3 ; CC1.4 ; CC1.5 ; CC2.1 ; CC2.2 ; CC5.1 ; CC5.2 ; CC5.3 ; CC6.1 ; CC6.7 ; CC7.2 ; CC7.4 ; CC9.1 ; A1.2 ; A1.3 ; C1.1	Inquired of an AWS Security Assurance Program Manager to ascertain formal security policies exist, including designation of responsibility and accountability for managing the system and controls, and providing guidance for information security within the organization and the supporting IT environment.	No deviations noted.
		Inspected the information security policies listed in the System Description and the internal Amazon Policy tool to ascertain they included organization-wide security procedures as guidance for the AWS environment and the supporting IT environment.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-1.3: Security policies are reviewed and approved on an annual basis by Security Leadership. Control responsible: AWS Inc.	CC1.5; CC5.1; CC5.2; CC5.3	Inquired of an AWS Security Assurance Program Manager to ascertain the security policies were reviewed and approved at least annually by Security Leadership.	No deviations noted.
		Inspected the security policies listed in the System Description and the internal Amazon Policy tool to ascertain they were approved within the last 12 months by reviewing the approval date and Security Leadership approval from the tool logs.	No deviations noted.
AWSCA-1.4: AWS maintains employee training programs to promote awareness of AWS information security requirements as defined in the AWS Security Awareness Training Policy. Control responsible: AWS Inc.	CC1.4; CC2.2; CC2.3; CC6.7	Inquired of a Technical Training Operations Specialist to ascertain employee training programs were established to promote awareness of AWS information security and data privacy requirements.	No deviations noted.
		For one newly hired AWS European Sovereign Cloud employee, inspected the training transcript to ascertain the employees completed the Amazon Security Awareness (ASA) training course within 60 days of role assignment and that the training course included information security requirements, data privacy requirements and AWS European Sovereign Cloud operational requirements as defined in the AWS Security Awareness Training Policy.	No deviations noted.
AWSCA-1.5: AWS maintains a formal risk management program to identify, analyze, treat and continuously monitor and report risks that affect AWS' business objectives and regulatory requirements. The program identifies risks, documents them in a risk register as appropriate, and reports results to	CC2.1; CC3.1; CC3.2; CC3.3; CC3.4; CC4.2; CC5.1; CC5.2; CC5.3; CC9.1; CC9.2; A1.2	Inquired of an AWS Senior Regulatory Risk Manager to ascertain a formal risk management program was maintained to identify, analyze, mitigate, and continuously monitor and report risks that affect AWS' business objectives, regulatory requirements, and customers. The program identifies risks, documents them in a risk register as appropriate, and reports results to leadership at least semi-annually.	No deviations noted.
		Inspected the AWS Risk Management policy to ascertain it outlined how to identify, analyze, mitigate, and continuously monitor and report risks that affect AWS' business objectives, regulatory requirements and customers, as well as detailed risk treatment options such as acceptance, avoidance, mitigation, and transfer.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
leadership at least semi-annually. Control responsible: AWS Inc.		For one risk, inspected relevant documentation to ascertain the risk was identified, analyzed, mitigated to an acceptable level, and monitored by management.	No deviations noted.
AWSCA-1.6: KMS-Specific – Roles and responsibilities for KMS cryptographic custodians are formally documented and agreed to by those individuals when they assume the role or when responsibilities change. Control responsible: AWS Inc.	CC2.2 ; CC2.3 ; CC6.7	Inquired of a Cryptography Technical Program Manager to ascertain roles and responsibilities for KMS cryptographic custodians were formally documented and acknowledged by those individuals when assumed or when responsibilities change.	No deviations noted.
		For one individual from the KMS cryptographic custodians group with access to systems that store or use key material, inspected the roles and responsibilities documents to ascertain user responsibilities were formally documented and that the individuals signed the document.	No deviations noted.
AWSCA-1.7: The Amazon Board and its Committees have the required number of independent Board members, and the Board and each Committee member is qualified to serve in such capacity. Annually, Board members complete questionnaires to establish whether they are independent and qualified to serve on each Board Committee under applicable rules. Control responsible: AWS Inc.	CC1.2 ; CC1.4	Inquired of the Amazon Corporate Counsel to ascertain the Board and its Committees had the required number of independent Board members, and each Board and Committee member was qualified to serve in such capacity.	No deviations noted.
		Inspected Amazon's Company Bylaws and the Company's Corporate Governance guidelines to ascertain they defined the number and roles of officers on the Board of Directors and their responsibilities.	No deviations noted.
		Inspected the annual Board member questionnaire to ascertain the questionnaires were completed by all Board members and included questions to establish whether members were independent and qualified to serve on each part of the Board Committee under the applicable bylaws and guidelines.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWS-1.8: The Board of Directors conducts an annual assessment of individual Board members and overall Board performance. The Nominating and Corporate Governance Committee periodically reviews and assesses the composition of the board. The Leadership Development and Compensation Committee, with the full Board present, annually evaluates the succession plan for each member of the senior management team. As part of the annual Company and CEO Performance review, the Board reviews the succession plan for the CEO. Control responsible: AWS Inc.	CC1.2 ; CC1.4	Inquired of the Amazon Corporate Counsel to ascertain the Board of Directors conducted an annual assessment of individual Board members and overall Board performance, the nominating and Corporate Governance Committee periodically reviewed and assessed the composition of the Board, and the Leadership Development and Compensation Committee evaluated the succession plan for each member of the senior management team, including the CEO.	No deviations noted.
		Inspected the Nominating and Corporate Governance meeting minutes to ascertain the annual assessment and review of the composition of the Board of Directors was discussed and completed.	No deviations noted.
		Inspected the Board of Directors meeting minutes to ascertain that the Board reviewed the succession plan for the CEO and senior management team as part of the annual Company and CEO performance review.	No deviations noted.
AWS-1.9: AWS prepares and consolidates the operational planning document annually. The operational plan includes operational and performance objectives, regulatory and compliance requirements with sufficient clarity to enable the	CC2.1 ; CC2.2 ; CC3.1 ; CC3.2	Inquired of the Financial Planning and Analysis Director to ascertain AWS prepared and consolidated the operational planning document annually including operational and performance objectives as well as regulatory and compliance requirements with sufficient clarity to enable the identification and assessment of risks relating to objectives.	No deviations noted.
		Inspected the Operational Plan related to the creation of the operational planning document to ascertain it included operational and performance objectives as well as regulatory and compliance	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
identification and assessment of risks relating to objectives. Control responsible: AWS Inc.		requirements that identified and assessed risks relating to those objectives.	
AWSCA-1.10: AWS has an approval process in place to review environmental and geo-political risks before launching a new region. Control responsible: AWS Inc.	CC2.1 ; CC3.1 ; CC3.2 ; CC3.3 ; CC3.4 ; CC4.1 ; CC4.2 ; CC5.1 ; CC5.2 ; CC5.3 ; CC9.1 ; CC9.2 ; A1.2	Inquired of the AWS Data Center Risk Management Head to ascertain environmental and geo-political risks were reviewed before launching new data centers/regions.	No deviations noted.
		For one in-scope data center from the AWS European Sovereign Cloud region, inspected review documentation to ascertain a review of environmental and geopolitical risks was performed and approval was obtained before the new data center was launched.	No deviations noted.
AWSCA-2.1: User access to the internal Amazon network is not provisioned unless an active record is created in the HR System by Human Resources. Access is automatically provisioned with least privilege per job function. First time passwords are set to a unique value and changed immediately after first use. Control responsible: AWS Inc.	CC6.1 ; CC6.2 ; CC6.3	Inquired of an Employee Onboarding Software Development Engineer to ascertain user access to the internal Amazon network was not activated unless an active record was created in the HR System by Human Resources, that access was automatically provisioned with least privilege per job function, and that first-time passwords were set to a unique value and changed immediately after first use.	No deviations noted.
		Inspected the system configurations responsible for provisioning access to the internal Amazon network to ascertain access to Windows and UNIX user accounts could not be provisioned unless an active record was created in the HR System by Human Resources, that access was provisioned automatically with least privilege per job function prior to employee start dates, and that first time passwords were configured to create a unique value and were required to be changed immediately after first use.	No deviations noted.
		For one corporate newly hired AWS European Sovereign Cloud employee, inspected the employee's HR System record to ascertain the HR system activated the employee's record prior to the creation of an	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		employee's Windows and UNIX accounts and that the first-time passwords are changed immediately after employee's first use of the account.	
AWSCA-2.2: IT access above least privileged, including administrator accounts, is approved by appropriate personnel prior to access provisioning. Control responsible: AWS Inc.	CC6.1; CC6.2; CC6.3; CC6.7; CC6.8	Inquired of Software Development Managers to ascertain IT access above least privileged, including administrator accounts, was approved by appropriate personnel prior to access provisioning.	No deviations noted.
		Inspected the system configurations responsible for the access provisioning process to ascertain IT access above least privileged, including administrator accounts, was required to be approved by appropriate personnel prior to automatic access provisioning.	No deviations noted.
		For one active employee, inspected the process of access provisioning to ascertain approval of the access was provided by appropriate personnel prior to the automatic provisioning of the access.	No deviations noted.
		For one active manager who met the access rules, inspected the access provisioning process to ascertain the manager could not add users who were not their direct reports.	No deviations noted.
		For one active manager that did not meet the access rules, inspected the access provisioning process to ascertain the manager could not add users.	No deviations noted.
AWSCA-2.3: IT access privileges are reviewed on a periodic basis by appropriate personnel. Control responsible: AWS Inc.	CC6.1; CC6.2; CC6.3; CC6.7; CC6.8	Inquired of Software Development Managers to ascertain access to systems supporting the infrastructure and network above least privilege was reviewed and approved on a quarterly basis by appropriate personnel.	No deviations noted.
		Inquired of Software Development Managers to ascertain access to internal AWS accounts above least privilege was reviewed and approved on a semi-annual basis by appropriate personnel.	No deviations noted.
		Inspected the system configurations responsible for the access review process to ascertain IT infrastructure and network access privileges were reviewed on a	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		quarterly basis by appropriate personnel or access was automatically removed.	
		Inspected the system configurations responsible for the temporary access revocation process to ascertain that when the temporary privileges to resources expired access to the resources was automatically removed.	No deviations noted.
		Inspected the system configurations responsible for the internal transfer revocation process to ascertain when users transferred internally, access to the previous resources was automatically removed.	No deviations noted.
		For one active access group of IT infrastructure and network access privileges marked for removal as part of the user access review process, inspected the access log to ascertain access was automatically revoked.	No deviations noted.
		Observed a Software Development Manager mark an active internal AWS account for removal as part of the user access review process and inspected the account after the review to ascertain access was automatically revoked.	No deviations noted.
		For one user with temporary access to the IT infrastructure and network access privileges, inspected the account to ascertain that when the temporary privileges to the resource expired, access was automatically revoked.	No deviations noted.
		For one active access group of IT infrastructure and network access privileges that were not reviewed during the quarter, inspected the access log to ascertain access privileges were automatically revoked.	No deviations noted.
		For one active access group, inspected the access review process to ascertain IT infrastructure and network access privileges were reviewed quarterly by appropriate personnel.	No deviations noted.
		For one active AWS European Sovereign Cloud account, inspected the access review process to ascertain internal AWS account	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		access privileges were reviewed semi-annually by appropriate personnel.	
AWSCA-2.4: User access to Amazon systems is revoked within 24 hours of the employee record being terminated (deactivated) in the HR System by Human Resources. Control responsible: AWS Inc.	CC6.1 ; CC6.2 ; CC6.3	Inquired of an Employee Onboarding Software Development Engineer to ascertain access to Amazon systems was automatically revoked within 24 hours of an employee record being terminated (deactivated) in the HR System.	No deviations noted.
		Inspected the system configurations responsible for terminating access to Amazon systems to ascertain access to Windows and UNIX user accounts were configured to be automatically revoked within 24 hours after an employee's record was terminated (deactivated) in the HR System by Human Resources.	No deviations noted.
		For one terminated AWS European Sovereign Cloud employee, inspected the employee's HR system record to ascertain access to the Amazon systems was automatically revoked within 24 hours on both Unix/LDAP and Windows/AD accounts.	No deviations noted.
AWSCA-2.5: Password settings are managed in compliance with Amazon.com's Password Policy. Control responsible: AWS Inc.	CC6.1 ; CC6.3	Inquired of a Corporate Systems Manager and Corporate Response Manager to ascertain password complexity, length, maximum age, history, lockout and credential monitoring was enforced per the Amazon.com Password Policy.	No deviations noted.
		Inspected the password configurations in the Active Directory domain to ascertain they were configured to enforce the Amazon.com Password Policy, including: • Passwords must be at least eight (8) characters long • Passwords must meet complexity requirements • Password history is configured to retain and prevent reuse of the most recent 15 passwords • Accounts are set to lockout after 6 invalid attempts	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH’s and Amazon Web Services, Inc.’s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		Observed that the following password configurations were enforced according to the Amazon.com Password Policy after attempting to set a combination of out-of-policy passwords using the password tool within the production environment: • Passwords must be at least eight characters long • Passwords must contain a combination of letters, numbers, and special characters • Passwords must not contain the user’s real name or username • Passwords must not be the same as or similar to a recently used password • Passwords must not contain 'Amazon' or any other business name	No deviations noted.
		Inspected the credential compromise monitoring configuration to ascertain that tickets for compromised credentials were created automatically and logged within a ticketing system per the Amazon.com Password Policy.	No deviations noted.
		Inspected an incident ticket created for impacted user credentials to ascertain credentials of flagged Amazon accounts were identified, tracked and rotated in a timely manner.	No deviations noted.
AWSCA-2.6: AWS requires two-factor authentication over an approved cryptographic channel for authentication to the internal AWS network from remote locations. Control responsible: AWS Inc.	CC6.1; CC6.3; CC6.6	Inquired of a Network Development Engineer to ascertain two-factor authentication over an approved cryptographic channel was required to access the Amazon corporate network from remote locations.	No deviations noted.
		Inspected the RADIUS and SAML server’s authentication protocol configuration to ascertain authentication to the internal AWS network from remote locations required two-factor authentication over an approved cryptographic channel.	No deviations noted.
		Attempted to login to the Amazon corporate network from a remote location to ascertain both a physical token and password were required to access the Amazon corporate	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		network over an approved cryptographic channel.	
AWSCA-3.1: Firewall devices are configured to restrict access to the computing environment and enforce boundaries of computing clusters. Control responsible: AWS Inc.	CC6.1 ; CC6.6 ; CC7.1 ; CC8.1	Inquired of an AWS Infrastructure Security Engineer to ascertain firewall devices were configured to restrict access to the computing environment and enforce boundaries of computing clusters.	No deviations noted.
		For one in-scope firewall, inspected the access control lists to ascertain the device was configured to deny all access to the computing environment and enforce boundaries of computing clusters, unless explicitly authorized.	No deviations noted.
AWSCA-3.2: Firewall policies (configuration files) are automatically pushed to production firewall devices. Control responsible: AWS Inc.	CC6.1 ; CC6.6 ; CC7.1 ; CC8.1	Inquired of an AWS Infrastructure Security Engineer to ascertain firewall policies were automatically pushed to production firewall devices.	No deviations noted.
		Inspected the configurations responsible for firewall policy deployment to ascertain that firewall configuration files were automatically pushed to production firewall devices.	No deviations noted.
		For one in-scope firewall, inspected the deployment log output to ascertain policies were automatically pushed to production firewall device.	No deviations noted.
AWSCA-3.3: Firewall policy updates are reviewed and approved prior to deployment. Control responsible: AWS Inc.	CC6.1 ; CC6.6 ; CC7.1 ; CC8.1	Inquired of an AWS Infrastructure Security Engineer to ascertain data center firewall policy updates were reviewed and approved.	No deviations noted.
		For one in-scope firewall policy update, inspected approval evidence to ascertain it was reviewed and approved by appropriate personnel prior to implementation.	No deviations noted.
		For one employee eligible to approve ACL requests, inspected the job title and team of the employee to ascertain that user access rights were appropriate.	No deviations noted.
AWSCA-3.4: AWS performs external vulnerability assessments at least quarterly, identified	CC3.2 ; CC3.3 ; CC3.4 ; CC4.1 ; CC6.8 ;	Inquired of an AWS Security Engineer to ascertain quarterly external vulnerability assessments were performed and that identified issues were investigated and tracked to resolution.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
issues are investigated and tracked to resolution in a timely manner. Control responsible: AWS Inc.	CC7.1 ; CC7.2 ; CC7.4	Inspected the listing of production end points used by the vulnerability assessment tools of a quarterly external vulnerability assessment performed to ascertain production hosts for the in-scope services (that supported public end points) were included in the scan.	No deviations noted.
		Inspected the evidence of a performed quarterly external vulnerability assessment to ascertain that results were documented, and identified issues were tracked, addressed, and resolved in a timely manner.	No deviations noted.
AWSCA-3.5: AWS enables customers to select who has access to AWS services and resources that they own. AWS prevents customers from accessing AWS resources that are not assigned to them via access permissions. Content is only returned to individuals authorized to access the specified AWS service or resource (if resource-level permissions are applicable to the service). Control responsible: AWS European Sovereign Cloud Entity	CC6.1	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain AWS enabled customers to select who had access to AWS European Sovereign Cloud services and resources that they owned, that customers were prevented from accessing AWS European Sovereign Cloud resources that were not assigned to them via access permissions, and that content was only returned to individuals authorized to access the specific AWS European Sovereign Cloud service or resource.	No deviations noted.
		Inspected the configurations of a AWS European Sovereign Cloud service that managed external access to AWS European Sovereign Cloud services and resources (if resource-level permissions were applicable to the service) to ascertain the service was designed to return content only to individuals authorized to access the specified AWS European Sovereign Cloud service or resource, and that AWS European Sovereign Cloud prevented customers from accessing resources that had not been assigned to them via access permissions.	No deviations noted.
		Observed a user with authorized access permissions attempt to access an AWS European Sovereign Cloud service and resource to ascertain that the service returned content to individuals authorized to access the specified AWS European Sovereign Cloud service or resource only.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH’s and Amazon
Web Services, Inc.’s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		Observed a user without authorized access permissions attempt to access an AWS European Sovereign Cloud service and resource to ascertain that the services did not return content to individuals without authorized access to the specified AWS European Sovereign Cloud service or resource.	No deviations noted.
AWSCA-3.6: AWS performs application security reviews for externally launched products, services, and significant feature additions prior to launch to identify whether security and privacy risks are identified and mitigated. Control responsible: AWS Inc.	CC2.1 ; CC6.1 ; CC7.1 ; CC8.1	Inquired of an Application Security Technical Program Manager to ascertain AWS performed application security reviews for launched products, services, and significant feature additions prior to launch to evaluate whether security risks were identified and mitigated.	No deviations noted.
		For one in-scope service, inspected the Application Security team’s review to ascertain the service and significant feature additions were reviewed and approved prior to launch.	No deviations noted.
AWSCA-3.7: S3-Specific – Network devices are configured by AWS to only allow access to specific ports on other server systems within Amazon S3. Control responsible: AWS Inc.	CC6.1 ; CC6.6	Inquired of an S3 Software Development Engineer to ascertain network devices were configured to only allow access to specific ports on server systems within Amazon S3.	No deviations noted.
		For one S3 network device, inspected the configuration settings to ascertain the device was configured to only allow access to specified ports.	No deviations noted.
AWSCA-3.8: S3-Specific – External data access is logged with data accessor IP address, object and operation information, and logs are retained for at least 90 days. Control responsible: AWS Inc.	CC6.1 ; CC6.6	Inquired of an S3 Software Development Engineer to ascertain external data access was logged with the data accessor IP address, object, and operation information, and that logs were retained for at least 90 days.	No deviations noted.
		Inspected the configuration settings pushed to the S3 web servers to ascertain that the servers were configured to log the data accessor IP address, as well as the object and operation information.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		For one in-scope AWS European Sovereign Cloud Availability Zone (AZ), inspected the environment operational configuration for log retention of external access to data to ascertain that logs were configured to be retained for 90 days.	No deviations noted.
		Observed a Software Development Engineer perform an access operation on an S3 object and inspected the external data access log output after 90 days to ascertain that external data access was logged with data accessor IP address, as well as object and operation information.	No deviations noted.
AWSCA-3.9: EC2-Specific – Physical hosts have host-based firewalls to prevent unauthorized access. Control responsible: AWS Inc.	CC6.1 ; CC6.6	Inquired of an EC2 Security Engineer to ascertain EC2 physical hosts had host-based firewalls, or access was logically restricted, to prevent unauthorized access.	No deviations noted.
		Inspected the automated configurations responsible for configuring a new host to ascertain that host-based firewalls were automatically added during the build process of new hosts.	No deviations noted.
		Inspected the monitoring configurations of physical hosts to ascertain that monitoring was in place to notify service team members in the case that a physical host did not have an active firewall.	No deviations noted.
		Observed an EC2 Security Engineer make an API request with and without the appropriate token to ascertain a host-based access token was required to authorize access to the host.	No deviations noted.
		For one EC2 physical host supporting the in-scope AWS European Sovereign Cloud region, inspected the host-based firewall settings to ascertain host-based firewalls were in place and operational to prevent unauthorized access.	No deviations noted.
AWSCA-3.10: EC2-Specific – Virtual hosts are behind software firewalls which are configured	CC6.1	Inquired of an EC2 Security Manager to ascertain virtual hosts were behind software firewalls, which prevented TCP/IP spoofing, packet sniffing, and restricted incoming connections to customer-specified ports.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
to prevent TCP/IP spoofing, packet sniffing, and restrict incoming connections to customer-specified ports. Control responsible: AWS Inc.		Observed an EC2 Security Engineer create a virtual EC2 host with a firewall configured to communicate with only specified IP addresses and ascertained that communications with the specified IP address were successful.	No deviations noted.
		Observed an EC2 Security Engineer attempt to communicate with an unspecified IP address to ascertain the attempts were denied.	No deviations noted.
		Observed an EC2 Security Engineer create a virtual EC2 host and inspected the IP table configurations to ascertain traffic was routed to prevent TCP/IP spoofing.	No deviations noted.
		Observed an EC2 Security Engineer create two EC2 instances on a single physical EC2 host and generate network traffic on each instance to ascertain neither of the instances was able to packet sniff the traffic of the other instance.	No deviations noted.
AWSCA-3.11: EC2-Specific – AWS prevents customers from accessing custom AMIs not assigned to them by a property of the AMI called launch-permissions. By default, the launch-permissions of an AMI restrict its use to the customer/account that created and registered it. Control responsible: AWS Inc.	CC6.1	Inquired of an EC2 Security Manager to ascertain AWS prevented customers from accessing custom AMIs not assigned to them by default launch-permissions.	No deviations noted.
		Inspected the AMI launch-permissions configuration within the AWS console to ascertain that by default the launch permission of an AMI restricted its use to the account that created it unless the customer granted access permissions.	No deviations noted.
		Created an AMI, attempted to access the AMI without the designated launch permissions, and inspected the error message within the AWS management console to ascertain access was restricted.	No deviations noted.
AWSCA-3.12: EC2-Specific – AWS prevents customers from accessing physical hosts or instances not	CC6.1	Inquired of an EC2 Security Manager to ascertain customers were restricted from accessing physical hosts or instances not assigned to them by filtering through the virtualization software.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
assigned to them by filtering through the virtualization software. Control responsible: AWS Inc.		Observed an EC2 Security Engineer attempt to IP ping the physical EC2 host from an EC2 instance within the host to ascertain the physical host was isolated from the instances.	No deviations noted.
		Observed an EC2 Security Engineer attempt to access a file stored on an EC2 instance from the physical EC2 host the instance was located on to ascertain the instances located on physical hosts were unable to be accessed.	No deviations noted.
		Observed an EC2 Security Engineer attempt to access a file stored on an EC2 instance from a different instance on the same physical EC2 host to ascertain the instances on the same physical hosts were isolated from one another.	No deviations noted.
AWSCA-3.13: VPC-Specific – Network communications within a VPC are isolated from network communications within other VPCs. Control responsible: AWS Inc.	CC6.1	Inquired of an EC2 Networking Software Development Engineer to ascertain network communications between different VPCs were isolated from one another.	No deviations noted.
		Observed an EC2 Networking Software Development Engineer configure the VPC infrastructure for two VPCs and attempt to communicate between instances across the two VPCs to ascertain network communication between the two VPCs was isolated.	No deviations noted.
AWSCA-3.14: VPC-Specific – Network communications within a VPN Gateway are isolated from network communications within other VPN Gateways. Control responsible: AWS Inc.	CC6.1	Inquired of an EC2 Networking Software Development Engineer to ascertain network communications between VPN gateways were isolated from one another.	No deviations noted.
		Observed an EC2 Networking Software Development Engineer configure a VPC infrastructure with two VPN Gateways and attempt to communicate between instances across the two VPN Gateways to ascertain network communication between VPN gateways was isolated.	No deviations noted.
AWSCA-3.15: VPC-Specific – Internet traffic through an Internet Gateway is	CC6.1	Inquired of a Sr. Software Engineer, EC2 VPC to ascertain internet traffic through an Internet Gateway was only forwarded to an instance in a VPC when an Internet Gateway	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
forwarded to an instance in a VPC only when an Internet Gateway is attached to the VPC and a public IP is mapped to the instance in the VPC. Control responsible: AWS Inc.		was attached to the VPC, and a public IP was mapped to the instance in the VPC.	
		Created a VPC, attached an Internet Gateway, allocated a public IP, and per inspection of traffic on an instance, ascertained traffic was successfully forwarded.	No deviations noted.
		Removed the Internet Gateway and public IP from the VPC and per inspection of the traffic on the instance, ascertained traffic was prevented from being forwarded.	No deviations noted.
AWSCA-3.16: AWS maintains formal policies and procedures that provide guidance for operations and information security within the organization and the supporting AWS environments. The mobile device policy provides guidance on: • Use of mobile devices. • Protection of devices that access content for which Amazon is responsible. • Remote wipe capability. • Password-guessing protection restrictions. • Remote synchronization requirements. • Security patch requirements	CC6.4; CC6.7; CC8.1	Inquired of an AWS Risk Management Program Manager to ascertain formal policies and procedures for the use of mobile devices existed and included guidance for operations and information security for organizations that support AWS environments.	No deviations noted.
		Inspected the AWS internal website to ascertain formal policies and procedures for the use of mobile devices were available to AWS employees.	No deviations noted.
		Inspected the mobile device policy to ascertain it included organization-wide security procedures as guidance for the AWS environment regarding: • Use of mobile devices • Protection of devices that access content for which Amazon is responsible • Remote wipe capability • Password-guessing protection restrictions • Remote synchronization requirements • Security patch requirements • Approved methods for accessing Amazon data	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
Approved methods for accessing Amazon data. Control responsible: AWS Inc.			
AWSCA-3.18: Anti-virus software is installed, updated and running on workstations. Control responsible: AWS Inc.	CC6.7; CC6.8	Inquired of an AWS Security Platform Manager to ascertain anti-virus software was installed, updated, and running on workstations.	No deviations noted.
		Inspected the anti-virus configurations on the administrator console for the imaging of workstations to ascertain the anti-virus software was in place to monitor for malicious code, was automatically updated with new release or virus definitions and prevented end-users from disabling the service.	No deviations noted
		Inspected a workstation that had anti-virus software disabled by an admin to ascertain that the workstation was in process of being isolated from the network.	No deviations noted
		Inspected a workstation to ascertain anti-virus software was installed, updated and running in accordance with the AWS System and Information Integrity Policy.	No deviations noted.
AWSCA-3.19: S3-Specific - All new objects uploaded to Amazon S3 are automatically encrypted with server-side encryption. Control responsible: AWS Inc.	CC6.1; CC6.7	Inquired of a Software Development Engineer to ascertain new objects uploaded to Amazon S3 were automatically encrypted with server-side encryption.	No deviations noted.
		Inspected the code configurations to ascertain new objects uploaded to Amazon S3 were automatically encrypted with server-side encryption.	No deviations noted.
		Observed a Software Development Engineer upload a new object to a general-purpose S3 bucket, and inspected the object's attributes to ascertain the newly uploaded object was encrypted with server-side encryption.	No deviations noted.
		Inspected a log from the monitoring tool which was configured to detect any plaintext (unencrypted) objects stored within S3 to	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		ascertain that no unencrypted objects were detected during the reporting period.	
AWSCA-4.1: EC2-Specific – Upon initial communication with an AWS-provided Linux AMI, AWS enables secure communication by SSH configuration on the instance, by generating a unique host-key and delivering the key's fingerprint to the user over a trusted channel. Control responsible: AWS Inc.	CC6.7	Inquired of a Technical Program Manager to ascertain upon initial communication with an AWS-provided Linux AMI, AWS enabled a secure communication by SSH configuration on the instance by generating and delivering a unique host-key fingerprint to the user over a trusted channel.	No deviations noted.
		Launched a public Linux AMI EC2 instance and inspected the EC2 console to ascertain the unique host-key fingerprint was accessible from the system log.	No deviations noted.
		Using the launched public Linux AMI EC2 instance, connected to the instance via SSH using the unique host-key fingerprint and inspected the connection logs to ascertain the unique host-key fingerprint was listed.	No deviations noted.
		Launched a second public Linux AMI EC2 instance and inspected the EC2 console and instance connection logs to ascertain the unique host-key fingerprint was different from the first instance.	No deviations noted.
		Using the second public Linux AMI EC2 instance, attempted to connect to the instance via SSH using the first instance's unique host-key fingerprint and observed the attempt was rejected by the system to ascertain that the connection to a Linux AMI EC2 instance could only be performed using the instance's unique host-key fingerprint.	No deviations noted.
AWSCA-4.2: EC2-Specific – Upon initial communication with an AWS-provided Windows AMI, AWS enables secure communication by configuring Windows Terminal Services on the instance by	CC6.7	Inquired of a Technical Program Manager to ascertain upon initial communication with an AWS-provided Windows AMI, AWS enabled a secure communication by configuring Windows Terminal Services on the instance by generating a unique self-signed server certificate and delivering the certificate's thumbprint to the user over a trusted channel.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
generating a unique self-signed server certificate and delivering the certificate's thumbprint to the user over a trusted channel. Control responsible: AWS Inc.		Launched a public Windows AMI EC2 instance and inspected the EC2 console and the system log to ascertain the self-signed server certificate was accessible.	No deviations noted.
		Using the launched public Windows AMI EC2 instance, connected to the instance using the unique self-signed server certificate to ascertain the connection logs matched the unique self-signed server certificate from the instance's EC2 console system log.	No deviations noted.
		Launched a second public Windows AMI EC2 instance and inspected the EC2 console and instance connection logs to ascertain the unique self-signed server certificate was different than for the first instance.	No deviations noted.
		Using the second public Windows AMI EC2 instance, attempted to connect to the instance using the first instance's unique self-signed server certificate and observed the attempt was rejected by the system to ascertain that connection to a Windows AMI EC2 instance can only be performed using the instance's unique self-signed server certificate.	No deviations noted.
AWSCA-4.3: VPC-Specific – Amazon enables secure VPN communication to a VPN Gateway by providing a shared secret key that is used to establish IPsec Associations. Control responsible: AWS Inc.	CC6.7	Inquired of a VPC Manager of Software Development to ascertain Amazon enabled secure VPN communication to a VPN Gateway through a secret key that established IPsec Associations.	No deviations noted.
		Observed a VPC Manager of Software Development use the shared secret key to establish IPsec Associations to ascertain the connection was successful.	No deviations noted.
		Observed the VPC Manager of Software Development alter the shared secret key to establish IPsec Security Associations to ascertain the connection was unsuccessful.	No deviations noted.
AWSCA-4.4: S3-Specific – S3 generates and stores a one-way salted HMAC of the	CC6.1 ; CC6.7	Inquired of an S3 Software Development Engineer to ascertain S3 generated and stored a one-way salted HMAC of the customer encryption key, and that the salted HMAC value was not logged.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
customer encryption key, and this salted HMAC value is not logged. Control responsible: AWS Inc.		Observed an S3 Software Development Engineer upload an encrypted object to S3 and inspected the metadata for the stored object to ascertain the encryption information included a one-way salted HMAC of the customer encryption key.	No deviations noted.
		Observed an S3 Software Development Engineer upload an encrypted object to S3 and searched the S3 host logs for the one-way salted HMAC value to ascertain it was not logged.	No deviations noted.
		Observed an S3 Software Development Engineer attempt to decrypt an object in S3 with an incorrect encryption key to ascertain the decrypt function failed and the object was unreadable.	No deviations noted.
AWSCA-4.5: KMS-Specific – KMS keys used for cryptographic operations in KMS are logically secured so that no AWS employee can gain access to the key material. Control responsible: AWS Inc.	CC6.1	Inquired of an AWS Cryptography Software Development Engineer to ascertain no AWS employee could gain logical access to the hardened security modules where customer keys were used for cryptographic operations.	No deviations noted.
		Inspected the configurations for gaining logical access to the hardened security module to ascertain KMS keys used for cryptographic operations in KMS were logically secured so that no AWS employee could gain access to the key material.	No deviations noted.
		Inspected the KMS key material access configurations to ascertain no single AWS employee could modify rulesets, host or operator membership to the domain of the hardened security appliance.	No deviations noted.
		Observed an AWS Cryptography Software Development Engineer attempt to gain logical access to the hardened security module where customer keys were used in memory to ascertain this was not possible.	No deviations noted.
		Observed an AWS Cryptography Software Development Engineer attempt to remove a host or operator without meeting the quorum rules to ascertain the actions resulted in a quorum rule error.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-4.6: KMS-Specific – AWS Services that integrate with AWS KMS for key management use a 256-bit data key locally to protect customer content. Control responsible: AWS Inc.	CC6.1; CC6.7	Inquired of an AWS Cryptography Technical Program Manager to ascertain AWS Services which integrate with AWS KMS for key management used a 256-bit AES data key locally to protect customer content.	No deviations noted.
		Inspected the API call configurations of a service which integrated with KMS for a service that stored customer content to ascertain the service was configured to send 256-bit AES key requests to KMS.	No deviations noted.
AWSCA-4.7: KMS-Specific – The key provided by KMS to integrated services is a 256-bit key and is encrypted with a 256-bit AES key unique to the customer's AWS account. Control responsible: AWS Inc.	CC6.1; CC6.7	Inquired of an AWS Cryptography Technical Program Manager to ascertain keys provided by KMS to integrated services were 256-bit AES keys and were themselves encrypted by 256-bit AES keys unique to each customer's AWS account.	No deviations noted.
		Inspected the KMS key creation configuration to ascertain KMS keys created by KMS utilized the AES-256 cryptographic algorithm.	No deviations noted.
		Inspected the KMS encryption activity configuration to ascertain 256-bit AES keys were returned for 256-bit AES key requests coming from the integrated KMS services to encrypt customer data.	No deviations noted.
		Observed an AWS Cryptography Software Development Engineer create a resource with content enabled for encryption using KMS to ascertain a KMS key was used to encrypt a 256-bit AES data encryption key (which was used to encrypt the content) as requested from the service.	No deviations noted.
		Observed an AWS Cryptography Software Development Engineer create a resource with content enabled for encryption using KMS and then attempt to access the data without decrypting to ascertain it was unreadable.	No deviations noted.
		Observed an AWS Cryptography Software Development Engineer create a resource with content enabled for encryption using KMS and then attempt to decrypt the data	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		using the required 256-bit AES data encryption key to ascertain the data was successfully decrypted.	
		Uploaded test data using a KMS-integrated service encrypted with a data encryption key, encrypted by a KMS key relating to an AWS account and attempted to perform the same activity, using another AWS account, calling upon the same KMS key to observe an upload failure occurred due to an authorization failure caused by a mismatch between the owner of the KMS key and the AWS account.	No deviations noted.
AWSCA-4.8: KMS-Specific – Requests in KMS are logged in AWS CloudTrail. Control responsible: AWS Inc.	CC6.1	Inquired of an AWS Cryptography Technical Program Manager to ascertain API calls made by the AWS services that integrate with KMS were captured when the logging feature was enabled.	No deviations noted.
		Inspected the configuration for KMS logging to ascertain requests in KMS were designed to be logged in AWS CloudTrail.	No deviations noted.
		Enabled CloudTrail logging on a service that integrated with KMS, uploaded data using a KMS key for encryption, and downloaded the same file for decryption and inspected the logs in AWS CloudTrail to ascertain activity from both encryption and decryption API calls was logged.	No deviations noted.
AWSCA-4.9: KMS-Specific – KMS endpoints can only be accessed by customers using TLS with cipher suites that support forward secrecy. Control responsible: AWS Inc.	CC6.1 ; CC6.7	Inquired of an AWS Cryptography Technical Program Manager to ascertain KMS endpoints could only be accessed using TLS with cipher suites to support forward secrecy.	No deviations noted.
		Inspected the configuration for KMS TLS communication to ascertain the cipher suites listed supported forward secrecy.	No deviations noted.
		Observed an AWS Security Assurance Manager attempt to connect to a public KMS service endpoint using an unsupported cipher suite to ascertain the endpoints could not be accessed.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		Observed an AWS Security Assurance Manager attempt to connect to a public KMS service endpoint using a supported cipher suite supporting forward secrecy to ascertain the endpoint connection was successful.	No deviations noted.
AWSCA-4.10: KMS-Specific – Keys used in AWS KMS are only used for a single purpose as defined by the key usage parameter for each key. Control responsible: AWS Inc.	CC6.1	Inquired of an AWS Cryptography Technical Program Manager to ascertain keys used in AWS KMS were only used for a single purpose as defined by the key usage parameter for each key.	No deviations noted.
		Inspected the source code responsible for AWS KMS key usage to ascertain the key usage parameter was configured at the key level and that key operations required the use of keys designated by the system for that operation.	No deviations noted.
		Created an AWS KMS key and attempted to perform a key operation in alignment with the key usage parameter to ascertain the operation was performed in accordance with the set parameter.	No deviations noted.
		Created an AWS KMS key and attempted to perform a key operation not in alignment with the key usage parameter to ascertain the operation resulted in a key usage error.	No deviations noted.
AWSCA-4.11: KMS-Specific – KMS keys created by KMS are rotated on a defined frequency if enabled by the customer. Control responsible: AWS Inc.	CC6.1 ; CC6.7	Inquired of an AWS Cryptography Technical Program Manager to ascertain the KMS service included functionality for KMS keys to be rotated on a defined frequency, if enabled by the customer.	No deviations noted.
		Inspected the source code responsible for KMS key rotation to ascertain a new backing key would be created in accordance with the customer defined frequency, if enabled.	No deviations noted.
		Inspected the on-demand key rotation event log for an AWS internal key to ascertain the key was rotated immediately, and that the rotation event was logged.	No deviations noted.
		Inspected a scheduled key rotation event log for an AWS internal key to ascertain the backing key was rotated in accordance with the defined frequency, and the rotation event was logged.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-4.12: KMS-Specific - Recovery key materials used for disaster recovery processes by KMS are physically secured offline so that no single AWS employee can gain access to the key material. Control responsible: AWS European Sovereign Cloud Entity	CC6.1; CC6.4	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain recovery key materials used for disaster recovery processes by KMS were physically secured offline and that no single AWS employee could gain access to the key material.	No deviations noted.
		For one AWS European Sovereign Cloud employee with physical access to the recovery key material resources used for disaster recovery processes by KMS, inspected the job title and reporting structure within the employee directory tool to ascertain access privilege was appropriate based on the roles and responsibilities.	No deviations noted.
		Inspected a physical access log of access attempts to rooms where the recovery key materials were located to ascertain no single AWS employee could gain access by themselves.	No deviations noted.
AWSCA-4.13: KMS-Specific – Access attempts to recovery key materials are reviewed by authorized operators on a cadence defined in team documentation. Control responsible: AWS European Sovereign Cloud Entity	CC6.1; CC6.4	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain access attempts to recovery key materials were reviewed by authorized operators on a cadence defined in team documentation.	No deviations noted.
		Inspected the review of access attempts or requests to recovery key materials to ascertain the review was performed and documented by authorized AWS European Sovereign Cloud operators on a cadence defined in team documentation.	No deviations noted.
AWSCA-4.14: KMS-Specific – Each production firmware version release for the AWS Key Management Service HSM (Hardware Security Module) either holds or is in the process of actively pursuing FIPS-140-3 level 3	CC6.1; CC6.6; CC6.7	Inquired of an AWS Cryptography Technical Program Manager to ascertain the production firmware version of the AWS Key Management Service HSM was certified with NIST under the FIPS 140-2 level 3 standard or is in the process of being certified under the FIPS 140-3 level 3 standard.	No deviations noted.
		For the in-scope AWS European Sovereign Cloud region, inspected the firmware version running on production AWS Key Management Service HSM devices to	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
certification from the National Institute of Standards and Technology's (NIST) Cryptographic Module Validation Program (CMVP). Control responsible: AWS Inc.		ascertain the production firmware version of the AWS Key Management Service HSMs was certified by NIST Cryptographic Module Validation Program Certificate under the FIPS 140-2 level 3 standard or updated firmware was in the process of being certified under the FIPS 140-3 level 3 standard.	
AWSCA-5.1: Physical access to data centers is approved by an authorized individual. Control responsible: AWS European Sovereign Cloud Entity	CC6.4 ; CC6.7	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain physical access to data centers was approved by authorized AWS European Sovereign Cloud Staff.	No deviations noted.
		Inspected the configuration for executing the physical access approval and provisioning within the data center access management system to ascertain physical access to data centers was designed to be granted after an approval by authorized AWS European Sovereign Cloud Staff.	No deviations noted.
		For one user provisioned data center access, inspected the data center physical access provisioning records to ascertain physical access was granted after it was approved by authorized AWS European Sovereign Cloud Staff.	No deviations noted.
AWSCA-5.2: Physical access is revoked within 24 hours of the employee or vendor record being deactivated. Control responsible: AWS European Sovereign Cloud Entity	CC6.4 ; CC6.7	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain physical access was automatically revoked within 24 hours of the employee or a vendor's employee record being deactivated.	No deviations noted.
		Inspected the system configurations within the data center access management system to ascertain physical access was automatically revoked within 24 hours of the employee, contractor or vendor's employee record being deactivated in the HR system.	No deviations noted.
		For one terminated AWS European Sovereign Cloud employee, inspected the access provisioning system and HR System record to ascertain physical access was systematically	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		revoked within 24 hours of the employee record being deactivated in the HR system.	
AWSCA-5.3: Physical access to data centers is reviewed on a quarterly basis by appropriate personnel. Control responsible: AWS European Sovereign Cloud Entity	CC6.4 ; CC6.7	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain physical access to data centers was reviewed on a quarterly basis by appropriate personnel.	No deviations noted.
		Inspected the system configurations of the data center access management system to ascertain that access marked for removal as part of the access review was automatically revoked.	No deviations noted.
		Inspected the documentation of a performed physical access review to ascertain that reviews of physical access were completed.	No deviations noted.
		For one user marked for removal during the performed physical access review, inspected the CloudWatch logs for revocation activities to ascertain the user's access was appropriately removed from the data center access management system.	No deviations noted.
		For one user who had data center access, inspected the documentation of the access review to ascertain that the review was performed as required by policy and that access was approved by appropriate AWS European Sovereign Cloud Staff.	No deviations noted.
AWSCA-5.4: CCTV are used to monitor server locations in data centers. Images are retained for 90 days, unless limited by legal or contractual obligations. Control responsible: AWS European Sovereign Cloud Entity	CC6.4	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain physical access points to server locations were monitored by a closed circuit television camera (CCTV) and that images were retained for 90 days unless limited by legal or contractual obligations.	No deviations noted.
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, observed the CCTV footage or inspected screenshots of video recordings around server location access points to ascertain physical access points to server locations were recorded.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, inspected the network video recorder configuration to ascertain CCTV images to server locations were retained for at least 90 days, unless limited by legal or contractual obligations.	No deviations noted.
AWSCA-5.5: Access to server locations is managed by electronic access control devices. Control responsible: AWS European Sovereign Cloud Entity	CC6.4	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain physical access points to server locations were managed by electronic access control devices.	No deviations noted.
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, observed electronic access control devices at physical access points to server locations and inspected the physical security access control configurations to ascertain electronic access control devices were installed at physical access points to server locations and that they required authorized Amazon badges with corresponding PINs to enter server locations.	No deviations noted.
AWSCA-5.6: Electronic intrusion detection systems are installed within data server locations to monitor, detect, and automatically alert appropriate personnel of security incidents. Control responsible: AWS European Sovereign Cloud Entity	CC7.2; CC7.3	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain electronic intrusion detection systems were installed and capable of detecting breaches into data center server locations.	No deviations noted.
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, observed on-premise electronic intrusion detection systems and inspected the physical security access control configurations to ascertain electronic intrusion detection systems were installed, that they were capable of detecting intrusion attempts, and that they automatically alerted security personnel of detected events for investigation and resolution.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-5.7: Amazon-owned data centers are protected by fire detection and suppression systems. Control responsible: AWS European Sovereign Cloud Entity	A1.2	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain Amazon-owned data centers were protected by fire detection and fire suppression systems.	No deviations noted.
		For one in-scope Amazon-owned data center, observed on-premise fire detection systems to ascertain they were located throughout the data center.	No deviations noted.
		For one in-scope Amazon-owned data center, observed on-premise fire suppression devices to ascertain they were located throughout the data center.	No deviations noted.
AWSCA-5.8: Amazon-owned data centers are air conditioned to maintain appropriate environmental conditions. Personnel and systems monitor and control air temperature and humidity at appropriate levels. Control responsible: AWS European Sovereign Cloud Entity	A1.2	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain Amazon-owned data centers were air conditioned to maintain appropriate environmental conditions and that the units were monitored by personnel and systems to control air temperature and humidity at appropriate levels.	No deviations noted.
		For one in-scope Amazon-owned data center, observed on-premise air-conditioning systems to ascertain they monitored and controlled temperature and humidity at appropriate levels.	No deviations noted.
AWSCA-5.9: Uninterruptible Power Supply (UPS) units provide backup power in the event of an electrical failure in Amazon-owned data centers and third-party colocation sites where Amazon maintains the UPS units.	A1.2	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain UPS units provided backup power in the event of an electrical failure in Amazon-owned data centers and in colocation sites where AWS European Sovereign Cloud maintains the UPS units.	No deviations noted.
		Inspected the system configuration responsible for the automatic onboarding and continuous monitoring of the health of AWS European Sovereign Cloud maintained backup battery units (BBU) to ascertain that BBUs were being monitored and would send an alert in the event of an electrical failure.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
Control responsible: AWS European Sovereign Cloud Entity		For one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, inspected evidence that BBUs were being monitored and would send an alert in the event of an electrical failure.	No deviations noted.
		For one in-scope Amazon-owned data center, observed on-premise UPS equipment to ascertain UPS units were configured to provide backup power in the event of an electrical failure.	No deviations noted.
AWSCA-5.10: Amazon-owned data centers have generators to provide backup power in case of electrical failure. Control responsible: AWS European Sovereign Cloud Entity	A1.2	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain Amazon-owned data centers had generators to provide backup power in case of utility power failure.	No deviations noted.
		For one in-scope Amazon-owned data center, observed on-premise generator equipment to ascertain generators were configured to provide backup power in case of electrical failure.	No deviations noted.
AWSCA-5.11: Contracts are in place with third-party colocation service providers which include provisions to provide fire suppression systems, air conditioning to maintain appropriate atmospheric conditions, Uninterruptible Power Supply (UPS) units (unless maintained by Amazon), and redundant power supplies. Contracts also include provisions requiring communication of	CC7.3; CC7.4; CC7.5; CC9.2; A1.2	Inquired of AWS Legal Corporate Counsel to ascertain contracts were in place at the colocation service providers which included provisions for fire suppression systems, air conditioning, UPS units, and redundant power supplies as well as provisions requiring communication of incidents or events that impacted Amazon assets or customers to AWS.	No deviations noted.
		For one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, inspected the current contractual agreement between the service provider and AWS to ascertain it included provisions for fire suppression systems, air conditioning, UPS units, and redundant power supplies as well as provisions requiring the colocation service provider to notify Amazon immediately of discovery of any unauthorized use or disclosure of confidential information or any other breach.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
incidents or events that impact Amazon assets and/or customers to AWS. Control responsible: AWS Inc.			
AWSCA-5.12: AWS performs periodic reviews of colocation service providers to validate adherence with AWS security and operational standards. Control responsible: AWS Inc.	CC3.2 ; CC3.3 ; CC3.4 ; CC4.1 ; CC7.3 ; CC7.4 ; CC7.5 ; CC9.2 ; A1.2	Inquired of a Sr. Security Engineer, AWS Infrastructure Security to ascertain periodic reviews were performed for colocation vendor relationships to validate adherence with AWS security and operational standards.	No deviations noted.
		For one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, inspected the corresponding vendor review to ascertain it was performed in accordance with the colocation business review schedule and included an evaluation of adherence to AWS security and operational standards.	We noted that the globally designed and implemented control was applicable to the AWS European Sovereign Cloud. However, since the implementation of the AWS European Sovereign Cloud and as of January 15, 2026, the control had not yet been executed for AWS European Sovereign Cloud-specific instances. Therefore, we performed the walkthrough based on control execution within the global AWS environment and inspected evidence indicating that the control was planned to be executed for the AWS European Sovereign Cloud in an equivalent manner.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-5.13: All AWS production media is securely decommissioned and physically destroyed, verified by two personnel, prior to leaving AWS control. Control responsible: AWS European Sovereign Cloud Entity	CC6.5 ; CC6.7 ; C1.2	Inquired of an AWS European Sovereign Cloud Data Center Operations Manager to ascertain AWS European Sovereign Cloud production media was securely decommissioned and physically destroyed prior to leaving AWS control.	No deviations noted.
		Inspected the AWS Media Destruction Standard Operating Procedures document to ascertain that it included procedures for data center personnel to securely decommission production media prior to leaving AWS European Sovereign Cloud control.	No deviations noted.
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, observed on-premise security practices to ascertain production media was restricted to the AWS European Sovereign Cloud control, unless securely decommissioned and physically destroyed.	No deviations noted.
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, observed on-premise equipment and media or inspected media destruction logs for secure decommissioning and physical destruction to ascertain production media was securely decommissioned, physically destroyed, and verified by two personnel prior to leaving AWS European Sovereign Cloud control.	No deviations noted.
AWSCA-6.1: AWS applies a systematic approach to managing change to ensure changes to customer-impacting aspects of a service are reviewed, tested and approved. Change management policies/procedures are based on Amazon guidelines and tailored to the	CC6.1 ; CC6.8 ; CC7.5 ; CC8.1	Inquired of Software Development Managers to ascertain customer-impacting changes of service to the production environment were reviewed, tested, approved, and followed relevant change management guidelines and that service-specific change management processes were maintained, followed, and communicated to the service teams.	No deviations noted.
		For one in-scope service, inspected the relevant change management guidelines to ascertain they communicated specific guidance on change management processes, including initiation, testing and approval, and	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
specifics of each AWS service. Control responsible: AWS Inc.		that service team-specific steps were documented and maintained by the teams.	
AWSCA-6.2: Change details are documented within one of Amazon's change management or deployment tools. Control responsible: AWS Inc.	CC6.8; CC8.1	Inquired of Software Development Managers to ascertain changes were documented within one of Amazon's change management or deployment tools.	No deviations noted.
		For one change deployed to production, inspected Amazon's change management or deployment tools to ascertain the change details were documented and communicated to service team management.	No deviations noted.
AWSCA-6.3: Changes are tested according to service team change management policies/procedures prior to migration to production. Control responsible: AWS Inc.	CC6.8; CC8.1	Inquired of Software Development Managers to ascertain changes were tested according to service team change management standards prior to migration to production.	No deviations noted.
		For one change migrated to production, inspected the change management system screenshots to ascertain the change was tested according to service team change management standards and testing occurred in a development environment prior to migration to production.	No deviations noted.
AWSCA-6.4: AWS maintains separate production and development environments. Control responsible: AWS Inc.	CC6.8; CC8.1	Inquired of Software Development Managers to ascertain AWS maintained separate production and development environments.	No deviations noted.
		For one change deployed to production, inspected the related deployment pipelines to ascertain the production and development environments were separate.	No deviations noted.
AWSCA-6.5: Changes are reviewed for business impact and approved by authorized personnel prior to migration to production according to service team change management policies/procedures.	CC6.8; CC8.1	Inquired of Software Development Managers to ascertain changes were reviewed for business impact and approved by authorized personnel prior to migration to production according to service team change management standards.	No deviations noted.
		For one changes migrated to production, inspected the relevant change management or deployment tools to ascertain the change was reviewed and approved by authorized personnel prior to migration to production	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
Control responsible: AWS Inc.		according to service team change management standards.	
		Inspected the configurations in-place for publishing AWS managed IAM policies to ascertain that policies were designed to require approvals prior to being moved to production.	No deviations noted.
		Inspected an AWS managed IAM policy to ascertain that the policy managed by AWS was approved prior to being moved to production.	No deviations noted.
AWSCA-6.6: AWS performs deployment validations and change reviews to detect unauthorized changes to its environment and tracks identified issues to resolution. Control responsible: AWS Inc.	CC6.8 ; CC7.1 ; CC8.1	Inquired of Software Development Managers to ascertain AWS performed deployment validations and change reviews to detect changes that did not follow the change management process and that appropriate actions were taken to track identified issues to resolution.	No deviations noted.
		For one change migrated to production, inspected the associated validation output to ascertain AWS performed deployment validations and change reviews to detect unauthorized changes and that follow-up actions were taken as necessary to remediate any issues identified.	No deviations noted.
		Inspected the quarterly security business review and the contents of the deployment violations dashboard to ascertain unauthorized changes were reviewed by AWS management.	No deviations noted.
		Inspected the contents of the deployment violation dashboard for one month and service to ascertain unauthorized changes were tracked to resolution by AWS management.	No deviations noted.
		Inspected the configuration of the compliance-based database used for monitoring in-scope services to ascertain that when new pipelines were added to the automated deployment monitoring tool, the corresponding in-scope services were uploaded into the compliance-based database.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-6.7: Customer information, including personal information, and customer content are not used in test and development environments. Control responsible: AWS Inc.	CC8.1	Inquired of software development managers to ascertain production data, including customer content and AWS employee data, were not used in test or development environments.	No deviations noted.
		Inspected the contents of the Secure Software Development Policy intended for software development engineers and software development managers throughout AWS to ascertain it provided instructions to not use production data in test or development environments.	No deviations noted.
AWSCA-7.1: S3-Specific – S3 compares checksums to validate the integrity of data in transit. If the customer provided or automatically calculated checksum does not match the S3's server-side checksum validation, the upload will fail, preventing corrupted data from being written to S3. Control responsible: AWS Inc.	CC6.7	Inquired of an S3 Software Development Manager to ascertain S3 compared checksums to validate the integrity of data in transit. If the customer provided or automatically calculated checksum did not match the S3's server-side checksum validation, the upload would fail, preventing corrupted data from being written to S3.	No deviations noted.
		Inspected the checksum configurations to ascertain S3 was configured to continually compare the user provided or automatically calculated checksums with the S3's server-side checksums to validate the integrity of data in transit.	No deviations noted.
		Observed an S3 Software Development Engineer upload a file with an invalid checksum to ascertain the transfer was aborted and an error message was displayed.	No deviations noted.
		Observed an S3 Software Development Engineer upload a file with a valid checksum that matched the S3 calculated checksum to ascertain the transfer was completed successfully.	No deviations noted.
AWSCA-7.2: S3-Specific – S3 performs continuous integrity checks of the data at rest. Objects are continuously	C1.1	Inquired of an S3 Software Development Engineer to ascertain S3 performed continuous integrity checks of the data at rest and that objects were automatically validated against their checksums to prevent object corruption.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
validated against their checksums to prevent object corruption. Control responsible: AWS Inc.		Inspected the integrity checks configurations to determine S3 was configured to continually perform integrity checks of the data at rest and validated against their checksums.	No deviations noted.
		Observed an S3 Software Development Engineer locate an object whose checksum was not validated against its object locator to ascertain the object was automatically detected by the S3 service to prevent object corruption.	No deviations noted
		Inspected system log files for an object at rest to ascertain checksums were utilized to assess the continuous integrity checks of data.	No deviations noted.
		Inspected the S3 logs to ascertain S3 was designed to automatically attempt to restore normal levels of object storage redundancy when disk corruption or device failure was detected.	No deviations noted.
AWSCA-7.3: S3-Specific – When disk corruption or device failure is detected, the system automatically attempts to restore normal levels of object storage redundancy. Control responsible: AWS Inc.	A1.2; C1.1	Inquired of an S3 Software Development Engineer to ascertain when disk corruption or device failure was detected, the system automatically attempted to restore normal levels of object storage redundancy.	No deviations noted.
		Inspected the system repair configurations to ascertain S3 was configured to automatically attempt to restore object storage redundancy when disk corruption or device failure was detected.	No deviations noted
		Inspected the S3 logs to ascertain S3 was designed to automatically attempt to restore normal levels of object storage redundancy when disk corruption or device failure was detected.	No deviations noted
		Observed an S3 Software Development Engineer locate an object that was corrupted or suffered device failure to ascertain the object was rewritten to a known location, which restored normal levels of object storage redundancy.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-7.4: S3-Specific – Objects are stored redundantly across multiple fault-isolated facilities. Control responsible: AWS Inc.	A1.2; C1.1	Inquired of an S3 Software Development Engineer to ascertain objects were stored redundantly across multiple fault-isolated facilities.	No deviations noted.
		Inspected the object sharding configurations to ascertain objects were stored redundantly across multiple fault-isolated facilities.	No deviations noted.
		Uploaded an object and observed an S3 Software Development Engineer access the object location configuration to ascertain the object was stored redundantly across multiple fault-isolated facilities.	No deviations noted.
AWSCA-7.5: S3-Specific – The design of systems is sufficiently redundant to sustain the loss of a data center facility without interruption to the service. Control responsible: AWS Inc.	A1.2; C1.1	Inquired of an S3 Software Development Engineer to ascertain systems were designed to sustain the loss of a data center facility without interruption to the service.	No deviations noted.
		Inspected the system configuration utilized by S3 on stored objects to ascertain critical services were designed to sustain the loss of a facility without interruption to the service.	No deviations noted.
AWSCA-7.6: RDS-Specific – If enabled by the customer, RDS backs up customer databases, stores backups for user-defined retention periods, and supports point-in-time recovery. Control responsible: AWS Inc.	A1.2; C1.1	Inquired of an RDS Software Development Manager to ascertain, if enabled by the customer, RDS backed up customer databases, stored backups for user-defined retention periods, and supported point-in-time recovery.	No deviations noted.
		Inspected the RDS backup configurations to ascertain, if enabled by the customer, RDS backed up customer database and stored backups for user-defined retention periods.	No deviations noted.
		Independently created an RDS database, enabled backups and backed up the database to ascertain RDS backed up customer databases via scheduled backups according to a user-defined retention period.	No deviations noted.
		Independently created an RDS database, captured a point in time database snapshot and restored the RDS database using the captured snapshot to ascertain RDS	No deviations noted

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		databases were capable of a point-in-time recovery using database snapshots.	
		Independently restored an RDS database using a database backup to ascertain RDS databases were capable of a point-in-time recovery.	No deviations noted.
AWSCA-7.7: AWS provides customers the ability to delete their content. Once successfully removed the data is rendered unreadable. Control responsible: AWS Inc.	CC6.5; C1.2	Inquired of an EC2 Principal Engineer to ascertain AWS provided customers the ability to delete their content and render it unreadable.	No deviations noted.
		Observed an EC2 Security Engineer create a virtual host, upload content, delete the underlying storage volume, then create a different instance within the same virtual memory slot and query for the original content to ascertain that the underlying storage volume and in memory data was removed.	No deviations noted.
		For one service that provides content storage as described in the System Description, inspected the configurations designed to automatically delete content from buckets, volumes, instances, or other means of content storage to ascertain it was designed to delete and render the data unreadable.	No deviations noted.
		For one service that provides content storage as described in the System Description, independently created an AWS cloud account registered to an independent email address and created sample content into buckets, volumes, instances, or other means of content storage, and compared the time stamp of creation with the current date and time. Observed Software Development Managers query for the objects to ascertain the objects existed and were in an active state.	No deviations noted.
		For one core storage service that provides content storage as described in the System Description, created an AWS cloud account registered to an independent email address and created sample content into buckets, volumes, instances, or other means of content storage, and compared the time	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		stamp of creation with the current date and time. Observed Software Development Managers query the backend to ascertain the objects existed and were in an active state.	
		For one service that provides content storage as described in the System Description, deleted the content and/or the underlying buckets, volumes, instances, or other means of content storage, and inspected if the data identifiers were removed or the data itself was zeroed out after being deleted to ascertain it was rendered unreadable.	No deviations noted.
		For one core storage service that provide content storage as described in the System Description, observed Software Development Managers query for the objects metadata for the deleted objects to ascertain that an error was returned stating the object could not be found.	No deviations noted.
AWSCA-7.8: AWS retains customer content per customer agreements. Control responsible: AWS Inc.	CC6.5; C1.1	Inquired of an IAM Software Dev II to ascertain AWS retained customer content per the customer agreements.	No deviations noted.
		Inspected the most recent copy of the AWS Customer Agreement to ascertain it was communicated externally to customers and contained an effective date, which was the most recent version of the agreement.	No deviations noted.
		Inspected the AWS Customer Agreement and the AWS European Sovereign Cloud Addendum to ascertain the contractual language in section 14 stated that AWS European Sovereign Cloud will not delete customer information for up to 90 days in the event of AWS account termination, and that the language explicitly stated the customer agreed to the responsibilities regarding confidential information disposal.	No deviations noted.
		Inspected the customer account content retention configuration to ascertain a centralized account service was designed to send notifications to services to delete customer content 90 days after account closure.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		For one AES integrated service that stores customer content integrated with the centralized account service, created a unit of content storage, closed the AWS account and inspected the content throughout the 90- day lifecycle to ascertain customer content was retained until deleted 90 days after customer account closure.	No deviations noted.
AWSCA-7.10: EC2-Specific - Amazon EC2 enables clock synchronization based on Network Time Protocol in EC2 Linux instances, to achieve accuracy within 1 millisecond of Coordinated Universal Time. Control responsible: AWS Inc.	CC7.1	Inquired of an EC2 Software Development Manager to ascertain Amazon EC2 enabled clock synchronization based on Network Time Protocol in EC2 instances, to achieve accuracy within 1 millisecond of Coordinated Universal Time for non-supported instances and within 100 microseconds of Coordinated Universal Time for supported instances.	No deviations noted.
		Inspected the clock synchronization configurations to ascertain the different infrastructure layers were linked to ensure clock synchronization.	No deviations noted.
		Observed an EC2 Software Development Engineer create an EC2 instance and enable clock synchronization to ascertain that clock synchronization achieved an accuracy within 1 millisecond of Coordinated Universal Time for one non-supported instance and within 100 microseconds of Coordinated Universal Time for one supported instance.	No deviations noted.
		For one supported instance, inspected the AWS managed Grandmaster clock devices to ascertain that the Grandmaster devices were active, and that monitoring was enabled to ensure that an accuracy within 100 microseconds of Coordinated Universal Time.	No deviations noted
		For one in-scope AWS Availability Zone (AZ), inspected the AWS managed Grandmaster clock devices to ascertain that the Grandmaster devices were active, and that monitoring was enabled to ensure that an accuracy within 1 millisecond of Coordinated Universal Time was achieved.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-8.1: Monitoring and alarming are configured by Service Owners to identify and notify operational and management personnel of incidents when early warning thresholds are crossed on key operational metrics. Control responsible: AWS European Sovereign Cloud Entity	CC2.1 ; CC6.1 ; CC6.6 ; CC6.8 ; CC7.2 ; CC7.3 ; CC7.4 ; A1.1 ; A1.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain the production environment was monitored and that alarming was configured by Service Owners to notify operational and management personnel when early warning thresholds were crossed on key operational metrics.	No deviations noted.
		For one key operational metric, inspected the applicable configurations to ascertain related monitoring and alarming were in place to notify appropriate personnel when a threshold was reached or exceeded.	No deviations noted.
		Inspected the network monitoring tool configurations which are responsible for automatically generating tickets for Network Monitoring incidents to ascertain incidents were logged within a ticketing system, assigned severity rating and tracked to resolution.	No deviations noted.
AWSCA-8.2: Incidents are logged within a ticketing system, assigned a severity rating and tracked to resolution. Control responsible: AWS European Sovereign Cloud Entity	CC2.1 ; CC6.1 ; CC6.6 ; CC6.8 ; CC7.2 ; CC7.3 ; CC7.4 ; CC7.5 ; CC8.1 ; A1.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain security incidents were logged in a ticketing system, assigned a severity level, and tracked through resolution.	No deviations noted.
		For one incident resulting from a security alert, inspected associated entries in the ticketing system to ascertain incidents were assigned a severity level and tracked through to resolution.	No deviations noted.
AWSCA-8.3: System activities are logged, retained for a defined period of time, and protected from unauthorized modifications. Control responsible: AWS European Sovereign Cloud Entity	CC7.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that AWS used logical access controls to restrict access to logs and protect system logs from unauthorized modification and deletion, and that upon request of the cloud customer, customer-specific logging was offered and made available to the customer.	No deviations noted.
		Inspected the administrative configurations for the log aggregation tool to ascertain that service activity was centrally logged and retained in accordance with internal	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		documentation then deleted when further retention is no longer necessary.	
		Inspected the access permissions for the log aggregation tool to ascertain that service team users were unable to delete or modify log records, and access and management of the logging and monitoring functionalities required multi-factor authentication.	No deviations noted.
		For one in-scope service, inspected the log aggregation tool and cross-referenced the hostclass name to the selected service to ascertain that logging and monitoring of events was implemented.	No deviations noted.
AWSCA-9.1: AWS maintains internal informational websites describing the AWS environment, its boundaries, user responsibilities and services. Control responsible: AWS Inc.	CC2.2; CC2.3	Inquired of the AWS Security Assurance Technical Program Manager to ascertain AWS maintained internal informational websites describing the AWS environment, its boundaries, user responsibilities, and the services.	No deviations noted.
		Inspected AWS internal informational websites for one in-scope AWS service to ascertain they described the AWS environment, its boundaries, user responsibilities, and the services.	No deviations noted.
AWSCA-9.2: AWS conducts pre-employment screening of candidates commensurate with the employee's position and level, in accordance with local law and the AWS Personnel Security Policy. Control responsible: AWS Inc.	CC1.1; CC1.4	Inquired of the HR Specialist to ascertain AWS conducted pre-employment screening of full-time candidates prior to the employees' start dates in accordance with local laws.	No deviations noted.
		For one AWS European Sovereign Cloud full-time new hire, inspected pre-employment screening records to ascertain pre-employment screening was performed prior to each employee's start date.	No deviations noted.
AWSCA-9.3: AWS performs annual formal evaluation of resourcing and staffing including assessment of	CC1.1; CC1.4; CC1.5	Inquired of the Principal HR Business Partner to ascertain a process was in place to perform a formal evaluation of resourcing and staffing annually, including an assessment of employee qualifications alignment with entity objectives, and that	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
employee qualification alignment with entity objectives. Employees receive feedback on their strengths and growth ideas annually. Control responsible: AWS Inc.		employees received feedback on their strengths and growth opportunities.	
		For one of AWS European Sovereign Cloud employee, inspected performance evaluation records to ascertain the employee was formally evaluated against entity objectives during the most recent annual formal evaluation of resourcing and staffing.	We noted that the globally designed and implemented control was applicable to the AWS European Sovereign Cloud. However, since the implementation of the AWS European Sovereign Cloud and as of January 15, 2026, the control had not yet been executed for AWS European Sovereign Cloud-specific instances. Therefore, we performed the walkthrough based on the control execution within the global AWS environment and inspected evidence indicating that the control was planned to be executed for the AWS European Sovereign Cloud in an equivalent manner.
AWSCA-9.4: AWS host configuration settings are monitored to validate compliance with AWS security standards and to verify that settings are automatically	CC6.1; CC6.8; CC7.1; CC8.1	Inquired of a System Engineering Manager and Software Development Manager to ascertain AWS host configuration settings were monitored to validate compliance with AWS security standards and that settings were automatically deployed to the fleet.	No deviations noted.
		Inspected the monitoring configurations to ascertain production hosts were configured to monitor compliance with AWS security standards and to automatically request and	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
deployed to the host fleet. Control responsible: AWS Inc.		install host configuration setting updates deployed to the fleet.	
		Inspected the provisioning configurations to ascertain hosts could not be deployed into production environment without the successful installation of configuration management tools.	No deviations noted.
		For one production hosts for the in-scope AWS European Sovereign Cloud region, inspected the automated deployment logs to ascertain production hosts automatically requested and installed host configuration setting updates deployed to the fleet.	No deviations noted.
		Inspected the ticket details for one incident ticket created for a failed deployment attempt for each host deployment mechanism to ascertain the unsuccessful installation of host configuration settings was identified, tracked and resolved in a timely manner.	No deviations noted.
AWS-9.5: AWS provides publicly available mechanisms for customers to contact AWS to report security events and publishes information including a system description and security and compliance information addressing AWS commitments and responsibilities. Control responsible: AWS European Sovereign Cloud Entity	CC2.2; CC2.3	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain AWS provided publicly available mechanisms for customers to contact AWS European Sovereign Cloud Staff to report security events and published information including a system description and security and compliance information addressing AWS commitments and responsibilities for the AWS European Sovereign Cloud services.	No deviations noted.
		Inspected AWS informational websites to ascertain they provided publicly available mechanisms for customers to contact AWS European Sovereign Cloud Staff to report security events.	No deviations noted.
		Inspected the AWS whitepapers and public websites to ascertain they provided information including a system description and security and compliance information addressing AWS commitments and responsibilities for the AWS European Sovereign Cloud services.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH’s and Amazon
Web Services, Inc.’s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		Inspected a ticket resulting from a customer inquiry to ascertain a process is in place to address, track and resolve customer inquiries in a timely manner.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as no customer inquiries occurred since the control was designed and documented, and as of January 15, 2026. Therefore, the implementation of the control could not be evaluated.
		For one customer submitted compliance inquiry, inspected supporting documentation to ascertain that the inquiry was followed up on timely through email or phone call by a marketing representative.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as no customer inquiries occurred since the control was designed and documented, and as of January 15, 2026. Therefore, the implementation of the control could not be evaluated.
AWSCA-9.6: The Company provides a hotline for employees to anonymously report on possible violations of conduct. Control responsible: AWS Inc.	CC2.2; CC7.2; CC7.3; CC7.4; CC7.5	Inquired of a Vice President of Litigation Legal to ascertain the company provided a hotline for employees to anonymously report on possible violations of conduct.	No deviations noted.
		Inspected the Owner’s Manual and Guide to Employment policy to ascertain employees were provided access to the ethics hotline in all geographies during orientation.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		Called the fraud hotline number to ascertain it was available for employees to anonymously report on possible violations of conduct.	No deviations noted.
AWSCA-9.7: Material violations of the Company's Code of Business Conduct and Ethics and similar policies are appropriately handled in terms of communication and possible disciplinary action or termination. Violations involving third parties or contractors are reported to their respective employers which will carry out any possible disciplinary action, removal of assignment with Amazon, or termination. Control responsible: AWS Inc.	CC1.1; CC1.5; CC7.4; CC9.2	Inquired of a Principal of Corporate Employee Relations to ascertain material violations of the Company's Code of Business Conduct and Ethics and similar policies were appropriately handled in terms of communications and possible disciplinary action or termination, and violations involving third parties or contractors were reported to their respective employers which were responsible for any possible disciplinary action, removal of assignment with Amazon, or termination.	No deviations noted.
		Inspected the Code of Business Conduct and Ethics policy to ascertain that employee expectations were published on the intranet for employees to review and consequences for certain violations were documented within the policy.	No deviations noted.
		Inspected the Human Resources team investigation process wiki and Enterprise Case Management system to ascertain they detailed standard operating procedures for the handling of a potential material violation of the Company's Code of Business Conduct Ethics for both employees and vendors, including the handling of communication and possible disciplinary action.	No deviations noted.
AWSCA-9.8: AWS has established a formal audit program that includes continual, independent internal and external assessments to validate the implementation and operating effectiveness of the	CC1.2; CC2.1; CC3.1; CC4.1; CC4.2	Inquired of a Director of Internal Audit to ascertain AWS had established a formal audit program that included continual, independent internal and external assessments to validate the implementation and operating effectiveness of the AWS control environment.	No deviations noted.
		Inspected the audit framework and list of interviewees to ascertain AWS functional areas including AWS Security and AWS Service teams were covered within the Internal Audit Risk assessment creation.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWS control environment. Control responsible: AWS Inc.		Inspected the yearly audit plan created by Internal Audit and submitted to the Audit Committee to ascertain Internal Audit formalized and outlined their specific audit plan as a response of the risk assessment conducted, and that the audit plan contained the AWS organization.	No deviations noted.
AWSCA-9.9: AWS has a process to assess whether AWS employees who have access to resources that store or process customer data via permission groups are subject to a post-hire background check as applicable with local law and the AWS Personnel Security Policy. Control responsible: AWS Inc.	CC1.1 ; CC1.4	Inquired of an AWS Security Assurance Enablement Professional to ascertain employees with access to resources that store or process customer data via permission groups received a background check, as applicable with local law, no less than once per calendar year.	No deviations noted.
		For one AWS European Sovereign Cloud employee with access to resources that stored or processed customer data, inspected their background check status to ascertain background checks were completed once per calendar year or access to resources that stored or processed customer data was removed as appropriate.	No deviations noted.
AWSCA-10.1: Critical AWS system components are replicated across multiple Availability Zones and backups are maintained. Control responsible: AWS Inc.	A1.2	Inquired of Software Development Manager and AWS Code Services Sr. Software Development Engineer to ascertain critical AWS system components were replicated across multiple Availability Zones and that backups were maintained.	No deviations noted.
		Inspected the replication configurations to ascertain critical AWS system components were configured to be automatically replicated across multiple Availability Zones.	No deviations noted.
		Inspected the backup configurations to ascertain critical AWS system components were backed up as changes were deployed or in accordance with periodically configured jobs throughout the day.	No deviations noted.
		For one package of system component files, inspected the production environment replication and backup logs for the related AWS service to ascertain data was replicated and backed up across multiple Availability Zones.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-10.2: Backups of critical AWS system components are monitored for successful replication across multiple Availability Zones. Control responsible: AWS Inc.	A1.2 ; A1.3 ; C1.1	Inquired of an AWS Code Services Sr. Software Development Engineer to ascertain critical AWS system components were monitored for replication across multiple Availability Zones.	No deviations noted.
		Inspected the backup monitoring configuration to ascertain that error incident tickets were automatically generated in the event of backup failures.	No deviations noted.
		For one critical alarm, inspected monitoring dashboards and alarming configurations to ascertain an alarming mechanism existed to notify appropriate personnel of replication and backup successes and failures and when files were insufficiently replicated across multiple Availability Zones.	No deviations noted.
		Inspected notifications of when a backup did not complete and when files were insufficiently replicated across multiple Availability Zones to ascertain the service team initiated the remediation process and tracked the issues to resolution.	No deviations noted.
AWSCA-10.3: AWS contingency planning and incident response playbooks are maintained and updated to reflect emerging continuity risks and lessons learned from past incidents. The AWS contingency plan is tested on at least an annual basis. Control responsible: AWS Inc.	CC2.2 ; CC3.2 ; CC3.3 ; CC3.4 ; CC5.3 ; CC7.3 ; CC7.4 ; CC7.5 ; CC8.1 ; CC9.1 ; A1.1 ; A1.2 ; A1.3	Inquired of an AWS Security Business Continuity Manager to ascertain AWS maintained an overall contingency planning procedure that reflected emerging continuity risks and incorporated lessons learned from past incidents, and that the AWS contingency plan was tested on at least an annual basis.	No deviations noted.
		Inquired of AWS Security Business Continuity Manager to ascertain AWS contingency planning and incident response playbooks, specific to each service team were maintained and updated to reflect emerging continuity risks and lessons learned from past incidents.	No deviations noted.
		Inspected the AWS contingency plan documentation to ascertain it was reviewed and approved at least annually, and that playbooks for each service existed, were maintained, and updated to reflect emerging continuity risks and lessons learned from past incidents.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		For one recent AWS contingency plan test, inspected the ticket to ascertain the contingency plan was tested within the past year, and that drills conducted to imitate incidents were resolved and service availability was restored.	No deviations noted.
AWSCA-10.4: AWS maintains a capacity planning model to assess infrastructure usage and demands at least monthly, and usually more frequently (e.g., weekly). In addition, the AWS capacity planning model supports the planning of future demands to acquire and implement additional resources based upon current resources and forecasted requirements. Control responsible: AWS Inc.	A1.1; A1.2	Inquired of a Senior Tech Infrastructure Program Manager to ascertain AWS maintained a centralized capacity planning model that assessed infrastructure usage, forecasted demand, and additional resources required to meet the availability requirements.	No deviations noted.
		For the in-scope region, inspected the capacity planning model to ascertain capacity was assessed per the defined cadence, and the model contained forecasting for future demands and resource availability.	No deviations noted.
AWSCA-11.1: Vendors and third parties with restricted access, that engage in business with Amazon are subject to confidentiality commitments as part of their agreements with Amazon. Confidentiality commitments included in agreements with vendors and third parties with restricted access are	CC1.1; CC1.4; CC2.2; CC2.3; CC9.2	Inquired of AWS Corporate Counsel to ascertain vendors or third parties with restricted access, that engage in business with AWS, were subject to confidentiality agreements as part of their agreements with AWS and that these agreements were reviewed by AWS and the third party at the time of contract creation or execution.	No deviations noted.
		For one external vendor or third party with restricted access who engaged in business with AWS, inspected the vendor agreement to ascertain the agreement contained confidentiality commitments.	No deviations noted.
		For one external vendor or third party with restricted access who engaged in business with AWS, inspected the vendor agreement	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
reviewed by AWS and the third party at time of contract creation or execution. Control responsible: AWS Inc.		to ascertain the agreement was signed and approved by the vendor and AWS.	
AWSCA-11.2: AWS has a program in place for evaluating vendor performance and compliance with contractual obligations. Control responsible: AWS Inc.	CC1.1; CC1.4; CC2.3; CC4.1; CC9.2	Inquired of the Data Center Global Services team to ascertain AWS has a program in place for evaluating vendor performance and compliance with contractual obligations.	No deviations noted.
		Inspected the AWS evaluation program calendars for vendor performance and compliance with contractual obligations to ascertain reviews for vendors with restricted access were scheduled on a frequency subject to the overall risk of doing business with each vendor.	No deviations noted.
		For one vendor, inspected the vendor evaluation of performance and compliance with contractual obligations to ascertain a review was performed in accordance with policy and served as means for evaluation of vendor performance with contractual obligations, based on risk.	No deviations noted.
AWSCA-11.3: Changes to standard confidentiality commitments to customers are communicated on the AWS website via the AWS customer agreement. Control responsible: AWS Inc.	CC2.2; CC2.3; CC9.2	Inquired of an AWS Security Assurance Technical Program Manager to ascertain that changes to standard confidentiality commitments to customers were communicated on the AWS website via the AWS customer agreement.	No deviations noted.
		Inspected the public-facing AWS Customer Agreement located on the AWS website to ascertain changes to standard confidentiality commitments were communicated via the AWS Customer Agreement and made publicly available via an embedded change log.	No deviations noted.
AWSCA-12.1: AWS informs customers of the AWS Data security and privacy commitments within the AWS Customer Agreement prior to	CC2.3	Inquired of an AWS Corporate Counsel to ascertain AWS informed customers of the AWS Data security and privacy commitments within the AWS Customer Agreement prior to activating an AWS account and made it available to customers to review any time on the AWS website.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
activating an AWS account and makes it available to customers to review at any time on the AWS website. Control responsible: AWS Inc.		Attempted to create an AWS account without acknowledging the AWS Customer Agreement and observed the system prevented proceeding any further with opening the account.	No deviations noted.
		Acknowledged the AWS Customer Agreement and successfully created an AWS account to ascertain that acknowledgement of the AWS Customer Agreement was required prior to opening an AWS account.	No deviations noted.
		Inspected the AWS Customer Agreement on the AWS website to ascertain that the AWS Customer Agreement is publicly available for customers to review and informed customers of AWS data security and privacy commitments.	No deviations noted.
AWSCA-12.2: AWS informs customers of changes made to the AWS Customer Agreement via the AWS public website. Control responsible: AWS Inc.	CC2.3	Inquired of an AWS Corporate Counsel to ascertain AWS informed customers of changes made to the AWS Customer Agreement via the AWS public website.	No deviations noted.
		Inspected the AWS Customer Agreement via the AWS website to ascertain that the last update date was displayed to customers.	No deviations noted.
		Inspected the AWS Customer Agreement to ascertain that it contained a commitment from management to make available to customers any changes made to the AWS Customer Agreement.	No deviations noted.
AWSCA-12.3: AWS offers customers the capability to update communication preferences via the AWS console. Control responsible: AWS Inc.	CC.2.3	Inquired of a Senior Digital Marketing Leader to ascertain that Amazon offered customers the capability to update their communication preferences via the AWS console.	No deviations noted.
		Observed a Senior Digital Marketing Leader update communication preferences for an AWS account via the AWS console; inspected the update in the back-end repository and inspected the confirmation notification to ascertain that Amazon provided customers the capability to manage communication preferences via the AWS console.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWSCA-12.4: AWS performs application security reviews for Third-Party systems that collect customer content in accordance with team processes, to ascertain security risks are identified and mitigated. Control responsible: AWS Inc.	CC2.3; CC8.1; CC9.2	Inquired of an AWS Security Manager to ascertain that AWS performed application security reviews for third-party systems that collect customer content in accordance with team processes to ascertain security risks were identified and mitigated.	No deviations noted.
		Inspected team documentation of external party onboarding for providers of third-party systems that collected customer content to ascertain that external parties were assessed for the collection of customer content and referred for additional security reviews.	No deviations noted.
		For one third-party system that collected customer content, inspected management's completed application security review tickets to ascertain that the system was assessed prior to launch to evaluate whether security risks were identified and mitigated.	No deviations noted.
AWSCA-12.5: AWS notifies affected data subjects and regulators of breaches and incidents as legally required in accordance with team processes. Control responsible: AWS Inc.	CC2.3; CC7.3; CC7.4	Inquired of Corporate Counsel to ascertain that AWS notified affected data subjects and regulators of breaches and incidents as legally required in accordance with team processes.	No deviations noted.
		Inspected the AWS Internal Privacy Policy to ascertain that AWS notified affected data subjects and regulators of breaches and incidents as legally required in accordance with team processes.	No deviations noted.
		Inspected the AWS internal Wiki Page to ascertain that AWS Security Operations should be engaged for security incidents above Sev 2.	No deviations noted.
		Inspected the Personal Health Dashboard of AWS account to ascertain that privacy events affecting AWS resources were listed.	No deviations noted.
		Inspected incident response details for one security alert incident ticket to ascertain if evaluations were conducted to determine if disclosures were required to be made to affected data subjects and regulators of breaches, and if required disclosures were appropriately made according to incident response documentation.	We noted that the globally designed and implemented control was applicable to the AWS European Sovereign Cloud. However, since the

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
			implementation of the AWS European Sovereign Cloud and as of January 15, 2026, the control had not yet been executed for AWS European Sovereign Cloud-specific instances. Therefore, we performed the walkthrough based on the control execution within the global AWS environment and inspected evidence indicating that the control was planned to be executed for the AWS European Sovereign Cloud in an equivalent manner.
AWSCA-12.6: AWS provides authenticated customers the ability to access, update, and confirm their data. Denial of access will be communicated using the AWS console. Control responsible: AWS Inc.	CC6.1 ; CC7.4	Inquired of Corporate Counsel to ascertain that AWS provided authenticated customers the ability to access, update, and confirm their data. Additionally, inquired of Corporate Counsel to ascertain what conditions would trigger a denial of access and that a denial of access would be communicated using the AWS console.	No deviations noted.
		Inspected the AWS Customer Agreement to ascertain that AWS committed to notifying customers prior to denial of access.	No deviations noted.
		Updated personal account information in the AWS Console to ascertain that AWS provided authenticated customers the ability to access, update, and confirm their data.	No deviations noted.
AWSCA-12.7: AWS records customer information requests to maintain a complete, accurate,	CC6.1 ; CC7.4	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that AWS European Sovereign Cloud recorded customer information requests to maintain a complete, accurate, and timely record of such requests.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
and timely record of such requests. Control responsible: AWS European Sovereign Cloud Entity		Inspected the Amazon Case Tracker Dashboard case listing for the recording of customer information requests through the Amazon Law Enforcement Request Tracker system to ascertain that AWS European Sovereign Cloud recorded customer information requests to maintain a complete, accurate, and timely record of such requests.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as no customer information request occurred since the control was designed and documented, and as of January 15, 2026. Therefore, the implementation of the control could not be evaluated.
		Observed the repository of AWS European Sovereign Cloud customer information requests to ascertain that AWS European Sovereign Cloud recorded customer information requests.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as no customer information request occurred since the control was designed and documented, and as of January 15, 2026. Therefore, the implementation of the control could not be evaluated.
AWSCA-12.8: Unless prohibited from doing so or there is a clear indication of illegal conduct in connection with the use of AWS products or services, AWS	CC2.3; CC7.3	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that AWS European Sovereign Cloud made a reasonable attempt to notify customers before disclosing Customer Content in response to valid/binding law enforcement requests unless legally prohibited from doing so.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
makes a reasonable attempt to notify customers before disclosing Customer Content in response to valid/binding law enforcement requests. Control responsible: AWS European Sovereign Cloud Entity		Inspected the Amazon Law Enforcement Guidelines public policy to ascertain that AWS European Sovereign Cloud did not disclose customer information in response to government demands unless AWS was legally required by a binding order. In such cases, the policy guided AWS European Sovereign Cloud Staff to notify customers before disclosure, unless legally prohibited from doing so.	No deviations noted.
		For one Customer Content disclosure in response to a binding law enforcement request, inspected an email notification sent from AWS Legal to an AWS European Sovereign Cloud customer to ascertain that AWS European Sovereign Cloud notified the customer before disclosure of customer content.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as no law enforcement request occurred since the control was designed and documented, and as of January 15, 2026. Therefore, the implementation of the control could not be evaluated.
AWSCA-12.9: AWS maintains contracts with third party sub-processors that contain data protection, confidentiality commitments, and security requirements. Control responsible: AWS Inc.	CC3.2 ; CC4.1 ; CC9.2	Inquired of an AWS Senior Corporate Counsel to ascertain that AWS maintained contracts with third party sub-processors that contain data protection, confidentiality commitments, and security requirements.	No deviations noted.
		For one AWS European Sovereign Cloud third party sub-processor, inspected the contract to ascertain that it contained data protection, confidentiality commitments, and security requirements.	No deviations noted.
AWSCA-12.10: A formal review of third-party sub-processors is performed prior to	CC3.2 ; CC4.1 ; CC7.2 ; CC9.2	Inquired of an AWS Senior Corporate Counsel to ascertain that a formal review of third-party sub-processors was performed prior to AWS allowing any processing by third-party sub-processors.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
AWS allowing any processing by third-party sub-processors to determine that appropriate restrictions are in place to limit the third-party sub-processors' processing of customer content only to the customer content that is necessary to provide or maintain the AWS services selected by the customer. Control responsible: AWS Inc.		For one AWS European Sovereign Cloud third party sub-processor, inspected the application security review performed by the Application Vendor Security (AVS) team to ascertain that restrictions were reviewed prior to AWS European Sovereign Cloud allowing any processing by the third-party sub-processor to limit the processing of customer content by the third-party sub-processor only to the customer content necessary to provide or maintain the AWS European Sovereign Cloud services selected by the customer.	No deviations noted.
AWSCA-12.11: AWS conducts annual reassessments of third-party sub-processors, or after major incidents or significant changes. Control responsible: AWS Inc.	CC3.2 ; CC4.1 ; CC7.1 ; CC9.2	Inquired of an AWS Senior Corporate Counsel to ascertain that AWS had a process in place to conduct annual reassessments of third-party sub-processors, or after major incidents or significant changes.	No deviations noted.
		For one AWS European Sovereign Cloud third party sub-processor, inspected the application security review performed by the Application Vendor Security (AVS) team to ascertain that a reassessment of the third-party sub-processor was performed annually or following major incidents or significant changes.	No deviations noted.
AWSCA-12.12: The launch process for new third-party sub-processors requires addition to the externally posted list of third-party sub-processors that are currently engaged by AWS to process customer data depending on the AWS region and AWS	CC3.2 ; CC4.1 ; CC9.2	Inquired of AWS Senior Corporate Counsel to ascertain the launch process for new third-party sub-processors required addition to the publicly available list of third-party sub-processors engaged by AWS.	No deviations noted.
		Inspected the AWS Products Legal sub-processor page to ascertain that AWS notified customers when it engaged a third-party to process customer data.	No deviations noted.
		Inspected the launch playbook to ascertain that it included requirements on notifying the appropriate team and adding third-party sub-	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
service the customer selects. Control responsible: AWS Inc.		processors to the externally posted list of sub-processors for the public disclosure of the use of new third-party sub-processors prior to AWS allowing any processing by third-party sub-processors.	
AWSCA-20.1: AWS has established an independent advisory board for the AWS European Sovereign Cloud composed of at least four members, all EU citizens residing in the EU, including at least one independent board member who is not affiliated with Amazon. The advisory board acts as a source of expertise and advises the managing directors on maintaining the organizational and operational independence of the AWS European Sovereign Cloud. Control responsible: AWS European Sovereign Cloud Entity	CC1.1 ; CC1.2 ; CC1.3 ; CC1.5 ; CC4.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that an independent advisory board for the AWS European Sovereign Cloud consisting of at least four members and at least one independent board member (not affiliated with Amazon) was established. Further, ascertained that all advisory board members were EU citizens residing in the EU.	No deviations noted.
		Inspected organizational charts and supporting documentation to ascertain that the AWS European Sovereign Cloud independent advisory board was established and consisted of at least four board members and one independent board member (not affiliated with Amazon).	No deviations noted.
		Inspected supporting documentation to ascertain that all AWS European Sovereign Cloud independent advisory board members possessed sovereign-related expertise and were all EU citizens residing in the EU.	No deviations noted.
		Inspected the AWS European Sovereign Cloud independent advisory board meeting minutes to ascertain that the advisory board provided expertise and accountability on sovereignty-related aspects of the AWS European Sovereign Cloud.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as the AWS European Sovereign Cloud independent advisory board meeting did not occur since the control was designed and documented, and as of January 15, 2026. Therefore, the implementation of

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
			the control could not be evaluated.
AWSCA-20.2: AWS European Sovereign Cloud maintains dedicated, physically distinct infrastructure within the EU that is designed to operate independently of AWS infrastructure components or resources outside the defined geographical and logical boundaries. Control responsible: AWS European Sovereign Cloud Entity	CC3.4 ; CC6.4 ; CC6.5 ; A1.1 ; A.1.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that a dedicated, physically distinct infrastructure existed within the EU to operate independently of global AWS infrastructure components or resources outside of the defined geographical and logical boundaries.	No deviations noted.
		Inspected the AWS European Sovereign Cloud architectural diagrams and infrastructure documentation to ascertain that the AWS European Sovereign Cloud infrastructure was implemented on dedicated physical hardware independent of the global AWS infrastructure.	No deviations noted.
		Performed a walkthrough of the AWS European Sovereign Cloud facilities to ascertain that the physical infrastructure was dedicated and independent from the global AWS infrastructure. Further, ascertained that access controls and security measures were in place to maintain the independence.	No deviations noted.
AWSCA-20.3: AWS conducts business continuity exercises at least annually for the AWS European Sovereign Cloud to test the ability to maintain essential operation in the event of complete disconnection from the AWS Backbone Network. Control responsible: AWS European Sovereign Cloud Entity	CC3.4 ; CC5.3 ; CC7.4 ; CC7.5 ; A1.2 ; A1.3	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that business continuity exercises were conducted to test the ability to maintain essential operation in the event of complete disconnection from the global AWS Backbone network.	No deviations noted.
		Inspected the documentation of the last performed business continuity exercise to ascertain that the business continuity exercise was conducted as required, the scope and objectives were defined and the exercise included defined scenarios that reflect potential disruption events (i.e., the scenario of the complete disconnection from the global AWS Backbone network). Further, inspected post-exercise evaluations to ascertain that the outcomes of the business continuity exercise were addressed and	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		follow-up measures were defined, if applicable.	
AWSCA-20.4: AWS provides dedicated incident response capability within the AWS European Sovereign Cloud to detect, analyze, and respond to security threats and disruptive events. Incidents that may affect Customer Content or Customer-Created Metadata are handled by AWS European Sovereign Cloud Staff. Control responsible: AWS European Sovereign Cloud Entity	CC2.2 ; CC5.3 ; CC6.1 ; CC7.2 ; CC7.3 ; CC7.4 ; CC7.5 ; A1.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that a dedicated incident response capability existed within the AWS European Sovereign Cloud, the capability was specifically designed to detect, analyze, and respond to security threats and disruptive events, and incidents affecting Customer Content or Customer-Created metadata were managed by AWS European Sovereign Cloud Staff.	No deviations noted.
		Inspected the incident response plan to ascertain that procedures to detect, analyze and respond to security threats and disruptive events existed. Further, inspected supporting documentation to ascertain that AWS European Sovereign Cloud operated its own incident management tool instance.	No deviations noted.
		Inspected the allocated access rights within the dedicated AWS European Sovereign Cloud incident management tool instance to ascertain that only AWS European Sovereign Cloud Staff was granted access to handle incidents affecting AWS European Sovereign Customer Content or Customer-Created metadata.	No deviations noted.
		For one incident, inspected the documentation to ascertain that the incident was detected, analyzed and responded to according to the incident response plan. Further, ascertained that the incident was handled by dedicated AWS European Sovereign Cloud Staff.	No deviations noted.
AWSCA-20.5: AWS European Sovereign Cloud Staff maintain change control over deployments within the AWS European Sovereign Cloud.	CC6.1 ; CC6.8 ; CC7.5 ; CC8.1	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that AWS European Sovereign Cloud Staff had the control over globally developed changes deployed in the AWS European Sovereign Cloud through the capability to stop change deployment.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
Control responsible: AWS European Sovereign Cloud Entity		Inspected the AWS European Sovereign Cloud change control tool configuration to ascertain that all globally developed changes had to go through the dedicated change control tool prior to being deployed in the AWS European Sovereign Cloud and access was restricted to authorized AWS European Sovereign Cloud Staff.	No deviations noted.
		Inspected the AWS European Sovereign Cloud change control tool configuration to ascertain that AWS European Sovereign Cloud Staff had the capabilities to reject and stop globally developed changes deployed in the AWS European Sovereign Cloud.	No deviations noted.
AWSCA-20.6: The AWS European Sovereign Cloud maintains Customer Content and/or Customer-Created Metadata within the EU, except as instructed by customers or as necessary to comply with a valid and binding order of a governmental body. The AWS European Sovereign Cloud implements technical controls and monitoring systems to enforce this requirement. Data transferred outside the EU must not contain Customer Content or Customer-Created Metadata, except as instructed by customers or as necessary to comply	CC2.1 ; CC6.1 ; CC6.6 ; CC7.2 ; CC7.3 ;	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that Customer Content and Customer-Created Metadata were maintained within the boundaries of the AWS European Sovereign Cloud, exceptions to this requirement only occurred based on customer instructions or to comply with valid and binding governmental orders, including the conditions under which data was transferred outside these boundaries, and technical controls and monitoring systems were in place to enforce these requirements.	No deviations noted.
		Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that service teams had to raise a request in order to be onboarded to the data transfer tool including the purpose for the transfer and the type of data to be transferred in accordance with the AWS European Sovereign Cloud Data Handling and Classification Standard before data transfer connections can be initiated. Further, ascertained that authorized AWS European Sovereign Cloud Staff had to review and approve of the request prior to the onboarding to the data transfer tool and any data transfers.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
with a valid and binding order of a governmental body. Control responsible: AWS European Sovereign Cloud Entity		Inspected the allocated access rights within the data transfer tool to ascertain that access rights to push data outside of the AWS European Sovereign Cloud region were only allocated to authorized AWS European Sovereign Cloud Staff.	No deviations noted.
		For one onboarding to the data transfer tool request, inspected the request to ascertain that authorized AWS European Sovereign Cloud Staff reviewed and approved of the request prior to the onboarding to the data transfer tool and any data transfers.	No deviations noted.
		Inspected monitoring configuration to ascertain that cross-partition network traffic was monitored and alerts were generated in case of suspicious events or violations with the data transfer process. Further, ascertained that alerts were investigated, resolved and follow-up measures were defined, if applicable.	No deviations noted.
		Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that weekly reviews of data transfers and monthly reviews of the transferred data patterns were performed to assess whether Customer Content or Customer-Created Metadata were transferred outside of the AWS European Sovereign Cloud region and to identify improvement opportunities.	No deviations noted.
		For one performed data transfer review, inspected the review documentation to ascertain that authorized AWS European Sovereign Cloud Staff performed a review of data transfers including an analysis of the transferred data based on the initial onboarding to the data transfer tool request and the AWS European Sovereign Cloud Data Handling and Classification Standard. Further, ascertained that follow-up measures were defined, if necessary.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		For one performed transferred data pattern review, inspected the review documentation to ascertain that authorized AWS European Sovereign Cloud Staff performed a review of the data patterns to assess the data transfer control effectiveness and identify potential improvement opportunities. Further, ascertained that follow-up measures were defined, if necessary.	No deviations noted.
AWSCA-20.7: AWS establishes and maintains data handling and classification standards specific to the AWS European Sovereign Cloud. Standards are reviewed and approved annually by authorized personnel. Control responsible: AWS European Sovereign Cloud Entity	CC2.2 ; CC5.3 ; C1.1 ; C1.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that a Data Handling and Classification Standard specific to the AWS European Sovereign Cloud was established.	No deviations noted.
		Inspected the AWS European Sovereign Cloud Data Handling and Classification Standard to ascertain that it included definitions of data classification, data handling procedures, and responsibilities for data management to enable a proper management of data within the AWS European Sovereign Cloud. Further, ascertained that the Data Handling and Classification Standard was reviewed and approved by authorized personnel.	No deviations noted.
		Inspected the classification of one data element transferred out of the AWS European Sovereign Cloud to ascertain that it was classified in accordance with the AWS European Sovereign Cloud Data Handling and Classification Standard.	No deviations noted.
AWSCA-20.8: AWS executes contractual agreements with AWS European Sovereign Cloud customers that define AWS's data residency commitments and obligations for protecting Customer Content. Unless customers specify otherwise, these	CC2.2 ; CC2.3 ; C1.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that contractual agreements between AWS European Sovereign Cloud and its customers clearly defined AWS European Sovereign Cloud's data residency commitments and obligations to protect Customer Content. Further, ascertained that unless specified otherwise by the customer, the contractual agreements established governing law within EU member states and set dispute resolution procedures through EU Member State courts, tribunals, or arbitration bodies.	No deviations noted.

term-token-gVpSULg1DjHDDoPBqQkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
contracts establish governing law within EU Member States and set dispute resolution procedures through EU Member State courts, tribunals, or arbitration bodies. Control responsible: AWS European Sovereign Cloud Entity		Inspected the AWS Customer Agreement and the AWS European Sovereign Cloud Addendum to ascertain that they included specific clauses addressing the AWS European Sovereign Cloud data residency commitments, obligations for protecting Customer Content, governing law, and dispute resolution procedures through EU Member State courts, tribunals or arbitration bodies, unless specified otherwise by the customer.	No deviations noted.
		Inspected the AWS Customer Agreement, the AWS European Sovereign Cloud Addendum and supporting documentation to ascertain that changes in the EU legislation were considered and contracts were adjusted, if needed.	No deviations noted.
AWSCA-20.9: AWS implements location-based access controls for administrative and privileged access to AWS European Sovereign Cloud production environments. Controls are designed to verify user geographic location at session start and throughout the duration of the session. Control responsible: AWS European Sovereign Cloud Entity	CC6.1 ; CC6.2 ; CC6.3 ; CC6.6 ; CC6.7 ; CC6.8 ; CC7.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that location-based access controls were implemented for administrative and privileged access to the AWS European Sovereign Cloud production environments. Further, ascertained that the controls were designed to verify user geographic location at session start and throughout the duration of the session.	No deviations noted.
		Inspected the location-based access control documentation to ascertain that it comprised of the requirements for verifying user geographic location, including the criteria for acceptable locations and the procedures for handling access requests from unauthorized locations.	No deviations noted.
		Inspected the authentication method used for access to the production systems of the AWS European Sovereign Cloud to ascertain that two-factor authentication, dedicated to the AWS European Sovereign Cloud, was required prior to obtaining access.	No deviations noted.
		Inspected the geographic compliance analytics system configuration for administrative and privileged sessions within	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		the AWS European Sovereign Cloud to ascertain that the configuration was set to validate that sessions were exclusively allowed from the EU. Further, ascertained that the validation occurred at the start of the session and throughout the duration of the session.	
		Inspected the session logs ingested into the geographic compliance analytics system for administrative and privileged sessions within the AWS European Sovereign Cloud to ascertain that location validation was performed at session start and throughout the duration of the session.	No deviations noted.
		Inspected the geographic compliance analytics system monitoring configuration to ascertain that alerts for unauthorized access attempts were monitored and alerts were generated based on defined thresholds. Further, ascertained that alerts were analyzed and follow-up measures were defined, if necessary.	No deviations noted.
AWSCA-20.10: AWS maintains residency and work authorization requirements for AWS European Sovereign Cloud Staff who operate and support the AWS European Sovereign Cloud. AWS European Sovereign Cloud Staff residency eligibility is verified before granting access privileges to the AWS European Sovereign Cloud. Temporary work authorization is re-validated no later than the last day of validity. AWS	CC1.1 ; CC1.3 ; CC1.4 ; CC1.5 ; CC4.2 ; CC6.1 ; CC6.2 ; CC6.3	Inquired of an AWS European Sovereign Compliance Program Manager to ascertain that EU residency and work authorization requirements were established for AWS European Sovereign Cloud Staff who operate and support the AWS European Sovereign Cloud.	No deviations noted.
		Inquired of an AWS European Sovereign Compliance Program Manager to ascertain that residency eligibility and work authorization of AWS European Sovereign Cloud Staff were verified upon hiring and granting access to the AWS European Sovereign Cloud. Further, ascertained that temporary work authorization was re-validated no later than the last day of validity and AWS European Sovereign Cloud Staff were required to notify AWS European Sovereign Cloud of any residency or work authorization status changes.	No deviations noted.
		Inspected the AWS European Sovereign Cloud Employment Agreement to ascertain that EU residency and work authorization	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
European Sovereign Cloud Staff are required to notify AWS of any residency status changes. Control responsible: AWS European Sovereign Cloud Entity		requirements were addressed. Further, ascertained that the Employment Agreement included requirements for AWS European Sovereign Cloud Staff to notify AWS European Sovereign Cloud of any residency or work authorization changes.	
		For one newly hired AWS European Sovereign Cloud Staff, inspected onboarding documentation to ascertain that a validation of the EU residency status and work authorization, the completion of the AWS European Sovereign Cloud-specific training and business justification was performed prior to granting access to the AWS European Sovereign Cloud.	No deviations noted.
		For one AWS European Sovereign Cloud Staff with an expiring temporary work authorization, inspected documentation to ascertain that the employee was notified about their expiring temporary work authorization and a re-validation was triggered.	No deviations noted.
AWSCA-20.11: AWS maintains a replica of source code required to operate AWS European Sovereign Cloud services within the AWS European Sovereign Cloud. The replica is protected with encryption and integrity controls, and updated through a controlled replication process from authoritative sources. Control responsible: AWS European Sovereign Cloud Entity	CC3.4; A1.1; A1.2	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that AWS European Sovereign Cloud maintained a replica of the source code required to operate the AWS European Sovereign Cloud services, the replica was protected with encryption and integrity controls, and the source code was updated through a controlled replication process from authoritative sources.	No deviations noted.
		Inspected the configuration of the source code replication mechanism to ascertain that source code required to operate services within the AWS European Sovereign Cloud was automatically replicated from the authorized source code control management system.	No deviations noted.
		Inspected the encryption and integrity measures implemented for the source code replica of AWS European Sovereign Cloud to ascertain that replicas were encrypted in-	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		transit and at-rest, and the integrity of these replicas was validated.	
		Inspected the AWS European Sovereign Cloud source code storage to ascertain that source code replicas were stored daily and retained accordingly in a dedicated secure bucket. Further, ascertained that the access to the source code storage was restricted to authorized AWS European Sovereign Cloud Staff.	No deviations noted.
		Inspected monitoring configuration of the source code replication mechanism to ascertain that the daily source code replication job was monitored, failed source code replication alerts were generated, and the generated alerts were resolved and followed up.	No deviations noted.
AWSA-20.12: Unescorted physical access to Key Data Center Areas within the AWS European Sovereign Cloud is restricted to AWS European Sovereign Cloud Staff and Approved Vendor Personnel. AWS maintains physical security controls designed to prevent unauthorized access to infrastructure containing Customer Content and/or Customer-Created Metadata. Control responsible: AWS European Sovereign Cloud Entity	CC6.4 ; CC6.5 ; CC6.7	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and AWS European Sovereign Cloud Data Center Operations Manager to ascertain that physical access to critical data center areas within the AWS European Sovereign Cloud was restricted to authorized AWS European Sovereign Cloud Staff and Approved Vendor Personnel. Further, ascertained that AWS European Sovereign Cloud maintained physical access controls to prevent unauthorized access to infrastructure containing Customer Content and/or Customer-Created Metadata.	No deviations noted.
		Inspected access logs and records for critical data center areas within the AWS European Sovereign Cloud to ascertain that only authorized AWS European Sovereign Cloud Staff and Approved Vendor Personnel were granted access to AWS European Sovereign Cloud infrastructure containing Customer Content and/or Customer-Created Metadata.	No deviations noted.
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud observed on-premise that physical security controls were implemented to prevent unauthorized access to AWS	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf
SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		European Sovereign Cloud infrastructure containing Customer Content and/or Customer-Created Metadata.	
		For one in-scope Amazon-owned and one in-scope data center managed by colocation service provider of the AWS European Sovereign Cloud, observed on-premise that visitors were escorted by authorized AWS European Sovereign Cloud Staff at all times.	No deviations noted.
AWSCA-20.13: Requests of a governmental body that pertain to Customer Content and/or Customer-Created Metadata in the AWS European Sovereign Cloud are reviewed by AWS European Sovereign Cloud Staff to assess legal validity, identify and challenge requests that conflict with applicable EU or Member State law or are otherwise overbroad or inappropriate, and handle customer notification, where legally permitted. Control responsible: AWS European Sovereign Cloud Entity	CC2.3 ; CC7.3	Inquired of an AWS European Sovereign Cloud Compliance Program Manager to ascertain that requests from governmental bodies pertaining to AWS European Sovereign Cloud Customer Content and/or Customer-Created Metadata were assessed by AWS European Sovereign Cloud Staff, the assessment process included assessing the legal validity of the requests, and AWS European Sovereign Cloud Staff were obligated to identify and challenge requests that conflict with applicable European Union or Member State law or were otherwise overbroad or inappropriate.	No deviations noted.
		Inspected the AWS Law Enforcement Process for handling governmental requests within the AWS European Sovereign Cloud to ascertain that they outlined the steps for assessing legal validity, identifying and challenging conflicts with applicable EU or Member State laws, and managing customer notifications where legally permitted.	No deviations noted.
		For one governmental request, inspected records received by AWS European Sovereign Cloud to ascertain that requests were assessed regarding the legal validity, identification and challenge of requests that conflict with applicable EU or Member State Law or were otherwise overbroad or inappropriate.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as no government request occurred since the control was designed and documented, and as of January 15, 2026. Therefore, the

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
			implementation of the control could not be evaluated.
		For one governmental request, inspected customer notification records to ascertain that customers were timely notified of governmental requests affecting their content, if legally permitted.	We inspected the design of the control based on available documentation. However, we noted that the control had not yet been executed as no government request occurred since the control was designed and documented, and as of January 15, 2026. Therefore, the implementation of the control could not be evaluated.
AWSCA-20.14: The AWS European Sovereign Cloud operates its own root of trust that autonomously controls and operates its CA key materials. Control responsible: AWS European Sovereign Cloud Entity	CC6.1 ; CC6.4 ; CC6.6 ; CC8.1	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that AWS European Sovereign Cloud operated its own root of trust and autonomously controlled and operated its CA root key materials.	No deviations noted.
		Inspected CA root key operation procedures to ascertain that they included details on the root key lifecycle including generation, storage, distribution, provisioning, rotation, handling of compromised keys, revocation, and deletion.	No deviations noted.
		For one CA root key, inspected root key records and root key ceremony documentation to ascertain that the root key was generated in accordance with the root key process.	No deviations noted.
		For one CA root key, inspected access restriction evidence to the storage rooms of the root key to ascertain that the root key was generated and stored within EU borders, and that access to the root key was managed	No deviations noted.

term-token-gVpSULg1DjHDDoPBqOkCRplf

SECTION IV – Description of SOC 2 Criteria, AWS European Sovereign Cloud GmbH's and Amazon
Web Services, Inc.'s Controls, Procedures and Results of Procedures

Controls Specified by AWS	Criteria	Procedures Performed by EY	Results of Procedures
		by authorized AWS European Sovereign Cloud Staff.	
AWSCA-20.15: The AWS European Sovereign Cloud performs bi-annual governance reviews to ensure data transfer monitoring controls remain effective. Significant changes requiring control adjustments are systematically identified and validations confirm that transfers are appropriate and accurate. Control responsible: AWS European Sovereign Cloud Entity	CC2.1 ; CC6.1 ; CC6.6 ; CC7.2 ; CC7.3	Inquired of an AWS European Sovereign Cloud Compliance Program Manager and inspected related documentation to ascertain that bi-annual governance reviews of the data transfer connections were performed to assess the effectiveness of the transfers controls.	No deviations noted.
		For the performed governance review, inspected review documentation to ascertain that data transfer connections were reviewed to confirm their appropriateness and accuracy.	We noted that at launch of the AWS European Sovereign Cloud an initial review was performed to identify any data transfer connections older than 6 months to re-validate that they were still required and approved. The next review of all data transfer connections is scheduled in accordance with the control frequency.



SECTION V – Additional Information Provided by AWS European Sovereign Cloud GmbH

**Additional information on control non-occurrences**

AWS acknowledges that certain controls described in Section IV, also referred to in Section I and II, have not yet occurred operationally as of January 15th, 2026. AWS acknowledges and confirms that these controls were designed and implemented by January 15, 2026, but have not been fully executed in practice as of January 15, 2026. For example, control AWSCA-20.1, AWS European Sovereign Cloud Entity has established an independent advisory board for the AWS European Sovereign Cloud. The advisory board consists of at least four members, all EU citizens residing in the EU, including at least one independent board member who is not affiliated with Amazon. The advisory board acts as a source of expertise and provides accountability on sovereignty-related aspects of the AWS European Sovereign Cloud operations (visit <https://aws.eu/governance/> for more information). However, the board's first meeting had not taken place by January 15, 2026.

APPENDIX

Appendix I – Glossary of Terms

AWS European Sovereign Cloud: The dedicated cloud in the EU, including the infrastructure and Services that AWS makes available to customers through AWS European Sovereign Cloud Regions.

AWS European Sovereign Cloud Staff: Persons that are (a) employed by an AWS entity registered in the EU, and (b) EU residents or EU citizens, and in each case located in the EU when performing their role.

Approved Vendor Personnel: A vendor/contractor personnel who provide services to AWS in connection with the AWS European Sovereign Cloud that may require physical or systems access, for whom the vendor has provided attestation that such personnel meet EU residency requirements, and who have been approved through AWS's vetting process.

AWS Backbone Network: means AWS's private global network infrastructure that interconnects AWS Regions and edge locations worldwide.

Advisory Board: means the advisory board of AWS European Sovereign Cloud GmbH that is staffed with EU citizens residing in the EU.

Customer-Created Metadata: A metadata that Customer creates to manage and configure AWS resources, including the roles, permissions, resource labels, and configurations Customer uses to run AWS. For example, Customer-Created Metadata includes customer-supplied tags, resource identifiers, system configurations, and AWS Identity and Access Management policies.

EU: The European Union.

Key Data Center Areas: are secured rooms in an AWS European Sovereign Cloud data center that contain hardware processing Customer Content and/or Customer-Created Metadata.

AMI: An Amazon Machine Image (AMI) is an encrypted machine image stored in Amazon S3. It contains all the information necessary to boot instances of a customer's software.

API: Application Programming Interface (API) is an interface in computer science that defines the ways by which an application program may request services from libraries and/or operating systems.

Authentication: Authentication is the process of determining whether someone or something is, in fact, who or what it is declared to be.

Availability Zone: Amazon EC2 locations are composed of regions and Availability Zones. Availability Zones are distinct locations that are engineered to be insulated from failures in other Availability Zones and provide inexpensive, low latency network connectivity to other Availability Zones in the same region.

Bucket: A container for objects stored in Amazon S3. Every object is contained within a bucket. More information can be found in <https://docs.aws.amazon.com/AmazonS3/latest/dev/Introduction.html#BasicsBucket>

AWS Content: "AWS Content" means Content we or any of our affiliates make available in connection with the Services or on the AWS Site to allow access to and use of the Services, including APIs; WSDLs; Documentation; sample code; software libraries; command line tools;

roofs of concept; templates; and other related technology (including any of the foregoing that are provided by our personnel). AWS Content does not include the Services or Third-Party Content.

Customer Content: Defined as “Your Content” in <https://aws.amazon.com/agreement/> and <https://aws.eu/esca/>.

HMAC: In cryptography, a keyed-Hash Message Authentication Code (HMAC or KMAC), is a type of message authentication code (MAC) calculated using a specific algorithm involving a cryptographic hash function in combination with a secret key. As with any MAC, it may be used to simultaneously verify both the data integrity and the authenticity of a message. Any iterative cryptographic hash function, such as MD5 or SHA-1, may be used in the calculation of an HMAC; the resulting MAC algorithm is termed HMAC-MD5 or HMAC-SHA1, accordingly. The cryptographic strength of the HMAC depends upon the cryptographic strength of the underlying hash function, on the size and quality of the key and the size of the hash output length in bits.

Personal Information: Personal information that AWS collects in the course of providing AWS’ offerings include:

- **Information You Give Us:** We collect any information you provide in relation to AWS Offerings. Click [here](#) to see examples of information you give us.
- **Automatic Information:** We automatically collect certain types of information when you interact with AWS Offerings. Click [here](#) to see examples of information we collect automatically.
- **Information from Other Sources:** We might collect information about you from other sources, including service providers, partners, and publicly available sources. Click [here](#) to see examples of information we collect from other sources.

Hypervisor: A hypervisor, also called Virtual Machine Monitor (VMM), is computer software/hardware virtualization software that allows multiple operating systems to run on a host computer concurrently.

IP Address: An Internet Protocol (IP) address is a numerical label that is assigned to devices participating in a computer network utilizing the Internet Protocol for communication between its nodes.

IP Spoofing: Creation of Internet Protocol (IP) packets with a forged source IP address, called spoofing, with the purpose of concealing the identity of the sender or impersonating another computing system.

MD5 checksums: In cryptography, MD5 (Message-Digest algorithm 5) is a widely used cryptographic hash function with a 128-bit hash value. As an Internet standard (RFC 1321), MD5 has been employed in a wide variety of security applications and is also commonly used to check the integrity of files.

Object: The fundamental entities stored in Amazon S3. Objects consist of object data and metadata. The data portion is opaque to Amazon S3. The metadata is a set of name-value pairs that describe the object. These include some default metadata such as the date last modified and standard HTTP metadata such as Content-Type. The developer can also specify custom metadata at the time the Object is stored.

Port Scanning: A port scan is a series of messages sent by someone attempting to break into a computer to learn which computer network services, each associated with a “well-known” port number, the computer provides.

Privacy Policy: “Privacy Policy” means the privacy policy located at <https://aws.amazon.com/privacy/> (and any successor or related locations designated by us), as it may be updated by AWS from time to time.

User entity: The entities that use the services of a service organization during some or all of the review period.

Service: Software or computing ability provided across a network (e.g., Amazon EC2, Amazon S3).

Service Organization: An organization or segment of an organization that provides services to user entities that are likely to be relevant to those user entities’ internal control over financial reporting.

Signature Version 4: Signature Version 4 is the process to add authentication information to AWS requests. For security, most requests to AWS must be signed with an access key, which consists of an access key ID and secret access key.

Subservice Organization: A service organization used by another service organization to perform some of the services provided to user entities that are likely to be relevant to those user entities’ internal control over financial reporting.

Virtual Instance: Once an AMI has been launched, the resulting running system is referred to as a virtual instance. All instances based on the same AMI start out identical and any information on them is lost when the instances are terminated or fail.

X.509: In cryptography, X.509 is an ITU-T standard for a Public Key Infrastructure (PKI) for Single Sign-On (SSO) and Privilege Management Infrastructure (PMI). X.509 specifies, among other things, standard formats for public key certificates, certificate revocation lists, attribute certificates and a certification path validation algorithm.

**Appendix II - General Engagement Terms for Wirtschaftsprüferinnen, Wirtschaftsprüfer and
Wirtschaftsprüfungsgesellschaften [German Public Auditors and Public Audit Firms] as of
January 1, 2024**

General Engagement Terms

for

Wirtschaftsprüferinnen, Wirtschaftsprüfer and Wirtschaftsprüfungsgesellschaften

[German Public Auditors and Public Audit Firms]

as of January 1, 2024

1. Scope of application

(1) These engagement terms apply to contracts between German Public Auditors (Wirtschaftsprüferinnen/Wirtschaftsprüfer) or German Public Audit Firms (Wirtschaftsprüfungsgesellschaften) – hereinafter collectively referred to as "German Public Auditors" – and their engaging parties for assurance services, tax advisory services, advice on business matters and other engagements except as otherwise agreed in writing (Textform) or prescribed by a mandatory rule.

(2) Third parties may derive claims from contracts between German Public Auditors and engaging parties only when this is agreed or results from mandatory rules prescribed by law. In relation to such claims, these engagement terms also apply to these third parties. A German Public Auditor is also entitled to invoke objections (Einwendungen) and defences (Einreden) arising from the contractual relationship with the engaging party to third parties.

2. Scope and execution of the engagement

(1) Object of the engagement is the agreed service – not a particular economic result. The engagement will be performed in accordance with the German Principles of Proper Professional Conduct (Grundsätze ordnungsmäßiger Berufsausübung). The German Public Auditor does not assume any management functions in connection with his services. The German Public Auditor is not responsible for the use or implementation of the results of his services. The German Public Auditor is entitled to make use of competent persons to conduct the engagement.

(2) Except for assurance engagements (betriebswirtschaftliche Prüfungen), the consideration of foreign law requires an express agreement in writing (Textform).

(3) If circumstances or the legal situation change subsequent to the release of the final professional statement, the German Public Auditor is not obligated to refer the engaging party to changes or any consequences resulting therefrom.

3. The obligations of the engaging party to cooperate

(1) The engaging party shall ensure that all documents and further information necessary for the performance of the engagement are provided to the German Public Auditor on a timely basis, and that he is informed of all events and circumstances that may be of significance to the performance of the engagement. This also applies to those documents and further information, events and circumstances that first become known during the German Public Auditor's work. The engaging party will also designate suitable persons to provide information.

(2) Upon the request of the German Public Auditor, the engaging party shall confirm the completeness of the documents and further information submitted as well as the explanations and statements provided in a statement as drafted by the German Public Auditor in a legally accepted written form (gesetzliche Schriftform) or any other form determined by the German Public Auditor.

4. Ensuring independence

(1) The engaging party shall refrain from anything that endangers the independence of the German Public Auditor's staff. This applies throughout the term of the engagement, and in particular to offers of employment or to assume an executive or non-executive role, and to offers to accept engagements on their own behalf.

(2) Were the performance of the engagement to impair the independence of the German Public Auditor, of related firms, firms within his network, or such firms associated with him, to which the independence requirements apply in the same way as to the German Public Auditor in other engagement relationships, the German Public Auditor is entitled to terminate the engagement for good cause.

5. Reporting and oral information

To the extent that the German Public Auditor is required to present results in a legally accepted written form (gesetzliche Schriftform) or in writing (Textform) as part of the work in executing the engagement, only that

presentation is authoritative. Drafts of such presentations are non-binding. Except as otherwise provided for by law or contractually agreed, oral statements and explanations by the German Public Auditor are binding only when they are confirmed in writing (Textform). Statements and information of the German Public Auditor outside of the engagement are always non-binding.

6. Distribution of a German Public Auditor's professional statement

(1) The distribution to a third party of professional statements of the German Public Auditor (results of work or extracts of the results of work whether in draft or in a final version) or information about the German Public Auditor acting for the engaging party requires the German Public Auditor's consent be issued in writing (Textform), unless the engaging party is obligated to distribute or inform due to law or a regulatory requirement.

(2) The use by the engaging party for promotional purposes of the German Public Auditor's professional statements and of information about the German Public Auditor acting for the engaging party is prohibited.

7. Deficiency rectification

(1) In case there are any deficiencies, the engaging party is entitled to specific subsequent performance by the German Public Auditor. The engaging party may reduce the fees or cancel the contract for failure of such subsequent performance, for subsequent non-performance or unjustified refusal to perform subsequently, or for unconscionability or impossibility of subsequent performance. If the engagement was not commissioned by a consumer, the engaging party may only cancel the contract due to a deficiency if the service rendered is not relevant to him due to failure of subsequent performance, to subsequent non-performance, to unconscionability or impossibility of subsequent performance. No. 9 applies to the extent that further claims for damages exist.

(2) The engaging party must assert a claim for subsequent performance (Nacherfüllung) in writing (Textform) without delay. Claims for subsequent performance pursuant to paragraph 1 not arising from an intentional act expire after one year subsequent to the commencement of the time limit under the statute of limitations.

(3) Apparent deficiencies, such as clerical errors, arithmetical errors and deficiencies associated with technicalities contained in a German Public Auditor's professional statement (long-form reports, expert opinions etc.) may be corrected – also versus third parties – by the German Public Auditor at any time. Misstatements which may call into question the results contained in a German Public Auditor's professional statement entitle the German Public Auditor to withdraw such statement – also versus third parties. In such cases the German Public Auditor should first hear the engaging party, if practicable.

8. Confidentiality towards third parties, and data protection

(1) Pursuant to the law (§ [Article] 323 Abs 1 [paragraph 1] HGB [German Commercial Code: Handelsgesetzbuch], § 43 WPO [German Law regulating the Profession of Wirtschaftsprüfer: Wirtschaftsprüferordnung], § 203 StGB [German Criminal Code: Strafgesetzbuch]) the German Public Auditor is obligated to maintain confidentiality regarding facts and circumstances confided to him or of which he becomes aware in the course of his professional work, unless the engaging party releases him from this confidentiality obligation.

(2) When processing personal data, the German Public Auditor will observe national and European legal provisions on data protection.

9. Liability

(1) For legally required services by German Public Auditors, in particular audits, the respective legal limitations of liability, in particular the limitation of liability pursuant to § 323 Abs. 2 HGB, apply.

(2) Insofar neither a statutory limitation of liability is applicable, nor an individual contractual limitation of liability exists, claims for damages due to negligence arising out of the contractual relationship between the

engaging party and the German Public Auditor, except for damages resulting from injury to life, body or health as well as for damages that constitute a duty of replacement by a producer pursuant to § 1 ProdHaftG [German Product Liability Act: Produkthaftungsgesetz], are limited to € 4 million pursuant to § 54 a Abs. 1 Number 2 WPO. This applies equally to claims against the German Public Auditor made by third parties arising from, or in connection with, the contractual relationship.

(3) When multiple claimants assert a claim for damages arising from an existing contractual relationship with the German Public Auditor due to the German Public Auditor's negligent breach of duty, the maximum amount stipulated in paragraph 2 applies to the respective claims of all claimants collectively.

(4) The maximum amount under paragraph 2 relates to an individual case of damages. An individual case of damages also exists in relation to a uniform damage arising from a number of breaches of duty. The individual case of damages encompasses all consequences from a breach of duty regardless of whether the damages occurred in one year or in a number of successive years. In this case, multiple acts or omissions based on the same source of error or on a source of error of an equivalent nature are deemed to be a single breach of duty if the matters in question are legally or economically connected to one another. In this event the claim against the German Public Auditor is limited to € 5 million.

(5) A claim for damages expires if a suit is not filed within six months subsequent to the written statement (Textform) of refusal of acceptance of the indemnity and the engaging party has been informed of this consequence. This does not apply to claims for damages resulting from scienter, a culpable injury to life, body or health as well as for damages that constitute a liability for replacement by a producer pursuant to § 1 ProdHaftG. The right to invoke a plea of the statute of limitations remains unaffected.

(6) § 323 HGB remains unaffected by the rules in paragraphs 2 to 5.

10. Supplementary provisions for audit engagements

(1) If the engaging party subsequently amends the financial statements or management report audited by a German Public Auditor and accompanied by an auditor's report (Bestätigungsvermerk), he may no longer use this auditor's report.

If the German Public Auditor has not issued an auditor's report, a reference to the audit conducted by the German Public Auditor in the management report or any other public reference is permitted only with the German Public Auditor's consent, issued in a legally accepted written form (gesetzliche Schriftform), and with a wording authorized by him.

(2) If the German Public Auditor revokes the auditor's report, it may no longer be used. If the engaging party has already made use of the auditor's report, then upon the request of the German Public Auditor he must give notification of the revocation.

(3) The engaging party has a right to five official copies of the report. Additional official copies will be charged separately.

11. Supplementary provisions for assistance in tax matters

(1) When advising on an individual tax issue as well as when providing ongoing tax advice, the German Public Auditor is entitled to use as a correct and complete basis the facts provided by the engaging party – especially numerical disclosures; this also applies to bookkeeping engagements. Nevertheless, he is obligated to indicate to the engaging party any material errors he has identified.

(2) The tax advisory engagement does not encompass procedures required to observe deadlines, unless the German Public Auditor has explicitly accepted a corresponding engagement. In this case the engaging party must provide the German Public Auditor with all documents required to observe deadlines – in particular tax assessments – on such a timely basis that the German Public Auditor has an appropriate lead time.

(3) Except as agreed otherwise in writing (Textform), ongoing tax advice encompasses the following work during the contract period:

- a) preparation and electronic transmission of annual tax returns, including financial statements for tax purposes in electronic format, for income tax, corporate tax and business tax, namely on the basis of the annual financial statements, and on other schedules and evidence documents required for the taxation, to be provided by the engaging party
- b) examination of tax assessments in relation to the taxes referred to in (a)
- c) negotiations with tax authorities in connection with the returns and assessments mentioned in (a) and (b)
- d) support in tax audits and evaluation of the results of tax audits with respect to the taxes referred to in (a)
- e) participation in petition or protest and appeal procedures with respect to the taxes mentioned in (a).

In the aforementioned tasks the German Public Auditor takes into account material published legal decisions and administrative interpretations.

(4) If the German Public auditor receives a fixed fee for ongoing tax advice, the work mentioned under paragraph 3 (d) and (e) is to be remunerated separately, except as agreed otherwise in writing (Textform).

(5) Insofar the German Public Auditor is also a German Tax Advisor and the German Tax Advice Remuneration Regulation (Steuerberatungsvergütungsverordnung) is to be applied to calculate the remuneration, a greater or lesser remuneration than the legal default remuneration can be agreed in writing (Textform).

(6) Work relating to special individual issues for income tax, corporate tax, business tax and valuation assessments for property units as well as all issues in relation to sales tax, payroll tax, other taxes and dues requires a separate engagement. This also applies to:

- a) work on non-recurring tax matters, e.g. in the field of estate tax and real estate sales tax;
- b) support and representation in proceedings before tax and administrative courts and in criminal tax matters;
- c) advisory work and work related to expert opinions in connection with changes in legal form and other re-organizations, capital increases and reductions, insolvency related business reorganizations, admission and retirement of owners, sale of a business, liquidations and the like, and
- d) support in complying with disclosure and documentation obligations.

(7) To the extent that the preparation of the annual sales tax return is undertaken as additional work, this includes neither the review of any special accounting prerequisites nor the issue as to whether all potential sales tax allowances have been identified. No guarantee is given for the complete compilation of documents to claim the input tax credit.

12. Electronic communication

Communication between the German Public Auditor and the engaging party may be via e-mail. In the event that the engaging party does not wish to communicate via e-mail or sets special security requirements, such as the encryption of e-mails, the engaging party will inform the German Public Auditor in writing (Textform) accordingly.

13. Remuneration

(1) In addition to his claims for fees, the German Public Auditor is entitled to claim reimbursement of his expenses; sales tax will be billed additionally. He may claim appropriate advances on remuneration and reimbursement of expenses and may make the delivery of his services dependent upon the complete satisfaction of his claims. Multiple engaging parties are jointly and severally liable.

(2) If the engaging party is not a consumer, then a set-off against the German Public Auditor's claims for remuneration and reimbursement of expenses is admissible only for undisputed claims or claims determined to be legally binding.

14. Dispute Settlement

The German Public Auditor is not prepared to participate in dispute settlement procedures before a consumer arbitration board (Verbraucherschlichtungsstelle) within the meaning of § 2 of the German Act on Consumer Dispute Settlements (Verbraucherstreitbeilegungsgesetz).

15. Applicable law

The contract, the performance of the services and all claims resulting therefrom are exclusively governed by German law.